Eberhard von Faber

Managing IT Service Security

Methods and Recipes for User Organizations and Providers Along the Supply Chain

Springer

Managing IT Service Security

Eberhard von Faber

Managing IT Service Security

Methods and Recipes for User Organizations and Providers Along the Supply Chain

Springer

Eberhard von Faber
Brandenburg University of Applied Science
Brandenburg, Germany

ISBN 978-3-031-55532-9 ISBN 978-3-031-55533-6 (eBook)
https://doi.org/10.1007/978-3-031-55533-6

© The Editor(s) (if applicable) and The Author(s), under exclusive license to Springer Nature Switzerland AG 2024
This work is subject to copyright. All rights are solely and exclusively licensed by the Publisher, whether the whole or part of the material is concerned, specifically the rights of translation, reprinting, reuse of illustrations, recitation, broadcasting, reproduction on microfilms or in any other physical way, and transmission or information storage and retrieval, electronic adaptation, computer software, or by similar or dissimilar methodology now known or hereafter developed.
The use of general descriptive names, registered names, trademarks, service marks, etc. in this publication does not imply, even in the absence of a specific statement, that such names are exempt from the relevant protective laws and regulations and therefore free for general use.
The publisher, the authors, and the editors are safe to assume that the advice and information in this book are believed to be true and accurate at the date of publication. Neither the publisher nor the authors or the editors give a warranty, expressed or implied, with respect to the material contained herein or for any errors or omissions that may have been made. The publisher remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

This Springer imprint is published by the registered company Springer Nature Switzerland AG
The registered company address is: Gewerbestrasse 11, 6330 Cham, Switzerland

If disposing of this product, please recycle the paper.

Preface

Ensuring the IT security or cybersecurity of IT services can be a complex undertaking. Adequately assessing the level of IT service security achieved is no less so. The larger the IT production and the more diverse and complex the IT services, the more confusing these tasks become.

People do not want to read extensive documents that mainly contain information that is not relevant for them. Yet, in practice a lot of documents are required to instruct employees on how to care for IT security in their respective work areas. But how to manage all these details so that they are correct and consistent?

This book is for IT service providers (including IT departments), user organizations (including business units) as well as for manufacturers, vendors etc. insofar as the IT is rather complex.

This book is about managing IT security, or more precisely, managing the security of IT services in terms of organization, orchestration, and optimization.

The primary task of an organization's management is to create the necessary conditions for defined goals to be achieved. Managers instruct experts to do their work. Primarily, however, they have to CREATE THE NECESSARY CONDITIONS that enable employees to WORK EFFECTIVELY (i.e., to achieve common goals) and EFFICIENTLY (i.e., with the least possible use of resources and time). In larger organizations, one creates the necessary conditions for effectiveness and efficiency by first creating organizational forms such as processes and divisions of topics and task areas. This is precisely the goal and content of this book.

The book describes a management system called ESARIS (Enterprise Security Architecture for Reliable ICT Services). This metasystem or security architecture builds on more than a decade of day-to-day experience in the IT industry with multi-national customers. The methods and recipes are field-proven.

The book is a compendium that compresses the complex subject matter into individual terms and their definition. This ensures, that we really get to the point. Explicit DEFINITIONS ARE PROVIDED FOR ABOUT 75 TERMS which can be used to look up a topic. FORTY-ONE FIGURES as well as ELEVEN TABLES further support orientation and understanding. Of course, detailed introductions and explanations are also given. Connections between the terms and topics are revealed by the sequence and hierarchy of the terms as well as by references and intermediate texts. The overall context is already apparent from the more general terms at the beginning. The understanding is further deepened the more details subsequent descriptions provide.

ARE YOU WONDERING what is so complicated about 'IT service security' and why it takes a book to explain how to 'manage' it? Below you will find a simple example of four types of compliance. All four are important to both the user and the IT service provider. This alone adds to the complexity. But the example also shows how they can be mastered with a bit of systematics.

WHY 'IT SERVICE SECURITY' IS MORE COMPLEX than one might think... One example:

Compliance is a trend, a must or simply something very fundamental. Because goals, targets, standards, and the like are meaningless if you do not also check whether they are achieved or complied with, i.e. you have been able to establish compliance. And without goals, targets, standards and the like, everything is arbitrary and therefore useless.

Fig. 0.1 illustrates which compliance must be checked and ensured so that an IT service (top right in red) complies with the contractual promises (in yellow on the left). There are four types or formations of target-actual pairs for which compliance must be checked. This is what the user (customer) expects and the IT service provider must establish and verify (with support from its suppliers).

We discuss all four cases one after the other in the shortness offered at this point. (Further down in the book, the terms and contexts will be explained in more detail).

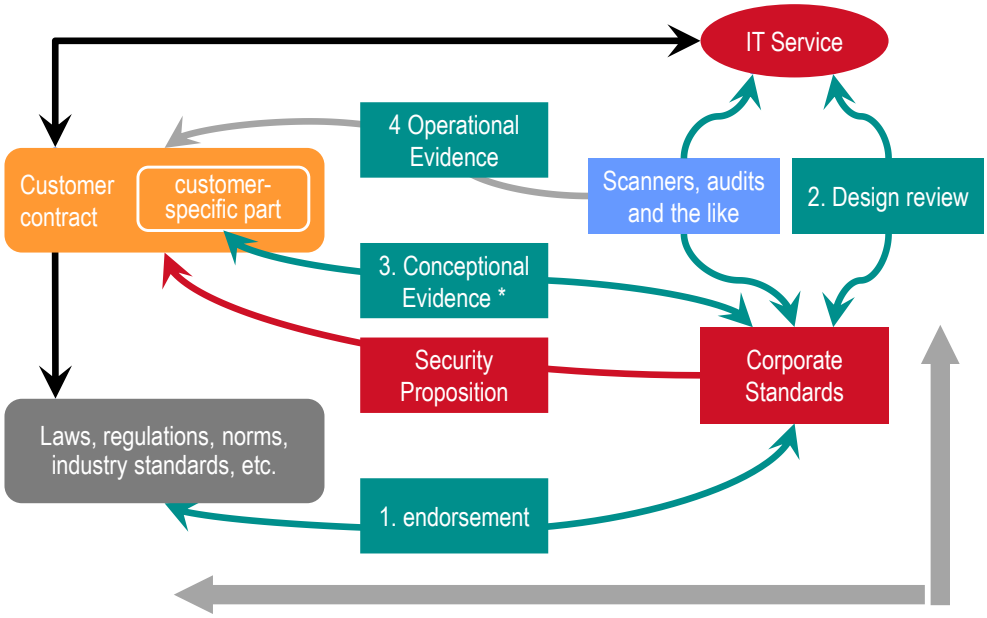


Fig. 0.1: Four ways of determining the compliance of an IT service

1. Endorsement (see Fig. 0.1): User organizations themselves must comply with laws, regulations, standards, and the like, and some of these requirements may affect IT that they do not produce themselves but obtain from an IT service provider. Following its own standards (corporate standards, see Fig. 0.1), the IT service provider ensures that the IT services are secure. The provider will therefore check in advance whether its own standards are sufficient to meet the customer's requirements that arise for it from certain laws, regulations, standards, and the like.

The user organizations (customers) receive information on the IT security of the IT services (see Security Proposition in Fig. 0.1) that are based on the standards of the IT service provider.

2. Design reviews (see Fig. 0.1): The IT service provider develops and implements its IT services. Its own standards are the basis for this and determine how they are secured. As part of quality assurance, it must check whether and to what extent the applicable standards were actually implemented during development and implementation. This is the second compliance area.

3. Conceptual evidence (see Fig. 0.1): Larger user organizations in particular often have their own ideas and requirements for IT service security. This can have very different reasons. But IT is rarely completely identical and 'one size fits it all' does not always apply in IT security either. In these cases, it must be checked whether the customer-specific requirements can be met. This third form of compliance is only relevant in the case of customer-specific contracts or contract clauses.

4. Operational evidence (see Fig. 0.1): If everything is correct up to this point, the contract can be signed and the IT service provider can deliver the IT service. However, IT is constantly changing, the threat situation may also change, and the IT security measures must be continuously checked to ensure that they are sufficiently effective. Therefore, both the IT service provider itself and the user organization need and expect appropriate checks and reports on their results, usually in the form of security reports. These compliance checks are usually highly automated.

The four cases have only been sketched cursorily here. They are intended to show that there are various sources (for specifications) and several types of verification (of compliance). This alone is one of the reasons for more complexity in securing business IT services and their use.

However, the example is also intended to illustrate how this book uses systematics and terminology to create order, illuminate relationships, and provide concrete support for implementing IT service security successfully and with an eye for the essentials.

All 41 figures and possibly further supplementary material are available as a PowerPoint file. Contact the author by email or via LinkedIn.

The author has decided to use the concept of his books from 2021 and 2023:

- The core of information on a topic is given by means of term definitions. These are sorted hierarchically. Subsequent ones expand and refine already explained terms and contexts.
- By means of giving a definition not only a term but a 'matter' is explained, sometimes also fully explaining other terms that are important in this context.
- The individual explanations of terms are lexicon-like, i.e. mostly short and precise. This suits readers who are used to processing snippets of information, which they then piece together step by step.
- Each topic is accompanied by generally understandable introductions, which above all provide the context that makes it easier to establish a practical connection and invites to explore the possibilities for own use.

Structuring by terms has great advantages:

- It facilitates the exchange of information enormously. If one uses these terms, it is ruled out from the outset that experts spend valuable time on a long discussion only to finally find out that (once again) they have completely missed each other's point because everyone started from a different situation or constellation.
- Most of the terms used in this book are not common property. Rather, they were chosen by the author to divide the complex undertaking of 'IT service security' into individual small sections, to make it manageable and easier to understand.

Boldface is used for the term when it is explained at this point. *Italics indicate* that the term is explained elsewhere. SMALL CAPS are used for emphasis. If the reader is unable to find a particular term definition, it is recommended to consult the index at the end of the book.

Since the eBook is also available by chapter, references to sources and further reading are repeated from time to time. This is also deemed necessary because sometimes even unmarked self-citations are considered problematic. This book contains earlier text and illustrative material of the author.

Thank you very much if you HAVE already BOUGHT this book. It takes a lot of work to write such a book. Feel free to recommend the book to others if you find it useful. But PLEASE DO NOT copy it.

IS SOMETHING MISSING? DO YOU DISAGREE? Send me an email at ESARIS@t-online.de!

Eberhard von Faber

Table of Contents

1 The Environment 1
1.1 Subject: IT as a Service 2
1.2 Some Technology: Cloud and Containers 7
1.3 Supply Chain: the Parties Involved 9
1.4 Life cycle: Business Relationship and IT 13
1.5 Processes and Workflows: IT Service Management (ITSM) 16
1.6 Outlook: Two IT Service Providers and the Supply Chain 21
Bibliography 23

2 The Metasystem 25
2.1 Basic Structure 26
2.2 Two Tasks or Twice Three Tasks 27
2.2.1 Define and Implement Standards (Attainment: Overview) 27
2.2.2 Meeting Customer Requirements (Fulfillment: Overview) 30
2.2.3 Summary 32
2.3 Attainment 33
2.3.1 Define and Maintain Standards (Details) 33
2.3.2 Be Able to Inform Customers (Overview) 37
2.4 Fulfillment 39
2.4.1 Providing IT Services Securely 39
2.4.2 Improve IT Service Security 44
2.5 Summary 46
Bibliography 48

3 Assurance Management 51
3.1 The Character of Services and the Consequences 52
3.2 The Two Faces of Being Sure 55
3.3 Provide and Manage IT Security Information 56
3.4 Organization 59
Bibliography 62

4 Taxonomy 65
4.1 Introduction 66
4.2 Goals and Rationale 66
4.3 Overview 68
4.4 Application 70
4.5 Details 71
4.5.1 Practices 72

4.5.2 Inventory Management 78
4.5.3 Technologies 80
4.6 Summary and Outlook 86
Bibliography 87

5 Document and Library Structure 89
5.1 Goals and Document-Related Solutions 90
5.2 Goals and Library-Related Solutions 95
5.3 More Suggestions 98
Bibliography 102

6 Secured by Definition 103
6.1 IT Security and Quality Management 104
6.2 IT Security and Processes 106
6.3 The Method 107
6.4 Implementation 110
6.5 Advantages and Final Remarks 115
Bibliography 116

7 Supply-Chain Relationship Management 119
7.1 Subject Matter and Relation to the Taxonomy 121
7.2 Environment and Problem Statement 122
7.3 Elements of the Concept 125
7.4 Provider Scope of Control 127
7.5 Security Proposition 131
7.6 Application 135
Bibliography 139

8 Cyber-Physical Systems (IoT and OT) 141
8.1 Subject 142
8.2 Taxonomy for Cyber-physical Systems 144
8.3 Profiles of New Taxonomy Areas for Cyber-Physical Systems 148
8.4 Classes, Zones, and Integration Stack 151
8.5 Application and Outlook 157
Bibliography 159

9 Perception, Knowledge, Competencies 161
9.1 Perception 162
9.2 Knowledge and Competencies 165
Bibliography 166

10 Index 167

About the Author

Eberhard von Faber studied electrical engineering and physics and earned his doctorate in the field of semiconductor physics. He is Chief Security Advisor, IT Services, at T-Systems and a part-time professor for IT security.

In January 1992, he began his career in the industry as a security systems developer. He developed CryptCard, the world's first hardware-based security system for notebook computers including all highly integrated electronical chips.

He then worked in various fields in security engineering, security consulting and the security evaluation of products and solutions. In 1995/1996, he demonstrated that the DES cryptographic algorithm can be broken by a brute-force attack using hardware he designed for this purpose. It was then decided to replace the algorithm in all components of card-based payment systems.

Eberhard has long been active as an evaluator. Specifically, he investigated the security of chips used worldwide in payment systems. He developed some sophisticated, mostly invasive new attack techniques. He is the principal author of an international standard for integrated circuit security. He built up the business of evaluations according to ITSEC and later Common Criteria, and headed the internationally active, commercial security testing laboratory.

As head of staff of a business unit of an IT group specializing in IT security services and solutions, he was responsible for strategy and business development. He then worked as Offering Manager for IT Security and later as Executive Consultant.

At the end of 2010, Eberhard took on the task of improving and completely reorganizing the IT service security at T-Systems. He developed dozens of new methods and standards and improved transparency, effectiveness, and efficiency. This resulted in the *ESARIS* security architecture.

Eberhard is the author of several books and is responsible for more than 170 publications and conference contributions. His special interest is the efficient execution of IT security, the implementation in complex delivery networks and the relationship between customers and IT service providers.

Editorial Note

Chapters 1-6 and 9 are modified translations from the author's German book "IT-Service-Security in Begriffen und Zusammenhängen" (ISBN 978-3-658-41932-5). The translation was done by the author with the help of DeepL Translator from Cologne, Germany (https://www.deepl.com/translator).

1 The Environment

Is securing IT services really that complicated? To understand why, we look at an example from another industry. Fig. 1.1 shows two airplanes. On which one do we need to do more for safety/security? For the Airbus A380, of course (shown on the right). And why? Not because the two-seater (left) is much cheaper and offers fewer options than the world's largest commercial aircraft. The A380 must do much more! That is why the safety/security measures are incomparably more extensive. Examples of this are included in the figure. The same applies to IT and *IT services*: The higher and farther you fly, the greater the demands on IT security. But much more has changed in IT than just size and reach. This introductory chapter explains what it means to provide IT services instead of selling products, how today's IT including cloud and container works in principle, and why supply chain complexity not a side issue. It is briefly described how modern IT services are deployed and maintained, how the user organization comes into play and how IT security is related to IT service management.

In which case do we need to do more for safety/security? And why?	
Left: Two people; short distance only; good weather; flies "slowly"; a few hundred feet altitude, one or only a few "airports"; sporadic use; private or charter.	Right: up to 800 people; worldwide operation; long distance; all weather conditions; goes fast; 10,000 meters altitude, almost all airports; constantly in use; public commercial service

Fig. 1.1: Case study comparison of two aircraft

© The Author(s), under exclusive license to Springer Nature Switzerland AG 2024
E. von Faber, *Managing IT Service Security*, https://doi.org/10.1007/978-3-031-55533-6_1

The 'Cloud' began with the customer promise of high standardization and rapid deployment. 'Simplicity' and 'IT as if from a power socket' were buzzwords. The image of an opaque cloud hovering over everything suggested that it would not be necessary to know the details. Today, however, the reality is completely different. The technology is highly complex, and the options are more diverse than ever.

At the same time, the demands on IT and also on IT security have increased. Both factors have to do with the fact that IT is being used in ever larger areas of application. Whereas it was initially limited to a few central business applications in the 'back office', IT applications soon became mobile, networking increased greatly, and the centralization of data storage and processing experienced a renaissance, and finally these models captured ever new areas of application.

All this has not made IT security simpler, but initially much more complex. Today, attempts are being made to combine and centralize IT security functions in cloud-based security solutions in order to reduce complexity for users. However, this does not fundamentally change the fact that the complexity still exists. The industrialization of IT, however, is leading to a major shift in responsibilities within the supply chain or supply network. As a result, each party can focus on specific IT security problems and issues, depending on the current technology and the associated division of labor. However, in terms of a comprehensive, end-to-end approach, important problems and issues remain: Which set of individual IT security solutions is adequate for a given application, and which parties should provide which services? The selection of IT security solutions is not made any easier by the constant progress and change in the market and does not answer the question of who is responsible for the IT security of the overall construct.

How should the security architecture be designed? The information technology (IT) in a data center usually does not show what it is used for and what it accomplishes. And each device in turn consists of many components, mostly in the form of software and therefore hidden from view. IT users see their screen and keyboard along with the mouse. How much is done by the local computer itself and what is done remotely in the data center is often hardly apparent. IT is very abstract. When it comes to safeguarding this abstract world, knowledge of the logical structure with chains of effects and processes is necessary. In the following, we want to develop the imagination and structure the world of IT a little.

1.1 Subject: IT as a Service

It was not until the beginning of the 2000s that there was a shift towards 'IT as a service'. What is meant by this? Whereas the IT departments of even large companies initially still supplied IT components (products) to install and operate them themselves or with outside help, today an increasing proportion of IT is no longer

purchased, but paid for. The service concept is gaining ground, and this has far-reaching consequences. Unlike a product, production takes place at the same time as use. *IT services* are provided continuously; the type of production is different. IT products, and thus also the IT systems made from them, have predominantly fixed properties at the time of installation and also afterwards, which they basically also retain [1]. In the case of 'IT as a service', on the other hand, it is primarily the function that is purchased. The underlying realization (technology) can change. Since service contracts often run for several years, it is likely that changes will be necessary and will take place.

But one very consequential difference concerns the loss of transparency and influence [2]. Risks regarding IT security are associated with any type of service delivery. In order to make a business decision about whether the user organization is willing to accept them (or improvements are needed), one needs knowledge about the security level.

Therefore, there are two real issues [2]:

A) the existence of unacceptable risks (i.e., lack of IT security) and

B) lack of knowledge about existing risks or the integrated security measures (lack of trustworthiness, or insufficient assurance).

Using IT services produced and provided by third parties may well improve IT security (A), but the knowledge on the part of the *user organization* (B, the 'trustworthiness' or 'assurance') decreases system-inherently if no systematic countermeasures are taken. Now this situation is relatively 'new' at best for IT. Outsourcing to third-party service providers began much earlier in other lines of business. The commercialization of aviation is a good example. Here, too, by the way, the passenger (user) bears the greatest risk, while only the manufacturer of the aircraft and the operator (the airline) can ensure that the risks are small and remain controllable. It is the same with IT services. However, the governments of leading countries have ensured with very rigid regulations that aircrafts crash extremely rarely. Unfortunately, the same cannot be said of IT. In general, the quality of IT is much poorer. This also applies to IT security.

Can *user organizations* rely on the IT security of third-party services at all? Of course, because larger, specialized IT companies can usually ensure quality better than smaller teams with limited resources. However, this does not mean that user organizations can use third-party services unconditionally without any precaution and rely on their IT security. They need to know and assess the risks. And they need ways to influence IT security - at least through their purchasing decisions by choosing one service over another.

The term 'security measures' is extensively used in this book. That is why a definition is given now before proceeding with considering IT in general.

Security measure

> Precautions taken to reduce risks as well as to identify and comprehend any circumstance that may indicate risks (i.e., the possible loss of confidentiality, integrity, or availability). Security measure is synonymous with security control. Security measures can be administrative, organizational, process-related, technical, or legal in nature.
>
> Checking and monitoring whether other security measures, for example technical security measures, have been implemented and are effective should also be defined as a security measure. Only then will a complete catalog of security measures be created.

In very simplified terms, nowadays 'IT' looks as shown in Fig. 1.2. The very largest part of IT is located in data centers. Sometimes the data center is operated by the *user organization* itself (left), but usually by *IT service providers* (on the right). The 'cloud' also consists of computers located in data centers. In all possible cases, users or their end devices are connected to the data centers via networks. This enables them to use the *IT services* offered.

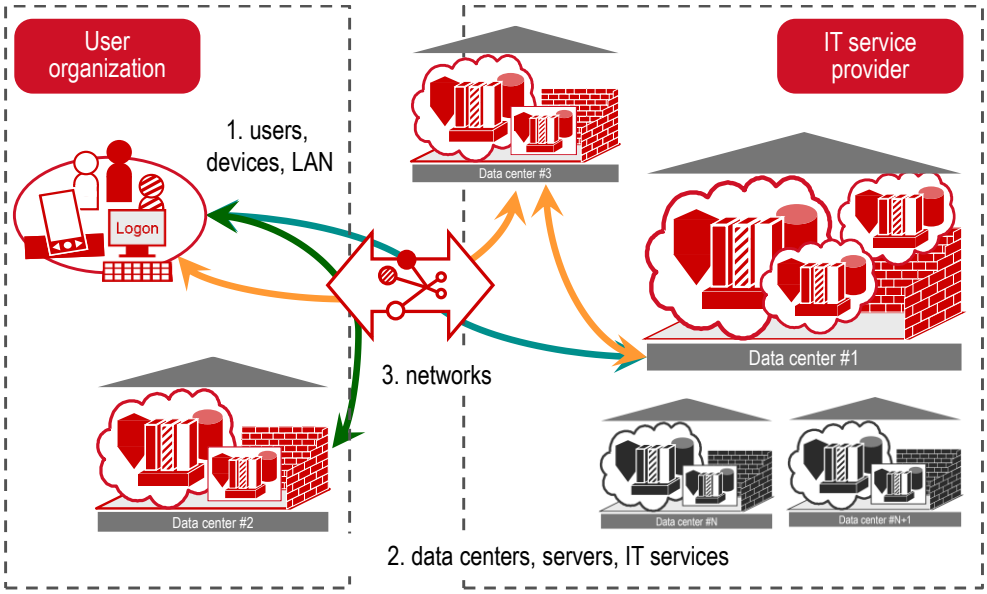


Fig. 1.2: Users, data centers and networks (basic model)

Now, finally, a few explanations of terms or definitions follow. Further explanations can be found below the term definitions.

NOTE: The following definitions are taken from the author's encyclopedia [3].

IT service (overview)

IT stands for information technology (IT). An IT service is provided over a longer period of time with the help of IT. In contrast to products (tangible goods), the benefit arises at the same time as production. A **product** is an asset (object) that has been manufactured for its intended, foreseeable use. Since the use is clearly defined a product (in contrast to a service) can in principle be specified precisely and completely.

Computing Service

Computing services comprise services for the operation of an application software (application) in a data center. In the case of infrastructure services, the *IT service provider* DOES NOT PROVIDE the application itself, but only operates it with the help of various IT and network components. Computing services essentially have three performance parameters or basic components: computing capacity (compute), storage capacity (storage) and network capacity (network).

Computing services are often simply called *IT services*. They are very diverse and differ primarily in terms of the service that the *IT service provider provides* deliver to the user or the *user organization*. The → *Service Model* classify IT services and define their most important groups or types.

Service Model

The Service Model is a characteristic of an *IT service*. There are different Service Models. Each Service Model characterizes which activities are part of the IT service and which IT components provide functionalities that are directly part of the IT service. The activities, functionalities and IT components are highly abstracted, so that roughly a dozen types or models can be distinguished.

The Service Models differ in terms of the IT components and activities for which the *IT service provider* bears responsibility. Since the IT stack is always complete and most of the activities always have to be performed, the user or the *user organization* must take care of the missing IT components and activities.

The last two explanations of terms have pointed to two realities that make IT security a complex undertaking even today:

1) Cost pressure, standardization, product success, compatibility, monopolies, and singular technologies[1] do indeed lead to standardization in IT. Nevertheless, there are many different IT services, because the requirements of the users or

[1] This refers to technologies for which there are no or only few alternatives. No fixed terminology!

user organizations are very different.[2] In many industries, IT has become a decisive competitive advantage. If all competing companies would use the same IT (the same IT services), there could be no clear differentiation through the use of IT.

2) IT consists of many function-providing parts (technical components) that are stacked on top of and sometimes next to each other. In addition, there are many supporting components for monitoring and maintenance. Very often, not all parts (components) are provided by and are the responsibility of the IT service provider. This is more often true the more specialized the business transactions or business applications to be supported are. For example, large companies bring their application software (application) or have it created by another IT specialist and/or configured specifically for them. It may also be necessary to purchase additional IT services from other IT service providers and link these to the original core service. One example is additional IT security solutions for cloud services, for example in the form of a cloud security gateway.

3) Many activities, some of them quite extensive, are required to install, integrate, operate, and maintain the necessary parts (technical components), i.e., to provide IT services with consistent quality and to deliver corresponding evidence. Various IT service providers do not offer a complete service here, so that certain activities are left to the user organization, which needs its own IT personnel for this or must commission another IT specialist. This reduction by the IT service provider can have various reasons: Business model, indication of lower prices, no own capacities, etc. However, since many of the activities are required to establish and maintain IT security, the division of labor (the *Service Model*) is an important factor for the user organization.

All this makes IT security management quite complex - even today. For the user organization, because of the diversity and specifics of IT services. For the IT service provider, this is also true in principle, but there is also the complexity of the internal and external supply chain because an IT service provider is dependent on various trades as well as many manufacturers, whose contributions must be adequately managed and integrated.

---

[2] This is not limited to IT either and also applies elsewhere, for example to safety: Cars are built from standardized components. In most cases, however, the car finally purchased differs from the many others of the same make and type. One person chooses airbags everywhere, while another buyer is fully satisfied with airbags for the driver and front passenger.

1.2 Some Technology: Cloud and Containers

NOTE: This chapter is based on an earlier article by the author [4].

How is the IT in the data center typically structured and how are cloud services and container services provided?

Basically, a 'cloud' is a collection of many computer systems that are interconnected and centrally controlled. The approximate technical structure is important for understanding which IT security measures are necessary and what they can achieve. The computing technology in the data center is built up in layers that form an IT stack, which we extend somewhat to the right. See Fig. 1.3.

The data center networks (No. 2 in Fig. 1.3) form a fabric that connects computer systems (servers, No. 3-9), central 'hard disk' storage (No. 4) and the central management and control system (No. 10) with each other and, via network access points (No. 1), with a wide-area network (and often the Internet).

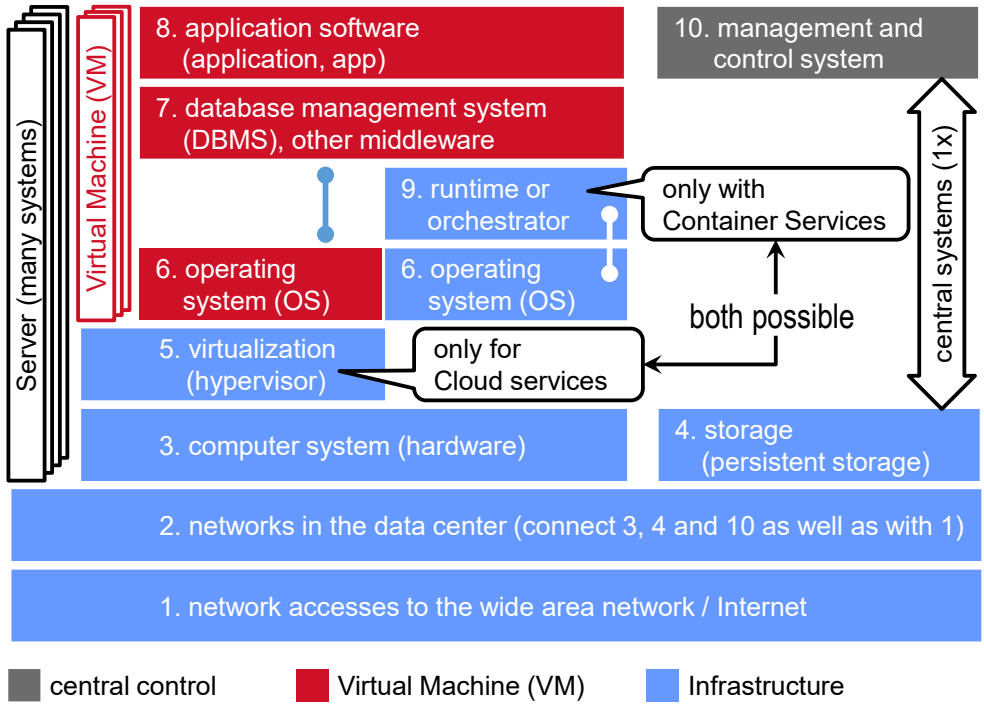


Fig. 1.3: Basic structure of a cloud and container solutions

Basically, one always wants to run application software (No. 8). For this one often needs data base systems and further software components (No. 7), which supplement functions of the operating system (No. 6). The operating system executes the

applications and provides important functions for them. Networks enable computer systems to communicate with each other, so that application software (in a data center) can be used at all.

But back to the cloud. The layers with the numbers 1-5 belong to the infrastructure in the narrower sense. Layers 6-8 form the workload, which in the cloud is called a virtual machine (VM). The infrastructure is the host, the virtual machines (VM) are the guests.

Clouds are FIRSTLY capable of hosting multiple applications independently and separately from one another (multi-tenancy). This means that several users or user organizations share one infrastructure. This in turn means that the IT components of the infrastructure process the data of different users. Multiple virtual machines (VMs) can share a physical computer. To make this work, there is a virtualization layer (No. 5), which provides each application software or VM with the resources (computing, storage, and network capacity) required at the time.

Clouds optimize resource utilization and SECONDLY achieve high scalability. The assigned system resources can grow easily and quickly with higher performance requirements, and also shrink accordingly. To make this work, there is a cloud management system (No. 10) that allows the resources of the guest systems or virtual machines (VMs) to be controlled. The cloud management system has direct access to the virtualization layer (No. 5) and the storage (No. 4), so that guest systems or virtual machines (VMs) can be moved from one computer (server) with outgoing resources to another one with sufficient resources available. For this purpose, the cloud management system (No. 10) provides functions such as deploying, starting, managing, copying, and stopping virtual machines (VMs) (Nos. 6-8).

The application software (application No. 8) can be distributed across several computer systems and clouds. If applications or virtual machines (VMs) move in the data center or cloud instance, the IP addresses move with them. This is achieved by reconfiguring virtual network adapters (software) to respond to the corresponding data traffic. In this way, users can reach their applications no matter where they are running (even if the addresses used externally do not necessarily match those in the data center).

In addition to the cloud, there are container solutions. The focus here is on compatibility or portability (and rapid deployment). Application software (application, No. 8) should be able to run on as many infrastructures as possible (including clouds). It should also be able to be installed and made ready for use as quickly and easily as possible.

The guest systems, which are called 'containers' here (Nos. 7-8, see Fig. 1.3), can therefore run on different infrastructures (No. 1-4 plus No. 6). Several containers can also run on one system; they then share the operating system (No. 6) or its core. The

operating system or an extension of it manages the containers (No. 7-8) and allocates infrastructure resources to them.

Applications can be composed of multiple services that run on different systems and possibly even in different data centers. This requires an intermediate layer (No. 9), which is called Runtime or Orchestrator here. The components of distributed applications need to communicate with each other. This is supported by a central service registry and a management system (No. 10). Provided that the application is appropriately designed, the allocated resources can scale up by deploying more containers. A container solution (No. 9) can run on a cloud infrastructure (No. 1-5). This offers a combination of high scalability and high portability.

The high level of abstraction provided by the intermediate layer (standardization of the infrastructure from the point of view of the guest system) enables software-driven configuration and provisioning of the infrastructure ('infrastructure-as-code'), which further increases portability and simplifies deployment. There are solutions which automatically scale up and down. They are called 'serverless' because users do not have to care about individual computer systems (servers).

These remarks suggest that IT has not become easier with the cloud. Rather, the responsibility for providing IT services is being shifted to a cloud service provider. The same applies to IT security. But the responsibility for the data and the business processes supported by the cloud remains with the user organization that contracts the IT service provider.

1.3 Supply Chain: the Parties Involved

NOTE: This chapter uses descriptions and definitions from the author's encyclopedia [3].

User organizations use IT services from specialized IT service providers. In this process, known as 'IT outsourcing', the responsibility for service provision is transferred to the IT service provider. The IT service provider provides the IT service and is responsible for its quality; i.e., also for ensuring security in the sense of freedom from unaccepted risks.

Although IT outsourcing transfers responsibility for the (security of) IT services to the IT service provider, the associated risk remains with the user organization. More precisely, inadequate security of the IT services represents a business risk for both sides. For the user organization, the risk relates to impairments to the business processes that are operated with the help of the IT services. For the IT service provider, the risk arises from failure to meet the expectations and requirements of its customers, i.e., the user organizations. It is difficult to say whose risk is more important, nor is it the decisive question.

Identification of the acting parties plays a major role because tasks and responsibilities must be assigned. Without a clear idea of the division of labor any specifications lack the connecting factor for their implementation. And without the assignment of responsibility, the discovery of gaps in the implementation would have no consequences.

With regard to the parties involved, this book is based on a simple model with the user organization or the user as the demand side (acquirer) on the one hand and the IT service provider as the supply side (supplier) on the other. The IT service provider also has suppliers such as manufacturers, vendors etc. where the latter also have suppliers and so on. In specific use cases, this model may have to be extended.

User organization

User organizations (group, company, public authority, etc.) form the demand side and assume the role of procuring, acquiring, and utilizing the IT services as a means of supporting their business activities. If the IT services are provided internally by an IT department (internal *IT service provider*, supply side), the term user organization refers to the business units of the organization. However, IT services are often purchased from specialized companies (external *IT service providers*, supply side). In this case, the term user organization refers to the entire organization with all its business units.

Users are persons who use IT services. If it does not matter much if user organizations or persons are meant, the term 'user' can be used encompassing both.

IT service provider

An IT service provider form the supply side and provides IT services within the scope of its primary business activity. Its customers are *user organizations* if it serves the corporate or business customer market, and *users* if it operates in the consumer market. The business model is almost always 'one-to-many': In other words, the IT service provider offers and delivers the IT services to many customers, usually in the same or a similar form.

The relation between the *user organization* (demand side) and the *IT service provider* (supply side) plays a decisive role in this book since the user organizations are ultimately the customers of the entire IT industry. Whenever deeper sections in the supply chain are referred to the term 'supplier' is used for organizations providing IT systems, IT components or even IT services.

Supplier (manufacturer, vendor)

The term 'supplier' is used for companies and other organizations that equip *IT service providers*, as their customers, with IT systems, IT components, products and the like, and even specific IT services. *IT service providers* acquire these and deliver *IT services* to *user organizations* at the end of the supply chain.

In a multi-tier supply chain, companies and other organizations which equip suppliers are also called suppliers.

If *user organizations* are not in focus the term 'supplier' may also cover *IT service providers*.

NOTE: This construction with three tiers builds the basis and is mostly used in this book. Managing IT security along the entire supply chain is subject to Chapter 7 where the terms 'demand side' or 'acquirer' and 'supply side' or 'supplier' are primarily used since these terms are suitable in all tiers of the supply chain.

Fig. 1.4 illustrates the supply chain. At the top (in green), one finds the just-defined terms user (or *user organization*), *IT service provider* and *supplier*. All three parties make up the supply chain with users (user organization), the acquirer (IT service provider) and suppliers (of the IT service provider), each shown in red. The suppliers in turn form a chain that is divided into different tiers. In principle, the same applies to the user side: Many *user organizations* in turn have customers. These can be companies or other organizations. The user of an IT service is ultimately a person as a member of an organization, as a citizen, consumer or in some other role.

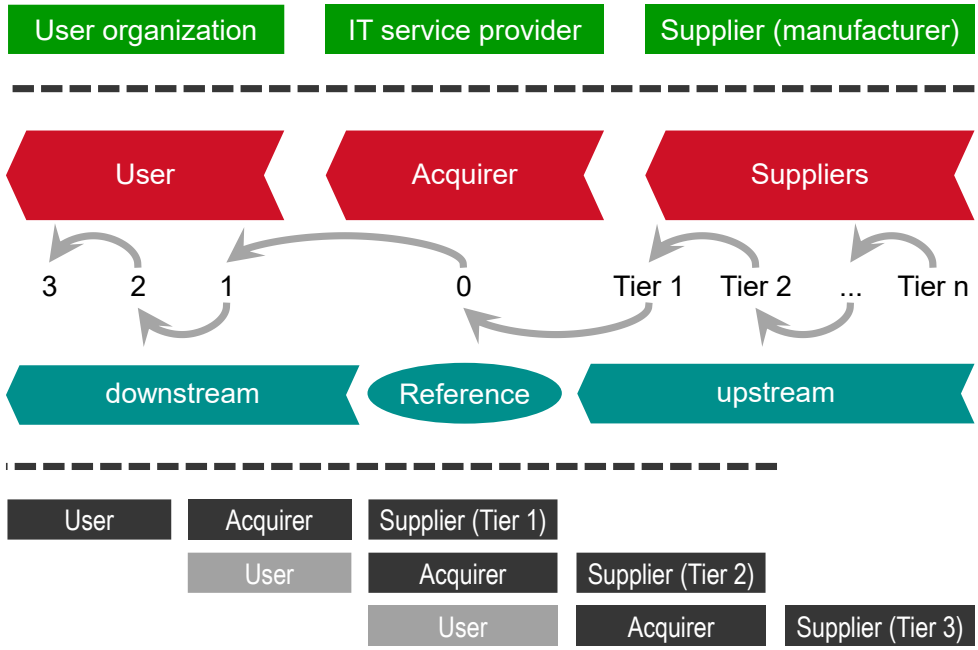


Fig. 1.4: Generic supply chain (inspired by and similar to ISO/IEC 27036-1 [5])

The two parts left and right of the 'acquirer' are referred to as 'upstream' and 'downstream' (in ISO/IEC 27036 [5]). The author first heard the terms in the oil and gas

industry. There, ‘upstream’ refers to the business of oil and gas production and ‘downstream’ refers to the business towards consumers, at the end of which are the service stations. These terms are also very useful in that they indicate that one's view of the supply chain depends on one's position in it. A supplier sees its customer as a user, while the latter may actually consider itself as a supplier to its customers, and so on. (This is why the term ‘customer’ is rarely used in this book.) This is illustrated in Fig. 1.4 indicated by the center point ‘reference’ and illustrated by the two examples below in gray in Fig. 1.4.

The role of suppliers (of the IT service provider) should not be underestimated. They build entire data centers with complex systems for air conditioning, power supply and fire protection, provide the network infrastructure in the data center, offer storage systems (storage) as a complete service, etc. Overall, the supply chain or the supply network of an IT service provider is quite extensive, because even the entire standard software from operating systems, database systems and cloud and container solutions to solutions for monitoring IT services etc. come from suppliers in the supply network.

Large IT service providers are also structured and organized internally with a very division of labor. Specialization and separation of functions within the company are indispensable. The tasks are too complicated and diverse. This means that large IT service providers also have a supply chain internally. (This is not shown in Fig. 1.4.) Orders are also placed within the company and responsibility for an order is passed on. Roughly, one can imagine that there is a division into service development, marketing, sales and contracting, production and customer support (service delivery management). In reality, the development and production areas in turn have a very complex structure and are deeply subdivided.

The user side is often somewhat underestimated in its potential complexity. The distinction between *user organization* and *users* (persons) has already been pointed out. A simple example of a more complex nesting is a reinsurer (insurance company that insure insurance companies). If the reinsurer purchases IT services, it is a user organization. But its customers, to whom it provides services and therefore may also owe accountability regarding the security of ‘its’ IT services, are insurance companies. These insurance companies, in turn, insure companies of various sizes and ultimately also consumers (individuals). This complexity may be of interest when considering security requirements. The situation is even more complex if one considers a large automotive group (OEM) as a user organization. For its automobile production, this company has an extensive and very deeply nested supply network. The crux is that almost all the companies in the supply network use one IT infrastructure, common IT services, or functionally link IT services. So, they are also user organizations when it comes to IT services.

Conclusion (see also [6]): Manufacturing and support systems cannot be viewed separately. The same is true for IT systems, data, and business processes. The number of parties and components is growing. Changes are occurring more and more frequently. The last article cited also contains many examples of problems and solutions. It is estimated there that around 100 IT vendors are active for the example company. The most important demand: Simplification and standardization of communication and cooperation!

1.4 Life cycle: Business Relationship and IT

NOTE: This chapter is based on another book by the same author [7].

User organizations purchase and procure IT services from *IT service providers*. The business relationship of the parties and the life cycle of the IT service (for the user organization) are closely linked. The course of the business relationship determines the possibilities for interaction between the parties. Specifically, the flow of the business relationship marks the points at which the user organization can exercise influence and obtain information about the design, implementation, and maintenance of the associated IT security measures. Therefore, the life cycle of IT services should be viewed in the context of the course of the business relationship.

Fig. 1.5 shows the course of the business relationship (red) and the life cycle of an *IT service* (light blue) together with the activities of the IT service provider (blue-green). Using this model, we will examine how an IT service comes into being and how the two parties (user organization and IT service provider) work together in the process.

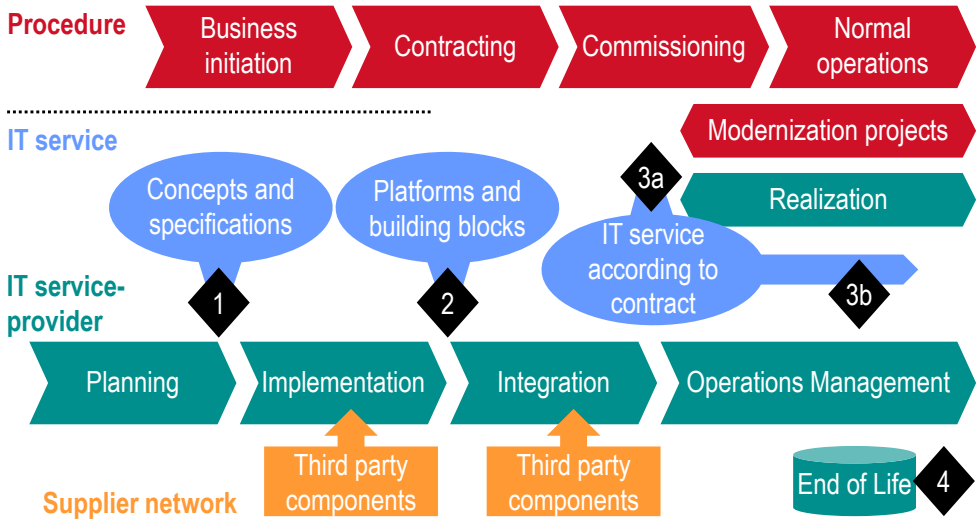


Fig. 1.5: Course of the business relationship and life cycle of IT services

The course of the business relationship (red) is shown in a very simplified way, but it contains all the essentials. The business initiation phase is intended to cover everything to do with marketing and sales activities on the part of the IT service provider. In this phase, the user organization analyzes the market with the providers and their offers. Then a contract is signed, the IT service is provided, and in the Normal Operations phase, it is made available for the duration of the contract. We come to these phases (red in Fig. 1.5) in a moment, because before a contract can be concluded, the IT service provider must make advance preparations: It must prepare to be able to supply its customers, because development and implementation cannot, after all, begin only when a customer comes knocking. The phases that an IT service goes through are often referred to as 'Plan - Build – Run'.

In modern cloud environments and industrialized IT production, this picture does not fit well. The difference becomes clear when one examines what forms an IT service really takes. They are shown in Fig. 1.5 in light blue and numbered from 1 to 4. The first result (No. 1) occurs at the end of the 'planning' phase (blue-green). The IT service provider has developed concepts and specified the IT service. To do this, it has examined typical requirements of its potential customers and designed appropriate solutions for them.

Implementation now takes place in two steps, labeled 'Implementation' and 'Integration' (blue-green shapes in Fig. 1.5). Accordingly, the IT service undergoes two transformations (light blue). Why? Today, for example, users can assemble standardized but despite this complex IT services by choosing building blocks at the click of a mouse. For example, they select computer performance, storage capacity and operating system and thus define their own server. The 'clicks' are used to install predefined IT modules on an existing IT platform with the help of fully or partially automated processes. In other words, there must be platforms and building blocks that are then integrated into a system in a second step. A closer look reveals that these two steps exist almost always: The IT service provider must complete certain parts in advance, which are then assembled, modified, and configured for a specific customer in a second step.

If, after completion of the 'Implementation' phase (blue-green in Fig. 1.5), the platforms and building blocks are implemented (IT service in status No. 2, light blue), contracts can be concluded with customers (red), since the completed platforms also include those with which the user clicks together and assembles his server in our example. This 'integration' (blue-green) means that the IT service is ready, i.e., it is available in a form that conforms to the contract (light blue, No. 3a). This corresponds with the 'Commissioning' phase in the business relationship (red). In many cases, however, the 'Commissioning' phase has not yet been completed or 'Normal operations' has not yet been reached. This is because adjustments now follow, which

in the case of complex IT services are carried out in the form of separate projects (marked 'Modernization projects' in Fig. 1.5). The user organization usually plays a role here, especially if it has just outsourced IT and handed it over to an IT service provider. However, the implementation in IT is almost always the responsibility of the IT service provider, which is why Fig. 1.5 still shows a 'Realization' box (blue-green). Once any necessary adjustments have been made, the IT service is provided in its final form (light blue, No. 3b).

Another aspect is important: The IT service provider integrates various components from other companies during 'Implementation' and 'Integration' (yellow in Fig. 1.5). This is of course considered and prepared for in the 'Planning' phase, as is the possible use of services from other companies.

The initial provision of the IT service marks the beginning of the run phase, during which the IT service provider provides operational services (labeled 'Operations Management' (blue-green) in Fig. 1.5). In the case of adaptations still in progress (red), however, this is not yet the 'Normal operations' phase (red). This is only reached as soon as all planned adjustments have been completed.

During the operating phase ('Normal operations'), smaller and larger adjustments (modernizations) are made again and again, such as the elimination of vulnerabilities or the elimination of performance bottlenecks. Larger adaptation projects can also be agreed, which run as described above. Also very important for IT security is the last change to the IT service: the decommissioning at the 'End of life' (light blue, No. 4). The contract expires, is terminated, or replaced. Any data still required by the user organization is handed over to it and then deleted. The IT service provider is relieved of its responsibility for IT security as well.

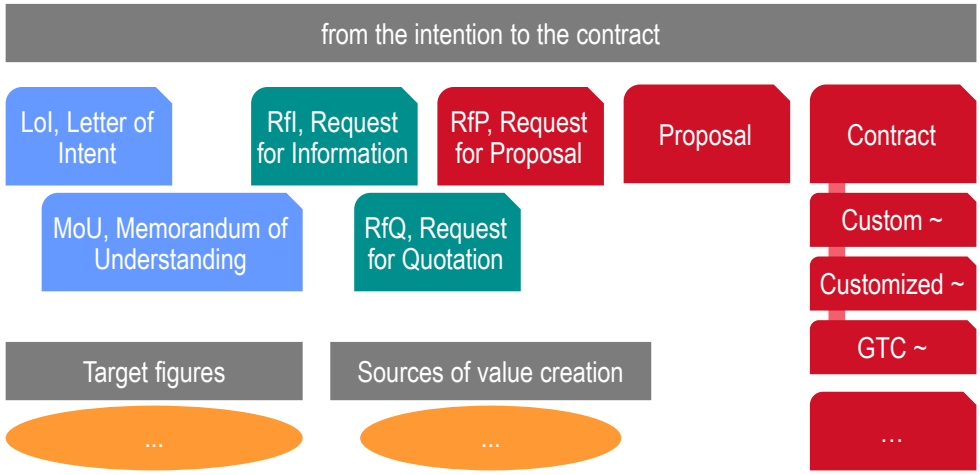


Fig. 1.6: Some terms related to agreements between user and provider (Source: [3])

Agreements and contracts also play a very important role for IT security management because one can only build on what has been agreed in writing. Fig. 1.6 shows some terms that are in use in this context in the business-customer environment.

1.5 Processes and Workflows: IT Service Management (ITSM)

NOTE: This chapter uses descriptions and definitions from the author's encyclopedia [3].

As soon as a certain technology has reached a certain complexity or is intensively used, regular repair and maintenance work is necessary. Continuous monitoring and regular inspection are required when users are particularly dependent on correct functioning. All this applies to cars just as much as to commercial aircrafts.

Maintenance, further development, and error handling also play a major role in IT. In addition, IT is 'never finished'. Changes are demanded and implemented again and again. This is not solely due to the sometimes poor quality of the software, but due to the fact that user requirements are subject to constant change and IT itself is always offering new possibilities.

IT Service Management (ITSM)

Set of procedures, tasks, and activities that enable an *IT service provider* to produce *IT services* efficiently and with consistent quality, to meet the agreed requirements, and to create added value for *users* and the IT service provider.

IT Service Management (ITSM) has a thoroughly defined structure. ISO/IEC 20000 first distinguishes between the service management system (SMS) and its operation. The SMS lays the foundations and creates the prerequisites for introduction and implementation. The operational part is based on the life cycle of an IT service and is divided into PROCESS GROUPS, each of which corresponds to general objectives or common intentions, respectively. Each process group consists of a few *ITSM processes*.

ITSM process

An ITSM process bundles and comprises a series of ACTIVITIES, each of which is performed in order to fulfill a common, process-specific task or to achieve an intended result. Since the activities are interdependent and must be performed in a logical sequence, they are referred to as processes. Examples of such ITSM processes are 'Change Management', 'Release and Deployment Management' and 'Incident Management'.

The international standard ISO/IEC 20000-2 [8] describes 18 to 21 provisioning or operational processes[3] for *IT services*, i.e., the provision of a service for *user organizations* (customers). The processes therefore also include relationship management and contracting. The implementation of ITSM processes is described in detail in ITIL®.[4] ITIL was developed as a collection of best practices and has been adapted and updated several times to meet requirements.

NOTE: A summary with many more details on IT service management can be found in chapter 12 of the author's book [9].

IT Service Management (ITSM) should form the basis for the organization of IT operations in the manner described. Although both sources (ISO/IEC 20000 and ITIL) focus on the quality of IT services as the primary goal, they remain quite vague on IT security. It is true that there are separate processes for ensuring availability, managing extraordinary events, and also for information security. However, IT security is an aspect that concerns almost all other areas. In other words, errors in almost all processes and technologies can lead to deficits and risks in IT security and, at the same time, almost all other processes must also make an active contribution to ensuring that an adequate level of security is achieved and maintained and that this is also evident and verifiable. It therefore makes sense to integrate IT security into the ITSM processes where necessary, or to expand them in such a way that IT security is explicitly considered.

Secured by Definition

'Secured by Definition' integrates the development, implementation, review, and improvement of all measures for securing IT services, IT systems and IT components into the development, deployment, and operational processes of IT along the entire life cycle (Plan-Build-Run[5]). This integration of IT SECURITY management and *IT service management* particularly affects the delivery and operational phases, which is critical to maintaining IT security. The concept uses the processes defined in ITIL® and ISO/IEC 20000 ([10] and [8]) for IT and extends them to cope with IT security.

---

3 The ISO/IEC 20000-2 standard does not contain any real process descriptions. Under the heading 'Service portfolio' there are three sections for which it is not entirely clear whether they should be understood as core processes.

4 IT Infrastructure Library®, a collection of predefined processes, activities, and roles along the life cycle of IT services, with particular attention to the operational phase. ITIL and IT Infrastructure Library are registered trademarks of Axelos Ltd.

5 Introduced by debis Systemhaus around 1995 as an expression of comprehensive IT services; extended in recent years in the IT4IT reference architecture to Plan, Build, Deliver, Run or Plan, Source, Offer, Manage.

The 'Secured by Definition' approach was introduced by the security architecture ESARIS [9]. Parts of it were adopted and further developed by the association 'Zero Outage Industry Standard'.[6]

'Secured by Definition' considers IT security as a quality. One of the guiding principles of 'Total Quality Management (TQM)' (1951) is to create quality instead of inspecting it later.[7] Accordingly, IT security should focus on processes and conditions for creating secure products and services throughout their life cycle rather than on (extensive) reviews and inspections and separate security processes. This means that people at every point in the value chain must follow predefined rules (for IT security) that are an integral part of all IT provisioning processes [11].

All process or process-related *security measures* including all steps to implement and maintain technical *security measures* thus become part of the ITSM process steps, the tools used there as well as the instructions for the IT staff and cover all stages of the extended life cycle (design, sales, contracting, implementation and integration, migration, and operations).

In addition, it has proven useful to have a separate, additional process for the identification and assessment of vulnerabilities and the planning of the necessary follow-up activities to eliminate them. Such a *Vulnerability Management* process

- ensures the systematic search for and detection of vulnerabilities,
- brings together the relevant information and ensures that vulnerabilities are assessed in the context of the organization's own IT operations,
- gives recommendations and instructions for dealing with vulnerabilities, especially for their removal,
- provides a picture of the situation (security posture) and also informs, for example, about changes in the IT security standards to be applied in the organization, and
- provides information for customers (stakeholders) so that they can assess existing risks, are aware of the status of vulnerability management and, if necessary, fulfill any necessary obligations to cooperate.

The core of such a process is shown in Fig. 1.7. The activities of situational awareness (posture management) and customer information are not shown. Patch management is not a process in its own, but a special procedure that is predominantly used for quality assurance, prevention of incompatibilities and failures, and coordination.

---

6 https://zero-outage.com/the-standard/security/, accessed December 13, 2023

7 Phil Cosby, who helped spread the method successfully introduced by U.S. Americans in Japan.

Patch management can therefore also be assigned to Step 3, Coordination, in Fig. 1.7).

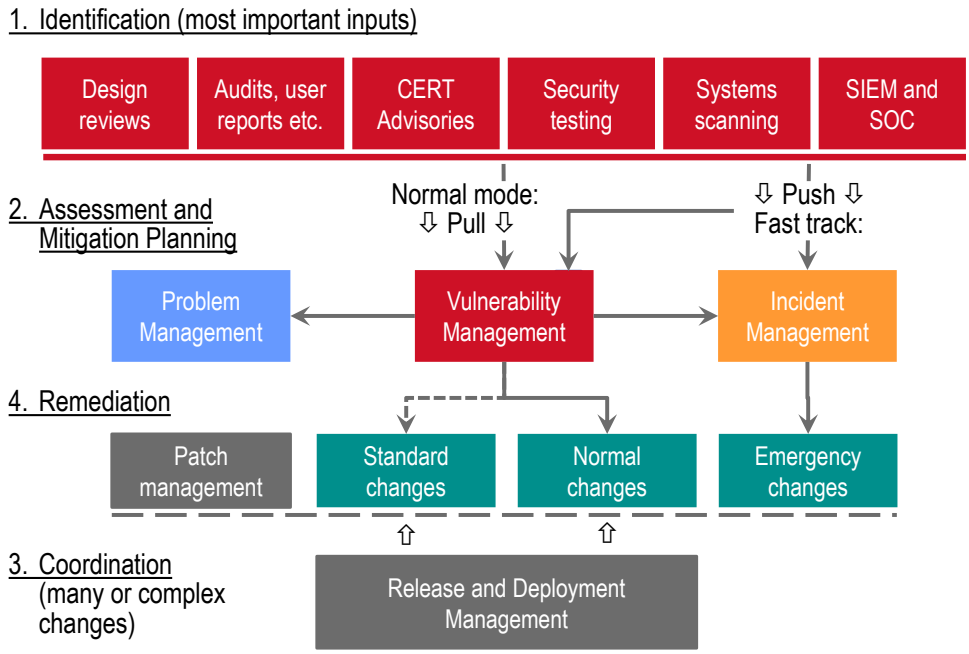


Fig. 1.7: Vulnerability management and its relationship to other core processes (Source: [3])

The figure shows the link with vulnerability remediation activities (Step 4). Vulnerabilities are eliminated by making changes to IT systems, IT components and IT processes. This is done as part of the standard processes, primarily the Change Management process. It is never permitted to make any change (relating to IT security) outside this framework. Security changes are registered, planned, approved, implemented, checked, and recorded like all other changes.

Since the elimination of vulnerabilities is not done as part of the vulnerability management process, it might be better called 'Vulnerability Assessment and Mitigation Planning (VAM)'. This name will be introduced and used in Chapter 4 for the corresponding topic area. In contrast, we will stick with the simpler name for the core process:

Vulnerability Management

This process has the task of providing IT operations with executable instructions (Qualified instructions) regarding the handling of *vulnerabilities* that are tailored to the needs of IT operations, i.e., they are relevant and have been clearly defined.

The process collects information about vulnerabilities (news, messages, reports) from reliable, qualified sources and checks the information provided for relevance to its own IT operations and, if necessary, again for validity (in the case of sources outside the IT operations to which the process belongs). The information is consolidated (duplicates are removed or merged), and missing details are added. This includes actionable instructions, if available, on how to remediate the vulnerability.

This is followed by an assessment of the 'degree of vulnerability' in connection with or for the organization's own IT operations. From this, a recommendation or instruction for dealing with the vulnerability is determined using a metric (measurement procedure). The recommendation or instruction contains information about the urgency of treatment which supports prioritization.

Options: The process should also estimate and quantify the expected effort, e.g. by collecting and using information about the number of affected instances (products, installations) in its own IT operations. The value called 'implementation gap' supports the planning of remediating activities. Furthermore, the process should additionally deliver a 'security bulletin' or newsletter in case of and about specific, particularly critical vulnerabilities in a form that can be understood by decision-makers at the IT service provider and the user organization and is suitable as a basis for decisions.

As can be seen in Fig. 1.7, the executable instructions (Qualified Instructions) regarding the handling of vulnerabilities usually lead to Normal Changes. Vulnerabilities that need to be addressed immediately, on the other hand, are classified as security incidents and are addressed with an Emergency Change. In principle, there may also be vulnerabilities for which no solution has yet been found. These can be passed on to Problem Management.

Often, the term vulnerability is associated only with security-related implementation errors in software and hardware products. To turn the vulnerability management process into a comprehensive correction and improvement process for IT security, a more comprehensive understanding is required:

Vulnerability

Vulnerabilities (or security gaps) indicate the absence or inadequacy of *security measures* (security controls). If a vulnerability can (with a certain probability) be exploited to cause damage (impact), there is a risk. The most common form of risk treatment is the elimination of the vulnerability.

Security measures can be administrative, organizational or process-related, technical, or legal in nature. If the aim is to eliminate a vulnerability, it must first be clarified in whose sphere of influence the vulnerability lies or which

organizational unit can eliminate it. For example, deficiencies in a process specification must be eliminated by the quality management department and deficiencies in process implementation by the users of the process. Legal deficits are eliminated by the legal department. Organizational deficits must be taken care of by the management. Technical deficits are eliminated by IT operations or IT engineering, etc.

If the term vulnerability is understood and used in this comprehensive way, the vulnerability management process becomes a comprehensive process of continuous improvement of IT security. However, this also requires that information about vulnerabilities be distributed to specific target groups.

1.6 Outlook: Two IT Service Providers and the Supply Chain

This chapter began with the statement that 'the cloud services' had promised to simplify IT: 'IT as if from the power socket'. At the beginning, this seemed to be true. The simple applications were moved to the cloud. But not everyone realized that it was (almost) only the low-hanging fruit that was being harvested. Because when the more complicated cases were also to be outsourced there, the cloud providers had to deliver considerably. And they did. What they (all) did not do, however, was continue to take care of everything. After all, the management and maintenance of IT is personnel-intensive and produce comparatively high costs. If many options and possibilities are offered to meet (almost) all customer requirements, it is complicated and personnel- and cost-intensive to select them, integrate them and make them usable. Fig. 1.8 illustrates what has been said.

Model A: We first consider the simple model at the bottom of Fig. 1.8 with only two parties. The *Service Model* is labeled 'IT outsourcing', which accurately captures reality in that the user organization obtains or can use EVERYTHING RELATED TO IT from the IT service provider: These are (red in the figure)

1. the IT components or IT services (i.e., IT functionality),
2. the integration and configuration of these components and services as the basis to provide the IT service for the first time,
3. operations (i.e., the continuous provision of IT functionality over the term of the contract) and
4. IT service management (i.e., the maintenance and repairs of the agreed services).

What remains for the user organization? It takes over

5. use (after initially defining and communicating its requirements).

The gray shapes in Fig. 1.8 explain points 1+3, 2+4 and 5 in more detail.

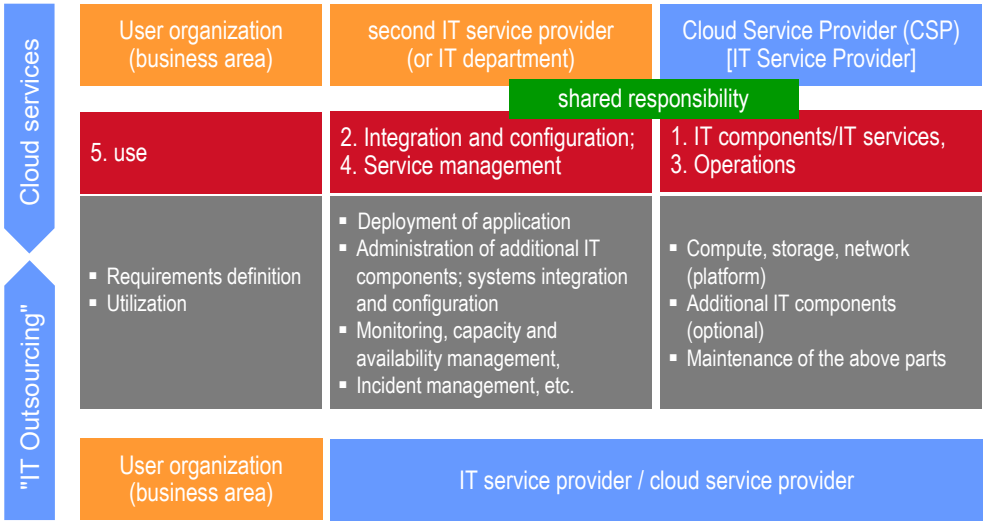


Fig. 1.8: Tasks in traditional IT outsourcing and in cloud environments (Source: [12])

Model B: We now consider the upper Service Model in Fig. 1.8, It is labeled 'cloud services', which is not quite true but typical for many IT services from public clouds. The cloud service provider (CSP), at the top right in Fig. 1.8, primarily provides

1+3 the IT components or IT services, i.e., the IT functionality continuously over the term of the contract.

The tasks

2+4 integration and the configuration of the components and services as well as maintenance and repairs

are customer-specific, personnel-intensive, and therefore scale less well. Some cloud service providers (CSPs) therefore like to leave these activities to the user organization. However, user organizations often no longer have the necessary competencies and the required personnel capacities (at the latest after harvesting the low-hanging fruit, see above) to set up the IT services (point 2) and to monitor and maintain them (point 4), possibly around the clock (7x24). If these competencies and capacities are not available, a second IT service provider can step in. See Fig. 1.8. This is where the so-called shared responsibility model becomes really interesting (green in the figure), since there are three parties involved now and not only two.

Such models are the rule rather than the exception in the case of complex IT. And in most cases, the three-party case just described is also rather simplistic. User organizations should therefore be prepared to play an important role in securing IT services. The *Joint Security Management (JSM)* model, to which the author has devoted an entire book, describes how this can be done and what needs to be taken into account [7]. Essentials of the JSM became an integral part of the improved version of the ESARIS security architecture described in the following chapters.

Bibliography

The first list below contains the literature referred to in this chapter. Some of the sources are only available in German. A second list of recommended reading has been added, containing only English references.

References (Sources)

[1] Torsten Gründer (Ed.): IT-Outsourcing und Digitalisierung in der Praxis, Vorgehen – Steuerung – Kontrolle – Ergebnisqualität; Erich Schmidt Verlag, 2021, 3rd edition, 671 pages, ISBN 978-3-503-19158-1

[2] Eberhard von Faber: Sicherheitsaspekte beim Cloud computing, Leitlinien für Anwender im "global sourcing"; E. von Faber and F. Holl (Eds.): The Bulletin Security Management, BSM Anwender 200, Sept. 1, 2009, ISSN 1869-2125

[3] Eberhard von Faber: IT und IT-Sicherheit in Begriffen und Zusammenhängen, Thematisch sortiertes Lexikon mit alphabetischem Register zum Nachschlagen; Springer Vieweg, Wiesbaden 2021, 289 pages, 64 figures, ISBN 978-3-658-33430-7, https://doi.org/10.1007/978-3-658-33431-4

[4] Eberhard von Faber: Warum sich Datenschützer mit Details beim Cloud computing auseinandersetzen müssen; BvD-NEWS, Das Fachmagazin für den Datenschutz, Issue 1, 2022, pages 14-19, ISSN: 2194-1025, https://www.bvdnet.de/wp-content/uploads/2022/03/BvD-News_1-2022.pdf, accessed December 13, 2023

[5] ISO/IEC 27036-1: Information technology – Security techniques – Information security for supplier relationships – Part 1: Overview and concepts

[6] Frank Damm and Hans-Peter Fischer: Lieferkette: Wie Cyber-Security von adäquater Zusammenarbeit abhängt; in: Datenschutz und Datensicherheit - DuD, 43(7), July 2019, Springer Fachmedien, Wiesbaden 2019, ISSN 1614-0702, pp 418-425; https://doi.org/10.1007/s11623-019-1137-z

[7] Eberhard von Faber and Wolfgang Behnsen: Joint Security Management: organisationsübergreifend handeln (Mehr Sicherheit im Zeitalter von Cloud computing, IT-Dienstleistungen und industrialisierter IT-Produktion); Springer Vieweg, Wiesbaden 2018, 246 pages, 60 figures, ISBN 978-3-658-20833-2, https://doi.org/10.1007/978-3-658-20834-9

[8] ISO/IEC 20000 – Information technology – Service management –Part 2: Guidance on the application of service management systems

[9] Eberhard von Faber and Wolfgang Behnsen: Secure ICT Service Provisioning for Cloud, Mobile and Beyond (ESARIS: The Answer to the Demands of Industrialized IT Production Balancing Between Buyers and Providers);

Springer Vieweg, Wiesbaden 2017, 2nd updated and extended edition, 383 pages, 159 figures, ISBN 978-3-658-16481-2, https://doi.org/10.1007/978-3-658-16482-9

[10] ISO/IEC 20000 – Information technology – Service management – Part 1: Service management system requirements

[11] Eberhard von Faber: Methods: 'Secured by definition' and the utilization of quality management principles, Seamless IT security through integration within IT-production processes; Translation of article (https://doi.org/10.1007/s11623-019-1136-0) originally published in: Datenschutz und Datensicherheit - DuD, 43(7), July 2019, Springer Fachmedien, Wiesbaden 2019, ISSN 1614-0702, pp 410-417, https://zero-outage.com/opinion/methods-secured-by-definition-and-the-utilization-of-quality-management-principles/, accessed December 13, 2023

[12] Eberhard von Faber: Enhancing Cloud Security Standards: A Proposal for Clarifying Differences of Cloud Services with Respect to Responsibilities and Deployment; European Identity and Cloud Conference (EIC) 2022, May 10-13, 2022, Berlin (invited keynote)

Further Literature (Recommendations)

[13] Elizabeth Sparrow: Successful IT Outsourcing, From Choosing a Provider to Managing the Project; Springer-Verlag, London, 2003, 287 pages, ISBN 978-1-4471-1114-6, https://doi.org/10.1007/978-1-4471-0061-4

[14] Naresh Kumar Sehgal, Pramod Chandra P. Bhatt and John M. Acken: Cloud Computing with Security, Concepts and Practices; Springer Nature Switzerland AG, 2020, 2nd edition, 381 pages, ISBN 978-3-030-24611-2, https://doi.org/10.1007/978-3-030-24612-9

[15] ISO/IEC 27036-1: Information technology – Security techniques – Information security for supplier relationships – Part 1: Overview and concepts

[16] Sjaak Laan: IT Infrastructure Architecture - Infrastructure Building Blocks and Concepts; Lulu.com, 4th edition, 480 pages, ISBN 978-1447785606

[17] Simon Winston: Cloud Computing and Distributed Systems: 2 in 1 Guide: Elevating Scalability, Efficiency, and Connectivity in the Digital Age; Independently published, 203 pages, ISBN 979-8862856453

ELECTRONIC SUPPLEMENTARY MATERIAL
The figures are available as a PowerPoint file.
Contact the author by email or via LinkedIn.

2 The Metasystem

Focus, ignore, simplify...? None of this really changes anything about the diversity and complexity of topics and tasks. Instead of closing our eyes or simplifying excessively, we should create structures and invent methods to make complexity manageable and understandable. Fig. 2.1 shows the handling of a commercial aircraft. There are 30 minutes available for this. It is all about coordination! What are the tasks? Who takes care of them? Which dependencies must be considered? What are the handover points? What do the customers want? What must the service provider deliver? What must its suppliers deliver? A system creates order – also in the case of IT service security. This chapter outlines a system or architecture helping to manage IT service security. It defines several areas of activities, each of which corresponds to general, business-driven objectives. Each area is described in terms of activities or tasks together with their inputs and outputs. The management system shows the interrelations between the areas of activities and forms an organizational schema creating the basis for comprehensively managing IT service security while taking the interests and responsibilities of the parties involved and their division of labor into account. The goal of implementing the schema is to create the necessary conditions for effectiveness (reach all goals with consistent quality) and efficiency (reduce effort and costs).

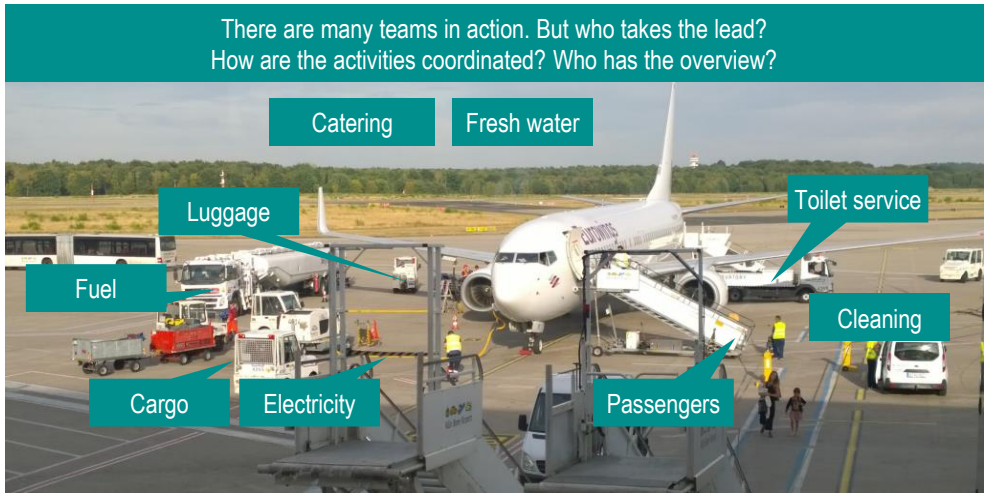


Fig. 2.1: Case study handling of a commercial aircraft

© The Author(s), under exclusive license to Springer Nature Switzerland AG 2024
E. von Faber, *Managing IT Service Security*, https://doi.org/10.1007/978-3-031-55533-6_2

2.1 Basic Structure

The IT security of IT services cannot be thought of without the users. After all, it is the users who primarily feel the effects of inadequate IT security and, in the event of successful attacks, have to accept restrictions on their business and suffer losses. For IT service providers and IT departments, customer orientation must mean dealing with and meeting the standard requirements ('state-of-the-art security') and the special requirements of users and user organizations. This is shown on the left in the highly simplified representation in Fig. 2.2 and forms a complex of tasks, which is referred to here as *Fulfillment*.. One of the most important points is to provide the user organization with information that allows it to understand and assess IT security risks. After all, user organizations have no direct influence on IT security themselves because they obtain IT services from external IT service providers or their IT departments. With the help of the information (*Assurance Material*) provided on the IT security of the IT service, user organizations can assess whether their business security requirements are being met. Refer to the left part in Fig. 2.2 labeled *Fulfillment* (green shape and the ones below).

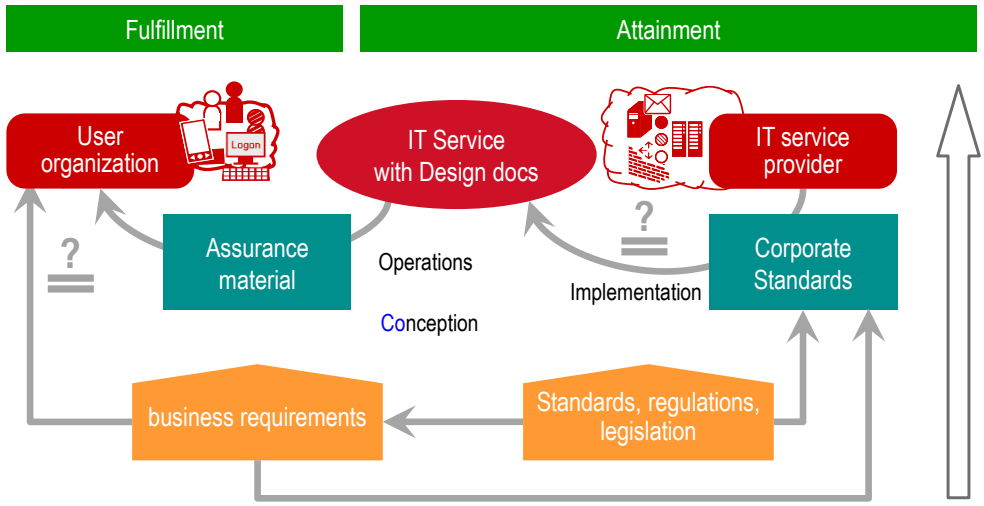


Fig. 2.2: Basic structure of IT service security management

This is well known, and yet external IT service providers or internal IT departments and their IT security specialists often focus too much on the correct implementation of their own IT security standards. The management and implementation of these '*corporate standards*' is shown on the right in Fig. 2.2 and forms a complex of tasks, which is referred to here as *Attainment* (green shape and the ones below).

The definition of such processes and task areas is carried out with the aim of standardization:

Standardization

> Adjustment and generalization (universalization) of a) product or service characteristics, b) components and sub-services used, and c) methods, processes, practices, and techniques used in the development and provision of products or services with the aim of 1) reducing effort and costs (efficiency) and 2) achieving consistent quality (effectiveness).

It is not enough to focus only on the (IT security) properties of products and services and their components and sub-services. Rather, it is imperative to standardize the process of their development and provision. This is not only where the greatest potential for savings lies, but also where the levers for ensuring the quality of the products and services, including IT, are to be found. Such standardization can only be carried out in detail on an organization-specific basis, but then it applies to all products and services or to larger groups of them.

The model or metasystem presented in more detail below (ESARIS) provides a generic framework that organizations can adapt to their own circumstances. The metasystem also defines a set of terminology for specific areas of activity, which makes communication and thus the accomplishment of tasks much easier.

2.2 Two Tasks or Twice Three Tasks

In reality, both subtasks are more complex than revealed above. Fig. 2.3 below shows three types of tasks each for 'Attainment' and 'Fulfillment'. Again, the temporal order in which the tasks are processed tends to be from bottom to top and from right to left, as indicated by the dark gray arrows.

2.2.1 Define and Implement Standards (Attainment: Overview)

We start with the right-hand side of Fig. 2.3 headed 'Attainment'. Although it takes place with knowledge of and under the influence of market and customer requirements, it is generally INDEPENDENT OF INDIVIDUAL CUSTOMERS in the case of industrialized IT service providers with many customers (user organizations). Standards are continuously developed and updated. When a new IT service is developed, it is usually intended to be made available to several or many customers (business model 'one-to-many').

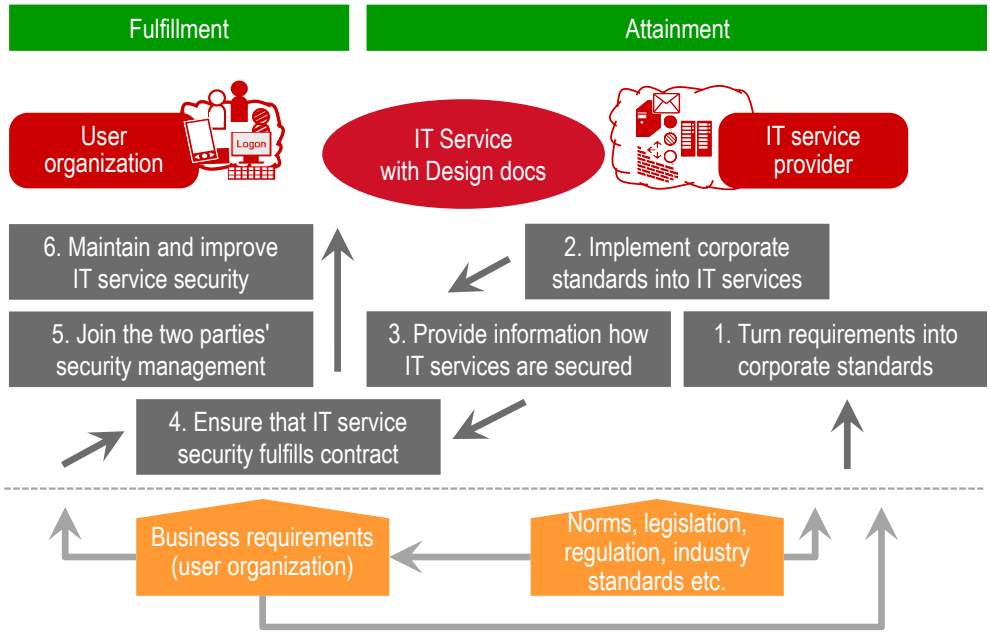


Fig. 2.3: Attainment and Fulfillment with three tasks each

The 'Attainment' deals with three questions (compare points 1-3 in Fig. 2.3).

1.) How to convert customer and market requirements into specifications or standards for the own organization (corporate standards)?

    (Note: Considering the state-of-the-art and using best practices is also expected by market participants and therefore subsumed under customer and market requirements.)

2.) How to ensure that the specifications or standards of the own organization (corporate standards) are implemented in the IT services?

3.) How to inform customers (user organizations) about how the offered IT services are secured and what IT security features they have?

These are primarily tasks for the IT service provider. However, the user organization often also contributes to the provision of the IT service or IT security. For example, by providing the application (application software) or identifying and assessing IT security risks. These forms of cooperation and mutual support will be explained in more detail below under the heading of *Joint Security Management (JSM)*.

At this point, the explanation of the term 'Attainment' with a focus on the IT service provider should be sufficient, as this area is very extensive in itself.

Attainment

Topic: Match between IT service (reality) and security standards (target, plan).

Attainment [1] comprises methods for achieving that an IT service complies with the relevant or applicable IT security standards. The entire life cycle is considered. Attainment also means that it is verified with reasonable effort (i.e., to a certain degree) that the applicable IT security standards are complied with, and that evidence is available in the form of **Attainment Statements** documenting the result of the *compliance* review. The review is a snapshot. If the applicable IT security standards do not change and the intended practices continue to be followed, the result of the review continues to apply. If the environmental conditions (such as threats) do not change either, the IT services maintain the achieved quality of IT security.

Attainment includes the following activities:

1) STANDARDS: the creation and maintenance of standards for IT service security are required, including the description (standardization) of the methods, procedures, practices, and techniques needed to perform ALL THE ACTIVITIES THAT STILL FOLLOW in Attainment and *Fulfillment*. The standards are standards of the organization (*corporate standards*) that also adopt best practices from other sources, but have been adapted to and consider the operational requirements of the organization (→ *Standardization*).

   Since the task of creating and maintaining standards is particularly important and time-consuming, the separate term *Maintenance System* is introduced for it.

   The standards must reflect customer requirements and implement requirements from certain norms, international and industry-specific standards, legislation and regulation and the like. Otherwise, they cannot be met. Setting requirements and providing input for the creation and adaptation of the organization's standards (*corporate standards*) is also an important and complex undertaking, which is why a separate term is introduced for this as well: *Endorsement Framework*.

2) SUPPLY CHAIN: the planning and execution of the procurement of all individual components and services required for the collaborative provision of an IT service. This also includes the planning, organization and safeguarding of the supply chain and the provision and conclusion of agreements or supply contracts within the own organization (→ *Operational Level Agreements, OLA*) and with external suppliers (→ *Underpinning Contract, UC*). If one wants to emphasize the cooperation in provision, one can also use the term 'Joint provision'.

The conception and determination of the division of labor in the supply chain is supported by a *Taxonomy* for IT service security. It is used as a scheme for ordering the many standards for IT service security that are created and maintained as described in the last point.

3) IMPLEMENTATION: the application of defined methods for the use and the translation into practice of these standards in the planning of new IT services, the realization of the IT services and in their further development. This also includes the creation of development documentation (architectural design, detailed design, etc.).

4) VERIFICATION: checking the conformance between standard and implementation (see above) and planning any necessary corrective actions. The above-mentioned *Attainment Statements*, documenting the result of verifying the conformance of design and implementation with the relevant standards for IT service security, become part of the development documentation generated in the last point.

5) SALES READINESS: the creation of documentation for users (customers) including contractual documents in the form of blueprints. These documents are created as part of the development of an IT service and are referred to below as *Security Proposition*. The part of the contract documents that relates to the form and quality of the provision of IT services and that represents a performance promise is usually referred to as Service Level Agreement (SLA).

2.2.2 Meeting Customer Requirements (Fulfillment: Overview)

We now turn to the left side of Fig. 2.3 which is headed 'Fulfillment'.. Here, the aim is to win over a specific customer (user organization) for the use of a specific IT service (project business) and then to provide the IT service in accordance with the contract (operations, continuous day-to-day business). The first part of 'Fulfillment' is related to a specific customer, the second (operations) is usually not, because platforms are used and 'cloud services' are offered. However, dedicated systems (such as private clouds) are provided on a customer-by-customer basis.

'Fulfillment' deals with three issues (compare items 4-6 above in Fig. 2.3):

4) How is it ensured that the IT services offered are secured in such a way and have precisely the IT security properties that contract-relevant or contractual promises to the customer (user organization) can be fulfilled?

   (Note: This item does not apply if the contract is concluded on the basis of conditions determined exclusively by the IT service provider, such as General

Terms and Conditions (GTC) and a service description of the IT service provider).

5.) How is it achieved that the customer (user organization) can provide the necessary cooperation services and base its IT security management on that of the IT service provider, so that both parties can work together in the sense of a *Joint Security Management (JSM)*?

6.) How does the customer (user organization) process information such as security reports that it receives from the IT service provider, and how can it influence improvements and enhancements to IT security within the scope of existing contracts and by modifying or extending them?

'Fulfillment' involves both parties, the IT service provider and the user organization. The following description provides further details and introduces terms that are also crucial for the understanding and cooperation of both parties.

Fulfillment

Subject: Match between IT service (reality) and the user's requirements (target).

Fulfillment [1] encompasses methods for ensuring that an IT service meets the security requirements of the user or customer. Large companies in particular take a comprehensive risk-oriented approach. They have different IT security requirements because their business is different and IT services process different data for different purposes in different deployment environments. Users (customers) express their interest and make their purchase decision based on diverse information. We refer to the information provided by the IT service provider related to the IT security of an IT service as *Assurance Material* [2].

Fulfillment includes the following activities:

1) IT service provider and user organization exchange information, with the IT service provider outlining the IT security features of the IT service and the user organization outlining its requirements. If necessary, contract negotiations take place.

2) The IT security measures implemented or to be implemented are compared with specific requirements of the user (customer). Conceptual compliance is checked and → *Conceptual evidence* generated.

   This comparison is NOT NECESSARY or is performed by the user organization if the IT service is offered and sold according to a standard contract, i.e., the value proposition and contract are not customer-specific and do not contain any customer-specific contract clauses.

3) The contract is drawn up if necessary and then concluded or signed. This means that the IT service provider also transfers responsibility from sales

and contract or deal management to its Service Delivery Management (SDM) and IT production.

4) The Operational Readiness is established.

   Processes and procedures required to maintain IT security are implemented for IT operations. The support of the security management department is organized. Interfaces with the customer are established. See *Joint Security Management (JSM)* [3].

5) In the operational phase, evidence such as security reports is created, communicated, and used (→ *Operational evidence*). Possible changes are supported.

2.2.3 Summary

Some of the new terms just introduced are shown in the again extended Fig. 2.4 which now appears complete. (The *Taxonomy* is not shown; it is part of the *Maintenance System* and will be explained in detail later).

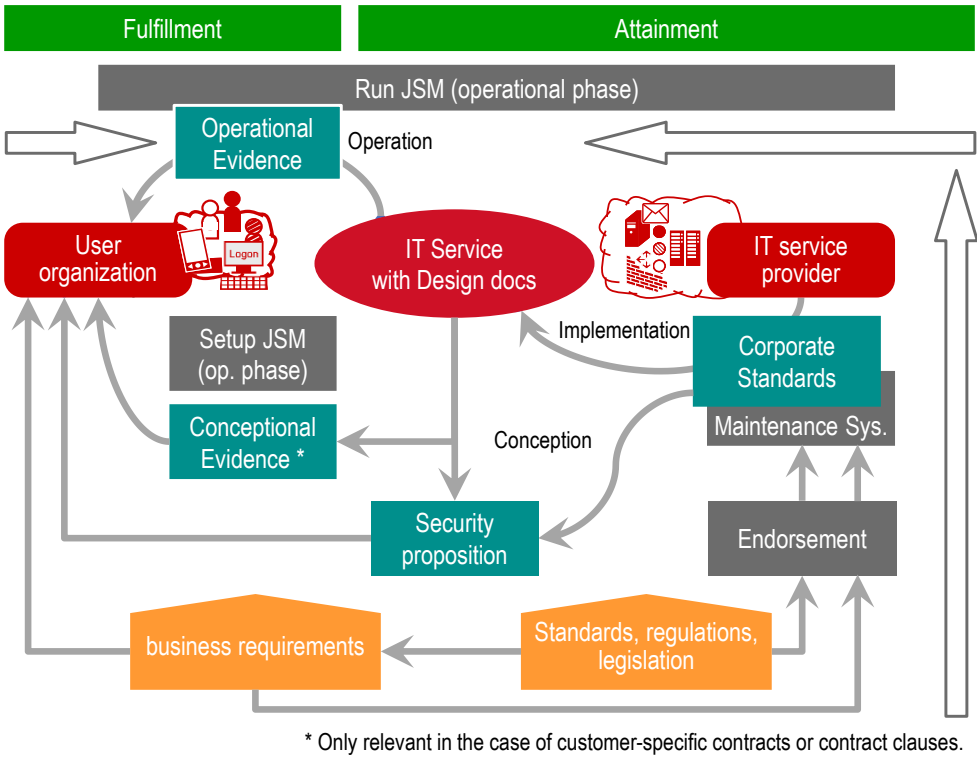


Fig. 2.4: Systematic IT service security management

2.3 Attainment

2.3.1 Define and Maintain Standards (Details)

It is important that each organization, but especially IT service providers, define their own standards (→ *corporate standards*). Due to the complexity of the subject matter, this must be done systematically. Ensuring and managing the sources, requirements and their consideration is the task of the→ *Endorsement Framework*. All standards are created and maintained within a → *Maintenance System*. All standards are organized using a *Taxonomy* and provided with identifiers accordingly. The terms in italics are now explained.

Corporate standards

Documents (standards for IT service security) that define procedures and measures to be applied or implemented on a mandatory or rule-based basis. They are needed to be able to produce uniform and consistent results. Documentation also increases quality because procedures and measures are then actually thought through and can subsequently be criticized and improved.

The standards adopt tried-and-tested information from national and international norms, standards, legal regulations, manuals, and the like, but adapt this to the organization's own operational requirements resulting in own representations. This is also necessary to create clarity about the binding nature and to reduce the room for interpretation.

All security mechanisms and functions, as well as actions for implementation, review, monitoring, etc., should be documented consistently in the form of *security measures* which describe facts and not requirements, and document achievements instead of general instructions for acting [4].

Endorsement Framework

Topic: Input for the organization's own standards and relationships between these and other regulations and (non-organizational) standards.

The Endorsement Framework [1] organizes and determines the adoption of best practices and measures from national, international, or industry-specific norms, standards, legal regulations, handouts, and the like, and verifies that *corporate standards* (the organization's own standards for IT service security) are suitable for meeting or complying with relevant norms, standards, legal regulations, handouts, and the like, respectively. A similar approach is taken with customer requirements which are adopted as general standards when it makes economic sense to do so. Alternatively, they lead to optional measures to be implemented.

1) On the one hand, the Endorsement Framework is a kind of demand management, because it identifies requirements that must be met in principle or

under certain conditions and must therefore be reflected in the organization's own standards for IT service security in the form of methodologies and measures.

2) On the other hand, the organization's own standards for IT service security are examined to determine whether their implementation is suitable for fulfilling the requirements of norms, standards, legal regulations, handouts, and the like. If this is the case, the examined norms, standards, handouts, and the like are complied with if the organization's own standards for IT service security are implemented. This facilitates audits in this regard and corresponding commitments to customers (user organizations).

Organizations must define procedures and measures for IT security. To ensure that they are applied and implemented, they must be written down and/or reflected in software. They also need to be reviewed and updated on an ongoing basis. These are the tasks of the *Maintenance System*:

Maintenance System

Topic: Creation, update, and provision of organization-specific standards.

The Maintenance System has the task of ensuring that *corporate standards* (standards for IT service security) and their manifestations in software tools (for example for IT service management) are developed, regularly reviewed, updated, put into force, and made available. The Maintenance System consists of a process, an editorial board (team) and specification requirements.

1) The process defines the steps and responsibilities starting with a Change request (CR), through the change itself, to the review and approval, and finally the enactment and release of the new version.

   (Note: The Request for Change (RfC) or 'change request' is more in the nature of a problem ticket when only the deficiency has been identified and the nature of the required change is not yet known).

2) The editorial board (team) accompanies and controls all steps along the mentioned process and ensures consistency, quality and up-to-dateness of the standards for IT service security. The quality criteria of the editorial board (team) include comprehensibility, completeness, consistency, and correctness of form (which we can call the C4 criteria). Note that the editors themselves cannot guarantee e.g., exactness and appropriateness. This is up to the experts writing the standards.

3) Specification requirements are defined in order to comply with the above quality criteria. All quality criteria are primarily aimed at facilitating application and avoiding implementation errors. To this end, forms and formats are defined in particular, which specify how standards are to be written and

how content is to be classified, assigned to and labeled with. The rules for writing are basic rules of syntax and semantics. Classification, assignment, and labelling are based on a hierarchy (*Documentation Hierarchy* and a *Taxonomy* (an IT-related organization and orchestration scheme).

The library with the *corporate standards* (standards for IT service security) is structured hierarchically and thematically in the two lower levels. Each document is assigned a place in a structure that is shown in Fig. 2.5 and is defined by two elements: the hierarchy of documents (*Documentation Hierarchy)* and the area in the *Taxonomy* (an IT-related organization and orchestration scheme). The two terms are explained below.

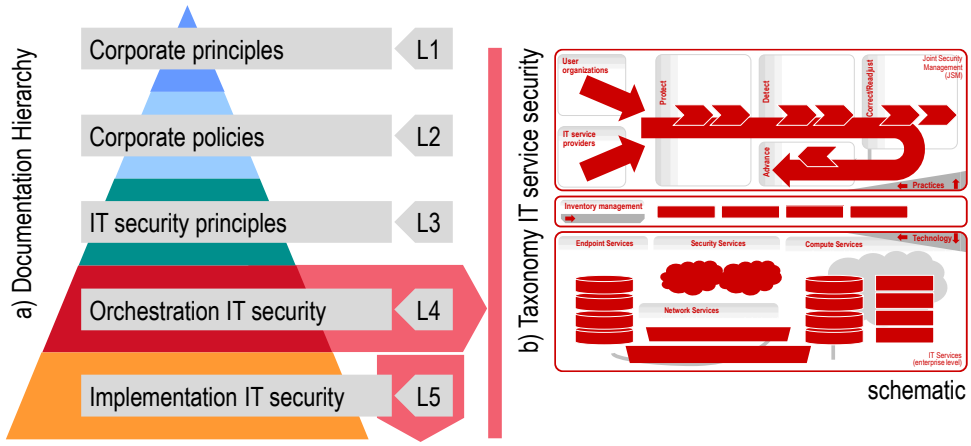


Fig. 2.5: Documentation Hierarchy and Taxonomy

Documentation Hierarchy

The documents (standards for IT service security) are arranged hierarchically. This means that general organizational guidelines on security topics are broken down to IT service security and specified in more detail for this area. And the guidelines and more general standards for IT service security are in turn refined down to detailed, technical instructions. Each lower level (layer) in the hierarchy usually contains more documents than its more abstract predecessor. It is a document pyramid that becomes broader, more comprehensive, and more detailed as it descends. This in turn makes it easier to specify and follow individual topics in the following level (layer) of the hierarchy.

Step-by-step refinement is a proven, successful architectural principle that allows experience and knowledge to be used optimally and thus produces quality. At the same time, documents become purpose- and target group-specific. The target groups are only provided with the information that is relevant to them,

which reduces complexity for them and helps to improve the quality of the implementation.

Each document therefore belongs to exactly one level (layer) in the hierarchy. There are no mixed documents. Mixing purposes and target groups would not only complicate the application, but also the creation and maintenance of the documents, because the restriction to one level of abstraction also makes it easier to ensure completeness and consistency.

Taxonomy

Topic: important organization and orchestration scheme within the overall architecture for more overview and other diverse use cases.

An organization and orchestration scheme that contains an overview of all topic areas for securing IT services. The topic areas include technology areas A (with IT components and IT systems to be secured or used for securing) and practices B (with process-related activities that must be performed to obtain secure IT services).

The Taxonomy is a graphical representation that can be easily displayed on half a page and that groups the topics in such a way that real connections between them can be recognized as well as possible.

The Taxonomy makes it possible to assign responsibilities and tasks and to orchestrate activities. **Orchestration** means managing diverse entities and coordinating their interaction to harmonize effects and achieve overall goals.

The topics are arranged in such a way that IT experts understand them more or less intuitively and not just IT security experts, because the IT organization (and not IT security experts) is largely responsible for implementing IT security measures in IT services. IT security is only one quality characteristic among others and cannot shape the processes. Security-related organization schemes are not understood, are of little help and cause considerable frictional losses.

The documents (standards for IT service security) are roughly divided into two groups: A) those describing measures that are implemented in or with IT components and IT systems, and B) those describing measures that ensure implementation of the measures in the first group and verify this in terms of correctness and effectiveness.

Justification: In the interest of effectiveness and efficiency, procedures, processes, and practices (Group B) must be standardized as much as possible and applied to all IT components (Group A). – The documents (standards for IT service security) in the middle of the *Documentation Hierarchy* (i.e., in the '*Orchestration Layer*') and below are organized according to the Taxonomy, i.e., a scheme

that is based on the technical and organizational reality of the information technology or the IT services provided (and not on IT security).

The information provided in this Chapter 2 provide a good overview and are of decisive help in systematically and successfully ensuring the security of IT services and in procuring and deploying adequately secured IT services. However, the many terms are not easy to remember. The *Taxonomy* for IT service security will present all essential aspects, tasks and activities in a clear and simple form and combine them with other aspects not detailed in this chapter.

The *Taxonomy* for IT service security is described in detail in Chapter 4 starting on page 65. Each individual task area is outlined. In addition, the benefits and use of the *Taxonomy* is also explained in detail.

The topic of document structure (with Documentation *Hierarchy* and other elements) has its own chapter. Please read Chapter 5 starting on page 89.

2.3.2 Be Able to Inform Customers (Overview)

The topic described in the following section is devoted a separate chapter later in this book. Chapter 3 starting on page 51 will deal with 'Assurance Management'. What is meant by this? In this book, we look at cases in which user organizations use IT services provided by IT service providers. Since the two parties are usually legally separate and independent organizations, this is a complex customer-supplier relationship in a market in which other customers and suppliers are active. Therefore, information needs to be exchanged between the parties.

We are interested here in IT service security, or the risks associated with the use of IT services provided by the IT service provider. The risks can originate in three ways [5]:

- in the IT service provider (its capabilities, resources, etc.),
- in the IT service itself (its construction, form of delivery, etc.) and
- in the very fact that users and service providers are separate organizations, which has implications in terms of knowledge, controllability, measurability, and predictability of IT security.

Only *Joint Security Management (JSM)* appreciates this situation in its entirety along the entire life cycle of the business relationship between the two parties. At this point, we will limit ourselves to the necessary minimum, namely the exchange or provision of information by the IT service provider. We are therefore concerned with promises by the IT service provider and with evidence to be provided that the promises have been kept. See also Chapter 8 in [1].

Assurance Material

Topic: Informing users regarding *Fulfillment* (meeting the user's requirements).

Assurance Material [2] can be understood as all information or documents that contain information relating to the IT security of an IT service and primarily serve to inform users (customers). The user organization is thus enabled to assess the risks associated with the use of IT (or the IT service or IT products), to conduct operational risk management, to demonstrate compliance with laws, standards, regulations and the like, and to inform the user organization's customers as well as auditors, shareholders and other stakeholders.

In our context, 'assurance' is synonym with the 'trustworthiness' of an IT service. Though, the term 'assurance' indicates its message character: 'to assure somebody something'. Users make decisions about using IT services (also) based on their perception of the 'trustworthiness'. Trustworthiness is the degree of knowledge/confidence that the 'entity under consideration' (here: the IT service) 'is secure', i.e., it meets its security target (the security objectives in particular). Trustworthiness is achieved through techniques such as adherence to certain security procedures in the life cycle and established by providing transparency regarding security compliance with security-related information. Assurance Material contains security-related information from the IT service provider.

The Assurance Material is divided into three parts:

1) Information provided primarily prior to the conclusion of the contract and prior to the use of the IT service (→ further below: *Security Proposition* (or offer/statement on IT service security),
2) Evidence or confirmations provided with the contract or at the time of their conclusion (→ below: *Conceptual evidence*), and
3) Evidence or confirmations provided during the provision of the IT service (operational phase) (→ below: *Operational evidence*).

The *Attainment* phase essentially involves laying the foundations and making preparations for the *Assurance Material*, because such tasks are part of the development and implementation of the IT service.

The *Assurance material* is mainly used in the *Fulfillment* phase which will be discussed in more detail in the next chapter. The management of the information or material can be seen as a separate discipline, called *Assurance Management*, which is described in Chapter 3 in more detail.

2.4 Fulfillment

In the *Fulfillment* phase, the focus is on providing the user organizations with the required evidence (*conceptual evidence* and *operational evidence*). This includes setting up IT services in line with customer requirements and maintaining IT security during operations. This forms the core of the explanations in Section 2.4.1.

However, it is often forgotten that 'IT' is constantly being adapted and changed as business requirements change and need to be met. The further development of IT services and their IT security is the subject of the presentation in Section 2.4.2.

2.4.1 Providing IT Services Securely

Important decisions are made during the initiation of the business, the conclusion of the contract and the preparatory activities to establish readiness for secure operations. For example, it must be ensured that the fully developed and usually almost completely implemented IT service (see *Attainment*) meets the expectations and requirements of the customer (user organization). It must also be ensured that the processes and procedures for maintaining IT security will function properly later during ongoing operations. This also includes ensuring that the user organization and the IT service provider can then work together in the sense of *Joint Security Management (JSM)*.

The details are again explained in terms of the logical chronological sequence in which the relevant activities are carried out, so that a more detailed overall picture emerges of the phase entitled *Fulfillment* because, in the broadest sense, it is about meeting the IT security requirements of the customers (user organizations).

Security Proposition (Security offer)

> Information provided by the IT service provider to the customer (user organization) primarily before the contract is concluded and before the IT service is used. The information enables the user organization to make a choice regarding the provider and the IT service, including any options.
>
> The materials used can be multi-faceted; the term itself refers to the fact that it is an offer or statement about IT service security that supports and enables the customer's choice and decision.
>
> The provision or use of information is part of complex marketing and sales processes on the part of the IT service provider and part of complex procurement processes on the part of the user organization. See also Chapter 7 in [6].

Conceptual evidence

Conceptual evidence is information that shows that the security measures implemented or planned for an IT service are suitably designed and meet specific user/customer requirements.

Conceptual evidence is generated by comparing A) requirements, expectations, or target specifications of the user organization on the one hand and B) solutions, realizations, or actual specifications of the IT service provider on the other hand.

User organizations often communicate their requirements (A) in the form of tender documents or the invitation to submit a proposal (Request for Proposal, RfP).

IT service providers communicate their solutions, implementations, etc. (B) primarily in the form of a *Security Proposition* (security offer) which can consist of different materials.

Three use cases can be distinguished:

1) If the user organization communicates its own requirements and demands that these become the subject of the contract, the IT service provider should perform an explicit target/actual comparison. This enables the IT service provider to determine whether it can fulfill the customer-specific contract or contract clauses, or what still must be done to achieve this.
2) The user organization should request *conceptual evidence* from the IT service provider if it needs it itself as evidence to its auditors, regulators, and other stakeholders. This applies in the same way to *operational evidence*. It may also be that the user organization needs the evidence for its operational risk management.
3) If the user organization does not communicate its own requirements or does not make them the subject of the contract, the contract will not be customer-specific and will not contain any customer-specific contract clauses regarding IT security.[8] The contract is then based solely on the solutions or the IT service promise of the IT service provider (*Security Proposition* (security offer)).[9] The user organization performs the target/actual comparison in a

---

[8] Here it is implicitly assumed that the IT service is not customer-specific, but is also offered to other customers in the same way.

[9] Large customers (user organizations) in particular often come to the conclusion that the *Security Proposition* (security offer) is not sufficiently comprehensive. This then leads to customer-specific contracts even when the IT service is NOT customized but highly standardized.

suitable manner on the basis of the *Security Proposition* (B). The IT service provider does not perform a target/actual comparison and does not generate *conceptual evidence*.

If the IT service provider performs the target/actual comparison, it can also draw on other information, such as development documentation, which is not disclosed to customers or is not disclosed in full. Since the target/actual comparison always relates to a contract, the 'conceptual evidence' can also be referred to as 'contractual evidence'.

If the target/actual comparisons are satisfactory for both parties, they conclude a contract. A contract is always concluded, even if it can take various forms (see *Contracting*).

Operational Readiness

The provision of an IT service or its implementation generally takes place in two steps. In the FIRST step, the IT service is developed and technical prerequisites are created to enable the IT service to be offered. The extent to which this customer-independent implementation goes (pre-commissioning as part of the *Attainment*) and what it comprises depends on the IT service and is ultimately a decision for the IT service provider. Further actions are always required in a SECOND step to make the IT service available to a specific customer and thus establish 'operational readiness'. Establishing operational readiness can involve, for example, a) a basically finished IT service being activated for the customer and thus made available, b) predefined IT modules being installed and integrated on existing IT platforms using fully or partially automated processes, or c) certain IT components are being procured or installed and other postponed activities being made up for.

The following list describes activities for establishing readiness for secure operations that must be carried out as a matter of principle if the order volume is very large and the IT service is highly complex. Details depend on the IT service provider's business model, the IT service itself and its *Service Model*, and the technical and organizational implementation.

1) CONFIGURATION: After, if necessary,[10] new systems have been set up and/or existing platforms have been expanded, they are configured in a user-specific manner. For example, systems are assigned, storage units are allocated, virtual networks are defined, and network connections are established and user accounts set up so that users can reach the IT systems. The nature and extent of this work is determined by the IT service itself and the scope of the

[10] See remark at the end under this definition.

customer-specific options. The configuration is carried out automatically. Some of the work is carried out only after the 'migration'.

2) MIGRATION: User organizations often have predecessor systems when a new IT service is to be put into operation. Then existing data must be transferred (migrated) to the new system. It is rare to start from scratch. It may also be that legacy systems are to continue to be used, integrated into the new IT service, and possibly modernized and replaced later.

   Migration includes all activities for handing over the IT services to the (new) IT service provider. The difficulty lies in managing the transition (with/without changing the IT service and/or the IT service provider) while maintaining IT security and without outages and other disruptions to the business operations of the user organization.

   Accordingly, migration planning is necessary in which risks are identified and addressed. Trouble shooting and fallback options must be prepared. With regard to IT security, it must be kept in mind that neither previous measures nor the measures of the new IT service will be fully effective during the migration.

3) ENABLE ITSM: Processes and procedures required to maintain IT security are implemented for IT operations. This includes assigning operations teams for IT Service Management (ITSM) and making the appropriate tools, such as ticketing systems, operational. Of course, in the end, the entire configuration, including the components for IT service, must be brought up to date by Asset and Configuration Management and stored in the corresponding database (CMDB).

4) SET UP JSM: If not already done, the security organization is now also activated on the part of the IT service provider and the user organization. Responsibilities are assigned, interfaces between both parties are established and linked to the ITSM processes. The involvement of all parties, including suppliers, is ensured (for example, for troubleshooting). See *Joint Security Management (JSM)* [3].

5) INTEGRATE INTO THE USER ENVIRONMENT: The correct use of the IT service also significantly contributes to IT security. This starts with the (new) IT service being correctly integrated into the business environment of the user organization and harmonizing with other IT services, processes, and the business organization as a whole. Key decisions should have been made earlier during the negotiation and contracting phase. Now it is up to the user organization to ensure that activities are finalized and any remaining tasks are completed. However, it is also important in the operations or utilization phase that users use the IT service appropriately and observe IT security

guidelines. To this end, the IT service provider supplies information in the form of 'operating instructions'. The user organization must ensure that users are aware of these and apply them.

It is assumed here that the IT service provider manages capacity (server and other systems as well as personnel) as part of its Capacity Management, an IT Service Management (ITSM) process in accordance with ISO/IEC 20000 [7], in line with identified or forecast demand (see Demand Management). If the volume of overall business changes more or less continuously, the IT service provider can build new systems and expand existing platforms in line with the forecast business development. If IT services are customer-specific or individual contracts have a very high volume, this is only possible to a very limited extent. In general, any kind of change in the contract portfolio can lead to systems being newly installed, removed or replaced, and platforms being expanded or decommissioned. If systems are removed, care should be taken to securely delete customer data. If new systems are installed, the latest IT service security guidelines should be applied. Capacity adjustments should be made as described in *Attainment*. I.e., the relevant standards (→ *Corporate Standards*) are applied.

Operational evidence

Operational evidence is information that demonstrates that security measures are not only adequately designed, but also implemented, used, maintained, and repaired during operations. Operational evidence is usually provided in the form of security reports, which can be generated from, for example, log data, event data and audit trails. At the core of security reports are elements such as the threat situation, (averted) attacks, security incidents and the handling of vulnerabilities. In this way, they provide a picture of the situation (security posture).

With this we have reached the operational phase. The final element in *Fulfillment* deals with improving IT service security. This is discussed in Sect. 2.4.2 where we discuss 'modernization and innovation'. But before that, two important aspects will be explained: 'Contracting' and 'Operating instructions'.

Contracting

At the beginning, a contract is always concluded. In the simplest case, the contract is formed by the user organization accepting the General Terms and Conditions (GTC) and the service description 'at the click of a button'.[11] In the complex case, a customer-specific contract is drawn up, which is part of a comprehensive relationship management process as 'Business Relationship

[11] There are no formal legal requirements for such contracts in most countries.

Management (BRM)' defined in ISO/IEC 20000 [7]. This process is in turn closely related to the Service Level Management (SLM) process in which a) the service catalogs are used and b) the IT services to be provided and target values for them are defined on a customer-specific basis. Since SLM controls the operational implementation, internal orders may now also be triggered (on the basis of *Operational Level Agreements, OLAs*; see below). In addition, it may even be necessary to commission suppliers externally, so that so-called *Underpinning Contracts (UC),* see below, are concluded, extended, or used. In principle, all these contracts and agreements are relevant for IT security. The complexity can be mastered only through standardization and the use of blueprints.

Operational Level Agreements (OLA) are agreements or contracts on the procurement or delivery of IT services, IT systems, IT components, software, or other services WITHIN THE *IT service provider*'s own organization, i.e., between organizational units that work together at the operational level.

Underpinning Contracts (UC) are contracts that the *IT service provider* concludes with its *suppliers* who contribute directly or indirectly to the provision of the IT service but are NOT PART OF the IT service provider's organization. As a rule, these are manufacturers, vendors, producers but sometimes also other IT service providers or consulting firms and the like.

It was mentioned above that the user organization must ensure that users use the IT service correctly and observe IT security guidelines. To this end, the IT service provider supplies information in the form of 'operating instructions'.

Operating instructions (user manuals)

Operating instructions or user manuals inform users how to securely set up, configure, use, and maintain an IT service or product and what must be observed to maintain functionality and quality including IT security. Operating instructions or user manuals are used after the purchase decision has been made and access to the IT service environment or product has been granted.

It is often necessary to distinguish between privileged and normal users. Privileged users perform configuration work (such as setting up users) or perform configuration work for establishing *operational readiness*, which the IT service provider leaves to the user.

2.4.2 Improve IT Service Security

The user organization and IT service provider reach agreements (conclude contracts) before an IT service is provided and used for the first time. However, the contracts are based on analyses and assumptions whose validity must be reviewed regularly.

This often leads to the need to readjust requirements and modernize solutions. (A more detailed discussion about this can be found in Section 7.11 in [3].)

Very different events can give rise to the need to reconsider and, if necessary, update contracts that have been concluded. On the part of the user organization, business requirements change that have an impact on the IT services required or even directly on the IT security to be implemented. For example, existing applications (application software[12]) are modified, new ones are added or are to be operated in a different environment. The number of IT service providers and/or the application landscape is also frequently consolidated. Acquisitions, mergers, and other organizational restructuring are another reason for merging and changing IT services.

On the IT service provider side, it is usually technological progress, cost pressure and changing market requirements that make modernization necessary. If IT changes, this always has an impact on the required IT security measures and their maintenance. But a change in the threat situation can also make it necessary to improve IT security measures. Very often, certain IT components (products) are no longer available and must be replaced by others, or the IT service provider wants to replace products or suppliers for strategic or commercial reasons.

There are a wide variety of occasions and reasons why IT and possibly also the agreed IT security should be modified. Both parties can initiate this. If the modification is initiated by the IT service provider, the contract may require that the user organization is informed or even give its consent. It may also be necessary to modify the contract. This may also be the case if the initiative comes from the user organization.

It is essential to keep an eye on such modifications (in the operational phase and after conclusion of the contract) and their impact on IT security and to actively shape them. To ensure this and to be able to discuss the different cases, we introduce the term *Modification* even though the term and the fact that it stands for have little innovative value in themselves. Often, contract modifications are also referred to as change. To avoid confusion with the term commonly used in IT, a different term has been chosen. In addition, the 'modifications' in question are often very comprehensive, because they are also intended to encompass the corresponding IT projects and their implementation (modernization and innovation projects).

---

[12] Software that directly supports the end user as a consumer or as part of a business workflow in completing specific tasks. The application is at the top of the IT stack.

Modification (Modification)

Changes that, from the point of view of affected customers (user organizations), are made during the operational phase and are aimed not only at maintaining functionalities and/or quality parameters, but at significantly changing them.

Modifications are carried out by the IT service provider in project mode on a customer-specific or customer-independent basis. In any case, customers (user organizations) are affected, since this is not a new development of an IT service, but the modified IT service is intended to replace one currently in use.

Depending on existing contractual regulations, three cases can be distinguished, especially if the modification is initiated by the IT service provider:

a) the customer (the user organization) does not have to be informed and does not have to give consent,
b) the customer (the user organization) must be informed, but not explicitly agree to the modification, and
c) the customer (the user organization) must be informed and give its consent.

However, the modification can also be initiated by the user organization. In this case, too, the existing contract can define reservations or other rules.

As a rule, the user organization will set up a separate project for the modification, as it creates a new situation. Among other things, consideration must be given to whether the existing contract needs to be supplemented or modified, what requirements exist, what dependencies exist with existing IT services, and what the overall impact of the new solution will be. User organizations are often actively involved in the modernization projects.

2.5 Summary

Fig. 2.6 contains the most important terms for systematic IT service security management according to the security architecture ESARIS (Enterprise Security Architecture for Reliable ICT Services.

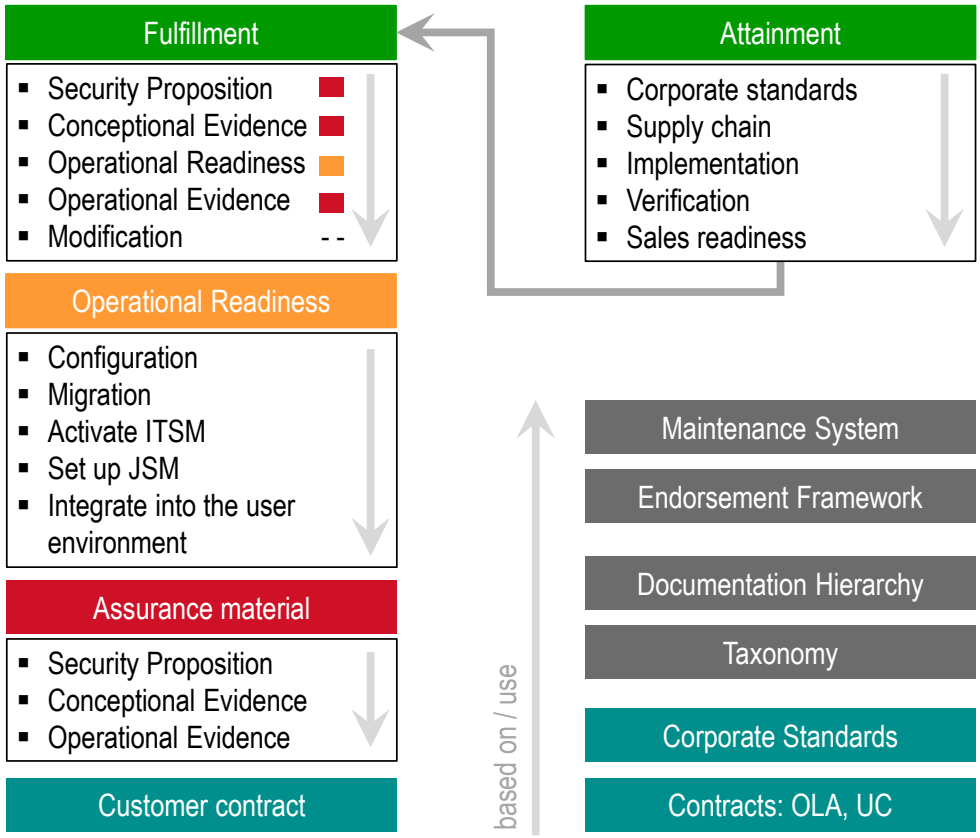


Fig. 2.6: Terms and structure of IT service security management

The *Attainment* (see Fig. 2.6) deals with the provision of security standards and their implementation. The FIRST STEP is to provide the standards. A *Maintenance System* (see Fig. 2.6) is used for creation, management, and provision. An *Endorsement Framework* ensures that relevant market requirements and important compliance requirements are taken into account. The standards are organized in a *Documentation Hierarchy* and with the help of a *Taxonomy* further sorted thematically and according to target groups. At the end, there is a set of *corporate standards* which form the basis for IT service security. The SECOND STEP concerns the 'supply chain' (see Fig. 2.6), i.e., the planning and execution of the procurement of all individual components and services. Agreements are made internally (*Operational Level Agreements, OLA*), and contracts are concluded with suppliers (*Underpinning Contracts, UC*) (see Fig. 2.6). The THIRD STEP is 'implementation' (see Fig. 2.6), followed by its 'verification' in the FOURTH STEP. The FIFTH STEP consists of establishing 'sales readiness' (see Fig. 2.6). In particular, documents are prepared for the user organizations (customers) of the IT

service provider. With these documents (referred to here as *Security Proposition* the *Attainment* ends, and we enter the *Fulfillment* phase (left in Fig. 2.6).

The *Fulfillment* (see Fig. 2.6) deals with ensuring that the security requirements of the user organization (the IT service provider's customer) are met and that appropriate evidence is available. In the FIRST STEP, the customer receives documentation. This documentation, called *Security Proposition*, is part of the *Assurance Material* (red in Fig. 2.6). If the user organization (the customer) articulates specific requirements, the SECOND STEP is to use the *conceptual evidence* to determine whether these requirements can be met. In each case, a 'contract' (see Fig. 2.6) is concluded with the customer. In the THIRD STEP, *operational readiness* is established. This step (amber in Fig. 2.6) is complex and consists of a) configuration, b) migration, c) activate ITSM, d) set up JSM and e) integrate into the user environment. In the FOURTH STEP, the IT service is provided in accordance with the contract. For the user organization (the customer), the provision of *operational evidence* plays a decisive role. This is also part of the *Assurance Material* (red in Fig. 2.6). During the operational phase, the FIFTH AND FINAL STEP may include *Modifications*.

Fig. 2.6 contains all defined core terms except *standardization, contracting* and *operating instructions*.

Bibliography

The first list below contains the literature referred to in this chapter. Some of the sources are only available in German. A second list of recommended reading has been added, containing only English references.

References (Sources)

[1] Eberhard von Faber and Wolfgang Behnsen: Secure ICT Service Provisioning for Cloud, Mobile and Beyond (ESARIS: The Answer to the Demands of Industrialized IT Production Balancing Between Buyers and Providers); Springer Vieweg, Wiesbaden 2017, 2nd updated and extended edition, 382 pages, 159 figures, ISBN 978-3-658-16481-2, https://doi.org/10.1007/978-3-658-16482-9

Note: Many of the terms and the basic structure of the ESARIS security architecture were already described in the first edition of this book from 2012.

[2] Eberhard von Faber: On the future of IT security management in the face of changes in technology and service delivery; translation of the article (https://doi.org/10.1007/s11623-021-1516-0) published in: Datenschutz und Datensicherheit - DuD, 45(10), October 2021; https://zero-

outage.com/opinion/on-the-future-of-it-security-management-in-the-face-of-changes-in-technology-and-service-delivery/, accessed December 13, 2023

[3] Eberhard von Faber and Wolfgang Behnsen: Joint Security Management: organisationsübergreifend handeln (Mehr Sicherheit im Zeitalter von Cloud computing, IT-Dienstleistungen und industrialisierter IT-Produktion); Springer Vieweg, Wiesbaden 2018, 246 pages, 60 figures, ISBN 978-3-658-20833-2, https://doi.org/10.1007/978-3-658-20834-9

[4] Eberhard von Faber: Twelve principles for systematic IT service security, Framework and principles for sustainable success; translation of the article (https://doi.org/10.1007/s11623-022-1687-3) published in: Datenschutz und Datensicherheit - DuD, 46, November 2022, https://zero-outage.com/opinion/12-principles-for-systematic-it-service-security/, accessed December 13, 2023

[5] Eberhard von Faber and Michael Pauly: User Risk Management Strategies and Models – Adaption for Cloud Computing; in: Securing Electronic Business Processes, Proceedings of the Information Security Solutions Europe, ISSE 2010, Vieweg+Teubner, Wiesbaden, 2010, pages 80-90, ISBN 978-3-8348-1438-8, https://doi.org/10.1007/978-3-8348-9788-6_8

[6] Eberhard von Faber: IT und IT-Sicherheit in Begriffen und Zusammenhängen, Thematisch sortiertes Lexikon mit alphabetischem Register zum Nachschlagen; Springer Vieweg, Wiesbaden 2021, 289 pages, 64 figures, ISBN 978-3-658-33430-7, https://doi.org/10.1007/978-3-658-33431-4

[7] ISO/IEC 20000 – Information technology – Service management – Part 1: Service management system requirements, Part 2: Guidance on the application of service management systems

Further Literature (Recommendations)

Basics of the metasystem are provided on four pages here:

[8] Eberhard von Faber: Twelve principles for systematic IT service security, Framework and principles for sustainable success; translation of the article (https://doi.org/10.1007/s11623-022-1687-3) published in: Datenschutz und Datensicherheit - DuD, 46, November 2022, https://zero-outage.com/opinion/12-principles-for-systematic-it-service-security/, accessed December 13, 2023

Some ideas were published for the first time here:

[9] Eberhard von Faber and Wolfgang Behnsen: A Systematic Holistic Approach for Providers to Deliver Secure ICT Services; in: ISSE 2012 Securing Electronic Business Processes, Highlights of the Information Security Solutions Europe,

ISSE 2012, Springer Vieweg, Wiesbaden, 2012, pages 80-88, ISBN 978-3-658-00332-6, https://doi.org/10.1007/978-3-658-00333-3_9

ELECTRONIC SUPPLEMENTARY MATERIAL
The figures are available as a PowerPoint file.
Contact the author by email or via LinkedIn.

3 Assurance Management

To manage IT-related risks, it is A) necessary to plan, implement and improve measures for IT security. To do this, B) the IT security achieved must be constantly reviewed and evaluated. Both belong together. See Fig. 3.1. However, if user organizations procure their IT services from independent IT service providers, the two areas of responsibility are partially decoupled and area of responsibility (B) changes significantly. The IT service provider is responsible for establishing IT security (A). The user organization, on the other hand, needs information about IT security to be able to measure and evaluate IT security and risks. Moreover, this information is required to satisfy the user organization's auditors, accountants, shareholders, authorities, customers, and other stakeholders. The collection, provision, communication, and evaluation of this information (B) is so central that we regard it as a separate discipline (Assurance Management) to which this chapter is dedicated. The related activities are very diverse and extremely important. IT security experts still talk abstractly about IT security and primarily about measures TO INCREASE IT security. Yet they already spend a large part of their time for procuring, evaluating, and communicating information ABOUT IT security.

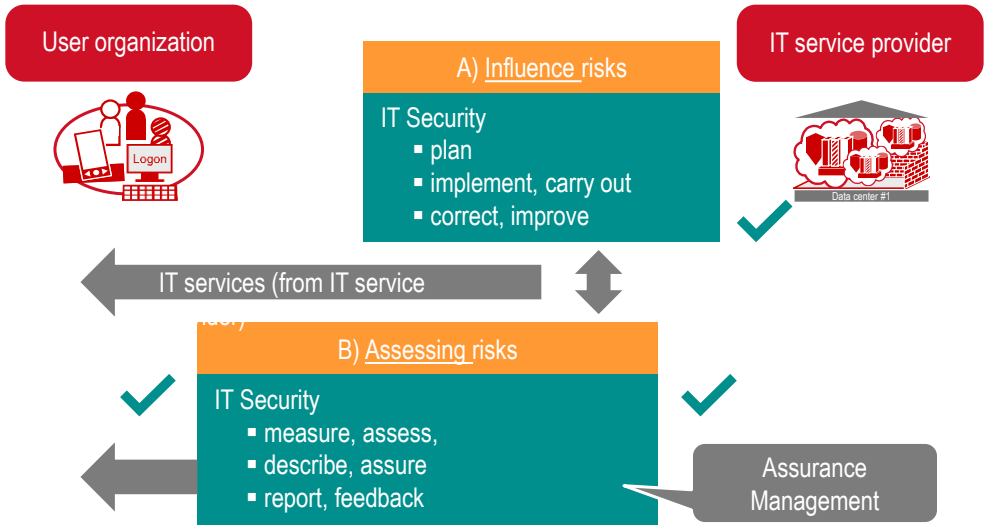


Fig. 3.1: Two tasks of IT security and their change due to the corporate separation of user and IT service provider

© The Author(s), under exclusive license to Springer Nature Switzerland AG 2024
E. von Faber, *Managing IT Service Security*, https://doi.org/10.1007/978-3-031-55533-6_3

3.1 The Character of Services and the Consequences

Very few of the employees working in security management in the broadest sense are actively involved in developing, implementing, and improving measures TO INCREASE IT security. They are concerned with information ABOUT IT security. And yet, the concept of 'assurance' or 'assurance management' [1] is little known; and its background is often poorly understood. Therefore, we start with an example on ownership and responsibilities. From this, we then derive requirements that make it understandable when user organizations need which information and what assurance management is all about.

Imagine one wants to use a complex property with a main building and various outbuildings. In principle, there are three possibilities. 1) One commissions an architect to design and build the main and auxiliary buildings according to one's own taste and requirements. Then one takes over the real estate as property and possession. 2) One can buy an existing property and take care of its maintenance and possible repairs oneself. In this case, the user has full control, but is also confronted with the full complexity and must have the necessary knowledge and resources to maintain the property and possibly develop it further according to new requirements. 3) The user can rent the property as a managed property. Maintenance is fully included. If something breaks down, the landlord is the contact person. The user can make separate agreements with the landlord about improvements to meet new requirements.

In IT, these options exist in principle as well. And here, as additional options in the rental model (3), a choice can be made between fully furnished, partially furnished and unfurnished. Tab. 3.1 shows some examples. In the case of an IT service, the IT is usually not owned by the user organization, but by the IT service provider (second column). Usually, the IT service provider also assumes the role of the administrator (third column). Sometimes, however, the role of administrator is also split. Then it must be defined who has to perform which tasks. The basic design (fourth column in Tab. 3.1) is almost always determined by the IT service provider in today's large-scale IT services. The *Service Model* determines the assignments more precisely [2].

If we return to the example with the real estate, there would still have to be two secondary conditions when transferring it to IT.

Secondary condition 1: You are not allowed to enter the site or inspect the buildings before you buy them. So, what would one do as an interested tenant? One would get floor plans, drawings, photos and the like and then decide. The 'offering brochure' for the IT security of an IT service was called *Security Proposition* in Chapter 2. Customer-specific details were provided by the *conceptual evidence*.

Tab. 3.1 : Responsibilities and opportunities to exercise influence
for users and service providers/manufacturers on products (simplified examples)

Role →	Owner of the IT		Administrator of the IT		Influence on construction		Influence in operations	
Party → / Delivery item ↓	User	Provider	User	Provider	User	Provider	User	Provider
Product	X					X		X
1. IT service, own operation	X		X		X		X	
2. IT service, unmanaged		X	X			X	X	
3. IT service, managed		X		X		X		X

Secondary condition 2: Even if you are moved in, you can use the rooms of the buildings, but you cannot see anything. Everything is dark - hidden in the dense fog of the cloud. Or a little more realistically, the user does not live there himself, but minors for whom he bears full responsibility. What would a user do here? It is always about information, but they must be demanded, provided, and procured. Outsourcing IT to an IT service provider changes more than one might think.

One should not transfer personal experience from the world of products to the area of IT services for large businesses. A *product* is produced by manufacturing and then handed over to the user for intended, foreseeable use [3]. In the business and key account sector, on the other hand, it is almost always an *IT service*. An IT service is provided over a longer period of time and does not just involve occasional interventions by the manufacturer as in the case of a product (such as warranty service and any troubleshooting by updating). The IT service is provided over a longer period of time and in a possibly changing environment. Instead of being specified in detail (like a product), an IT service defines key points that describe what is offered and what the manufacturer (here: IT service provider) does. Activity descriptions predominate. The result is less precisely defined for the user than with a product.

Here are a few examples of what can change in the environment and result in changes while an IT service is being delivered as contracted:

- A changed threat situation requires new IT security measures.
- New errors (vulnerabilities) are found that need to be eliminated.
- Products and components are no longer available or supported (no bug fixing). They must be replaced.
- Cost pressure or other such requirements necessitate changes in processes, the use of other IT components or a new IT architecture.
- New functional requirements of customers and markets require a redesign of IT systems.
- Increasing customer and market requirements for availability, performance and other quality parameters mean that IT systems have to be redesigned.
- Changes in usage habits lead to changes in IT.

In such situations, one product might be replaced by another. In the case of IT services, on the other hand, these or their underlying IT systems are modified.

Why are we interested in this? The relationship between the user and IT service provider is different, especially in the enterprise customer segment. Not only that the offer or service descriptions do not define everything precisely. Even how adjustments will be made in the future and what they will be is not precisely defined. Maintaining an IT service under changing conditions requires a certain degree of flexibility not only from the IT service itself, but also from the parties involved. That is why the user organization and the IT service provider are in a continuous exchange of information.

In addition to or as part of the IT service, the IT service provider must therefore also provide information, primarily at the beginning of the business relationship, but also continuously throughout the entire period of the business relationship. We refer to this as *Assurance Material* when it comes to information on IT security. See Fig. 3.2. Since the information can have consequences or often must lead to adjustments, information also flows back to the IT service provider. Both parties must be in continuous exchange, which can sometimes be more, sometimes less intensive. As has been shown, this arises from the nature of an IT service, in which one party is commissioned to provide a service over a longer period of time with the aid of information technology, which primarily means “doing something”.

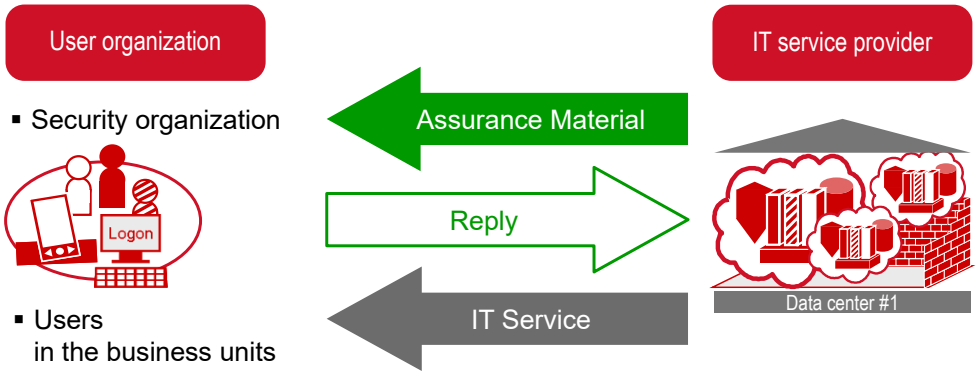


Fig. 3.2: Two delivery items (green and gray arrows) for two target groups [4]

3.2 The Two Faces of Being Sure

The literature and standards are usually primarily concerned with establishing and maintaining IT security. For user organizations, i.e., the vast majority of companies and institutions, however, this is not the primary task. Even among IT service providers, a large proportion of IT security experts are NOT concerned with establishing and maintaining IT security, but with managing information ABOUT IT security, i.e., with obtaining, evaluating, and communicating information ABOUT IT security.

The concept is called 'assurance' and is the focus of TCSEC [5], ITSEC [6] and Common Criteria [7]. The English verb means as many as 'to promise something' but also 'to ensure something'. The related term 'trustworthiness' refers to the result or the property which enables the user to trust or rely on the fact that residual risks are acceptable to him.

Assurance (trustworthiness)

> Assurance is the degree of knowledge/confidence that there are no unaccepted risks (or that security is guaranteed). This is the case when the 'security target' is implemented and the security objectives are achieved. Assurance is achieved through techniques such as following certain security procedures in the life cycle and through transparency regarding their compliance. Third-party investigations (security evaluations) often play an important role in establishing transparency and can also form the basis for certification.
>
> That is, a system or IT service is considered trustworthy when the user has sufficient information about the effectiveness and correctness of the security measures [6].

The definition objectifies: It links the property 'risk-free' for the user to the compliance with a 'security target' definition but only if sufficient information about this link is available.

In order to assess if the use of an IT service may do harm to the user organization, the latter needs security-related information raising the *Assurance* (trustworthiness) of the IT service. Note that one cannot straightaway identify risks and then rate the trustworthiness. The identification of risk requires a lot more, e.g., knowing vulnerabilities (deficiencies in IT security). The information relating to IT service security (for which the IT service provider bears responsibility) serves as a basis for the user organizations' operational risk management and to satisfy their auditors, accountants, authorities, customers, and other stakeholders. The concept of *Assurance* (trustworthiness) deserves more attention and, just like the establishment and maintenance of IT security, must be planned and implemented with individual measures. In addition to 'Security Management', an 'Assurance Management' is needed.

Assurance Management

> A system, including all associated activities, for obtaining, assessing, and communicating information about IT security. While 'IT security management' in the narrower sense INCREASES IT security and aims to do so, 'Assurance Management' activities DO NOT INCREASE IT security, although they may provide important impetus for it.
>
> Assurance management manages *Assurance Material*. This can be understood to mean all documents that contain information about IT security and have been prepared primarily to inform users. Users are thus enabled to assess the risks associated with the use of IT (IT service or IT products), to maintain an operational risk management system, to provide evidence of compliance with laws, standards, regulations and the like, and to inform customers, auditors, shareholders and other stakeholders.

It is important to understand that 'Assurance Management', unlike 'IT security management', does NOT INCREASE IT SECURITY, although it may provide important impetus for it. Nevertheless, the tasks of an 'Assurance Management' at a larger IT service provider are very diverse and extremely important, especially if it provides IT services commercially.

3.3 Provide and Manage IT Security Information

Procuring IT services that meet the IT security requirements of the user organization means at least three things: 1. selecting the 'right' (trustworthy) IT service provider, 2. selecting the IT service that meets the requirements (is trustworthy), and 3. being able to continuously check whether both assessments are still correct. In addition,

4. the user organization not only has the option of terminating the contract and leaving the provider, but can also exercise influence in such a way that this is not necessary and the IT service is improved.

Thus, with respect to the IT service provider (No. 1, 3 and 4), there are the following issues [8] or criteria from the perspective of the user organization:

- Controllability: How can the IT service provider be managed to ensure that it does the right thing?
- Capability: How to know if the IT service provider is capable of doing the right things?
- Transparency: How can one know if the IT service provider is doing the right thing?
- Measurability:
  - How to know if the IT service provider is doing the right thing in the right way?
  - How to know if the goal is achieved and the security objectives are adequately met?
- Predictability: How can one know if the IT service provider will continue to do the right thing in the right way in the future?

With regard to the IT service (No. 2), the user organization has defined its requirements, which are compared with the characteristics of the IT service and its production. Information in this regard from the IT service provider was called *conceptual evidence* (see Section 2.4.1).

During operations or in the phase of provision and use of the IT service, the IT service provider should continuously provide such information. It is referred to as *operational evidence*.

The user organization evaluates them. In the first case, it makes its purchasing decision, for example. In the second case, the information is used for its own operational risk management and as evidence to its own stakeholders. In both cases, the information is needed for auditing and determining compliance, and the user organization can use it as a basis to demand improvements, for example.

Standing on the other side, what must the IT service provider do?

Here are some examples [1] associated with the 'Assurance Management' (managing information about IT security) at the IT service provider:

- Analysis of the justified information needs of the (potential) users regarding IT security and compliance of the IT services and comparison with the practices of possible competitors of the IT service provider,
- Participation in the development of a corresponding transparency strategy that determines the importance the IT service provider attributes to informing its

customers (users) and interacting with them in general, and how this is to be implemented in practice,

Note: We are only talking about participation here because there are other tangible influencing variables that determine a transparency strategy. So, multiple stakeholders will be involved not only the IT security management organization.

- Define and decide which information can be communicated to customers (users) under which conditions and which information is considered intellectual property and may not be communicated,

  Note: There are other reasons for not communicating information to customers. If technical details may become part of the contract or may considered by the user organization to be agreed, the IT service provider may not be possible to easily change the implementation.
- In the early phases of the development of an IT service, help to formulate the IT security objectives and the customer promise (regarding IT security and compliance),
- Ensure that the technical security measures of an IT service are adequately described in its service description in a user-friendly and sufficiently comprehensive manner,
- Ensure that the life cycle-related IT security measures (development, implementation, operations, maintenance, decommissioning) of the IT service are described adequately, in a user-friendly manner and in sufficient detail in the service description,
- Ensure that both *conceptual evidence*) as well as *operational evidence* can be provided to show customers (users) that the technical and life cycle security measures have been implemented,
- Support and control that all suppliers of the IT service provider also contribute the necessary information, that appropriate agreements are made (this requires the analysis of internal and external supply relationships along the supply chain) and that the information is used adequately,
- In doing so, support that the IT service provider's documentation is structured and documents are marked in such a way that strictly internal use on the one hand and mixed internal and external use on the other hand can be carried out in compliance with the rules and without additional effort,
- Ensure that compliance statements are well prepared, can be substantiated, and can be presented accurately,

- Support and control the creation of material for sales purposes (presentations, flyers, websites, and the like),
- Accompany the drafting of terms and conditions and blueprints for contracts,
- Assist in responding to customer (user) inquiries prior to contracting, during any negotiations, and throughout the operational phase until the completion of decommissioning,
- Develop solutions and monitor their application so that customers (users) are provided with IT security information in accordance with contractual agreements (security reporting),
- Organize and support external audits, tests and certifications and forward their results to IT security management, as well as customer requests that become known and the like.

The tasks of an *Assurance Management* are therefore extremely diverse for a larger IT service provider. They are also extremely important, especially if the IT service provider offers the IT services commercially to a large number of customers who have different requirements because they operate in different industries, provide different services and are subject to different laws and regulations.

3.4 Organization

IT security experts still talk abstractly about IT security and primarily about measures TO INCREASE IT security. Yet they already spend a large part of their time for procuring, evaluating, and communicating information ABOUT IT security. It is time that, in addition to 'Security Management' (ensuring), the '*Assurance Management*' (assuring) is also systematized and understood as a separate discipline. User organizations and all buyers in the value chain require information ABOUT IT security (*Assurance Material)*) in order to assess risks and make appropriate decisions.

Should organizations therefore have two departments? One for 'IT security management' and one for 'Assurance Management'? Tab. 3.2 shows topics or qualifications and their evaluation for IT security on the one hand and *Assurance Management* on the other. The criteria were chosen in such a way that differences become visible. Often the difference is not so great because one of the two ratings is 'medium'. This is again due to the fact that this single rating again represents a mean value and smoothes out the swings. Overall, however, it is probably the case that personnel with quite different qualifications are required for both areas of expertise (IT security management and Assurance Management) and that the activities differ greatly in their character and characteristics. An organizational separation into task areas or at least a differentiation of roles therefore seems obvious and useful.

Tab. 3.2 : Can IT security and assurance be separated organizationally?

Topics, qualifications	IT Security Management	Assurance Management	Difference (absolute)
Necessary leadership	high	medium	medium
Need for decision	medium	low	large
Customer reference	low	high	large
Technology reference	high	medium	medium
Intervention in IT	high	medium	medium
Intervention in ITSM processes	medium	low	large
Automation capability	low	medium	large
Importance	high	high/medium	low

Fig. 3.3 shows some task areas or organizations (primarily on the IT service provider side) that are directly relevant to IT service security. One should only view the right side as a hierarchy in a very limited way; the left side reminds who works for whom.

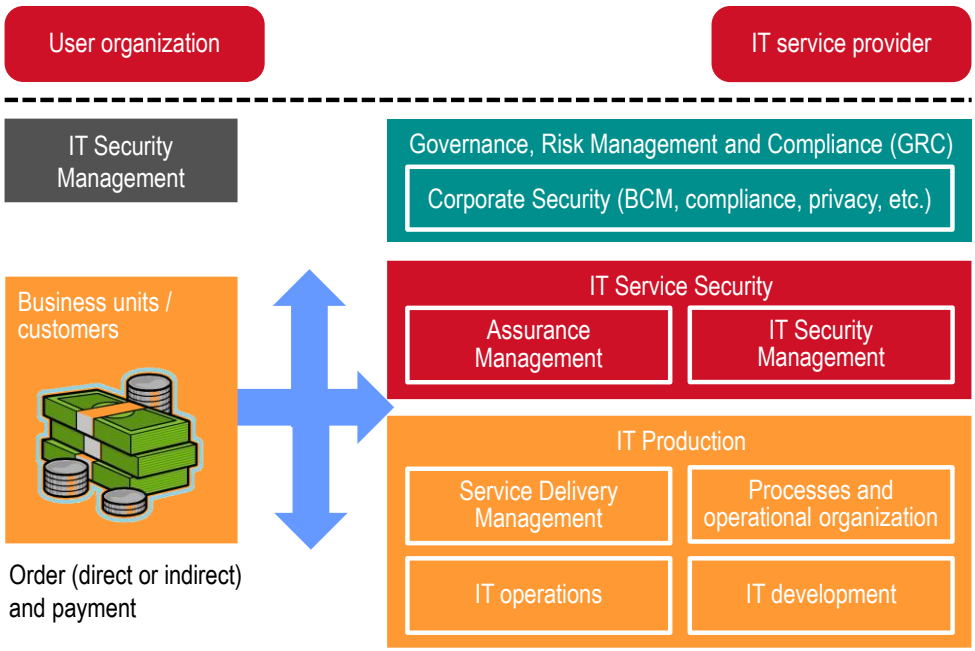


Fig. 3.3: Security-relevant task areas

The collection and assessment of information on IT security is very closely linked to the issue of *compliance*. Many organizations maintain separate departments for this purpose. The same applies to audits, of which the *security audits* are of most interest. As in *Assurance Management* information ABOUT IT security is collected. All three areas are somewhat similar in this respect. However, while *Assurance Management* is primarily concerned with providing information to the user organizations, the other two areas focus on target/actual comparisons and identifying possible deviations. *Compliance* is the overarching theme, and *security audits* are ONE OF the means of determining compliance or deviations. The following definitions are taken from the author's book [2].

Compliance

In the business environment, the term 'compliance' has become established. On a technical level, the term conformity is also in use.

a) In the corporate context, compliance is understood to mean adherence to internal and external standards, specifications, and other requirements, for example from contracts. Compliance includes the identification and enforcement of guidelines, laws, contractual requirements, etc., and the monitoring of their observance.

b) For organizations or for their employees, compliance means acting in accordance with certain defined standards. This is usually achieved by defining processes and procedures that are applied in practice.

c) A physical entity meets the compliance or **conformity** requirements if its properties match predefined characteristics or attributes or if it has a predefined quality or predefined attributes. Property here can also mean being constructed in a predefined way.

Security audit

A security audit is a random, independent review, analysis, and evaluation of records, reports, or observed facts. The focus is on comparison or *compliance* with expected or warranted characteristics.[13] It examines whether measures are in place and effective, whether policies and procedures are adhered to, and whether changes to measures, policies, or procedures are necessary and, if so, which ones are recommended.

---

[13] In principle, the organization concerned can even object to an audit that is too deep and too extensive. In the case of an evaluation, on the other hand, it is more likely to be entitled only to a comparable assessment (for example, in comparison with competitors or competing products). Of course, both approaches must be objective.

A security audit can be performed by departments internal to the organization (such as the audit or security department) or by external parties (customers, auditing companies, etc.).

An audit is conducted in the form of a walk-through, questioning and evaluation of security records and usually includes practical tests.

User organizations are also interested in whether the IT service or IT service provider conforms with certain specifications ('is compliant'). This is often checked or confirmed by *security audits*.. The user organization is itself subject to certain regulations and must provide evidence of *compliance*. It is supported in this by *Assurance Material* which it receives from the IT service provider.

Bibliography

The first list below contains the literature referred to in this chapter. Some of the sources are only available in German. A second list of recommended reading has been added, containing only English references.

References (Sources)

[1] Eberhard von Faber: On the future of IT security management in the face of changes in technology and service delivery; translation of the article (https://doi.org/10.1007/s11623-021-1516-0) published in: Datenschutz und Datensicherheit - DuD, 45(10), October 2021; https://zero-outage.com/opinion/on-the-future-of-it-security-management-in-the-face-of-changes-in-technology-and-service-delivery/, accessed December 13, 2023

[2] Eberhard von Faber: IT und IT-Sicherheit in Begriffen und Zusammenhängen, Thematisch sortiertes Lexikon mit alphabetischem Register zum Nachschlagen; Springer Vieweg, Wiesbaden 2021, 289 pages, 64 figures, ISBN 978-3-658-33430-7, https://doi.org/10.1007/978-3-658-33431-4

[3] Torsten Gründer: Erfolgreiches IT-Management – Strategisches Sourcing als Option; in: Torsten Gründer (Ed.): IT-Outsourcing in der Praxis: Strategien, Projektmanagement, Wirtschaftlichkeit, Erich Schmidt Verlag, Berlin, 2nd edition, 2011, pages 17-28, ISBN 978-3-503-09015-0

[4] Eberhard von Faber and Wolfgang Behnsen: Secure ICT Service Provisioning for Cloud, Mobile and Beyond (An Architectural Approach Balancing Between Buyers and Providers); Springer Vieweg, Wiesbaden 2013, 298 pages, 74 figures, ISBN 978-3-658-00068-4, https://doi.org/10.1007/978-3-658-00069-1

NOTE: This is the first edition from 2012, and is cited here because Chapter 2, cited here, is not included in the second, updated and extended edition from 2017.

[5] Trusted Computer System Evaluation Criteria; also known as the Orange Book; United States Government Department of Defense (DoD) standard of requirements for assessing the IT security mainly of products; now superseded by [7]

[6] Information Technology Security Evaluation Criteria (ITSEC); Version 1.2, June 1991, 163 pages, ISBN 92-826-3004-8; available at: https://www.bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Zertifizierung-und-Anerkennung/Zertifizierung-von-Produkten/Zertifizierung-nach-CC/IT-Sicherheiskriterien/ITSEC/itsec_node.html, accessed December 13, 2023; now superseded by [7]

[7] Common Criteria for Information Technology Security Evaluation, Part 1: Introduction and general model; April 2017, Version 3.1 Revision 5; https://www.commoncriteriaportal.org/cc/index.cfm, accessed December 13, 2023

Earlier version also as: ISO/IEC 15408 – Information technology – Security techniques – Evaluation criteria for IT security – Part 1: Introduction and general model; 2009

[8] Eberhard von Faber and Michael Pauly: User Risk Management Strategies and Models – Adaption for Cloud Computing; in: Securing Electronic Business Processes, Proceedings of the Information Security Solutions Europe, ISSE 2010, Vieweg+Teubner, Wiesbaden, 2010, ISBN 978-3-8348-1438-8, pages 80-90, https://doi.org/10.1007/978-3-8348-9788-6_8

Further Literature (Recommendations)

[9] Information Technology Systems Security Evaluation Manual (ITSEM); version 1.0, September 1993, 262 pages, ISBN 92-826-7087-2; available from: https://www.bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Zertifizierung-und-Anerkennung/Zertifizierung-von-Produkten/Zertifizierung-nach-CC/IT-Sicherheiskriterien/ITSEC/itsec_node.html, accessed December 13, 2023; now superseded by [10];

In particular, the first parts of the ITSEM are recommended for reading; the methodology [10] belonging to [7] on the other hand, focuses very much on the application of the Common Criteria during a system or product evaluation; [10] is thus given for reference purposes only.

[10] Common Methodology for Information Technology Security Evaluation, Evaluation methodology; November 2022, CEM:2022, Revision 1; available

from: https://www.commoncriteriaportal.org/cc/index.cfm, accessed December 13, 2023

[11] Eberhard von Faber: On the future of IT security management in the face of changes in technology and service delivery; translation of the article (https://doi.org/10.1007/s11623-021-1516-0) published in: Datenschutz und Datensicherheit - DuD, 45(10), October 2021; https://zero-outage.com/opinion/on-the-future-of-it-security-management-in-the-face-of-changes-in-technology-and-service-delivery/, accessed December 13, 2023

ELECTRONIC SUPPLEMENTARY MATERIAL
The figures are available as a PowerPoint file.
Contact the author by email or via LinkedIn.

4 Taxonomy

Misunderstandings are often encountering. People argue, they try to convince, but actually the participants are talking about different things. A lot of time passes before this is even noticed. And then it takes until the participants are at least thematically together. Some may think this 'process' is inevitable. It is not! And it is expensive! Every project management primer says: You need a glossary (vocabulary, terminology). Aviation knows it even better (see Fig. 4.1): You need a chart, terms, and codes. This chapter introduces a Taxonomy for IT service security. The Taxonomy is a graphic showing topic areas relating to technologies and activities, each with a brief profile. Terms and codes ease referencing. The Taxonomy creates overview and clarity and is the universal tool for organizing, orchestrating, and optimizing IT service security. The Taxonomy is derived from goals and design principles. Several use cases are considered. Brief profiles for all topic areas are provided which can be used as the basis for elaborating or compiling related IT security standards.

The ATA reference and numbering system systematizes hundreds of subsystems of an aircraft. It serves as a reference for the exchange of information in the supply chain up to the airlines during maintenance.

The tables show the subchapters of the category "Aircraft systems" as an example.

Chapter	System
ATA 21	Air conditioning system
ATA 22	Automatic flight control system
ATA 23	Communication
ATA 24	Electrical power
ATA 25	Equipment
ATA 26	Fire protection
ATA 27	Flight controls
ATA 28	Fuel system
ATA 29	Hydraulic power

Chapter	System
ATA 30	Ice and rain protection
ATA 31	Instruments
ATA 32	Landing gear
ATA 33	Lights
ATA 34	Navigation
ATA 35	Oxygen
ATA 36	Pneumatic
ATA 38	Water / waste
ATA 49	Airborne auxiliary power

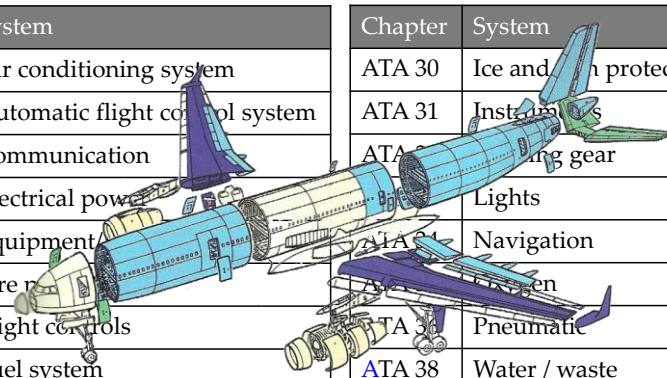


Fig. 4.1: ATA system for commercial aircraft manufacturing, certification, and maintenance (Source for aircraft illustration and subsections: [1])

© The Author(s), under exclusive license to Springer Nature Switzerland AG 2024
E. von Faber, *Managing IT Service Security*, https://doi.org/10.1007/978-3-031-55533-6_4

NOTE: The Taxonomy described below improves upon the original ESARIS Security Taxonomy [2] from earlier versions of the security architecture ESARIS (Enterprise Security Architecture for Reliable ICT Services). A first version of the following paper appeared in English as an 'opinion paper' by the author on the website of the Zero Outage Industry Standard association. [3]. The present version has been improved and differs from it.

4.1 Introduction

An organization and orchestration scheme (taxonomy) is presented that supports information security management in gaining an overview of technical solutions and process-related activities for securing IT and, based on this, in assigning responsibilities and tasks and orchestrating activities. The Taxonomy is based on the technical and operational reality of IT service delivery. It builds largely on what is known and refrains from using trends and fashionable terms to enable its long-lasting use as an ordering and organizational scheme. Of course, all modern solutions can be found and assigned just as established solutions and common practices. The Taxonomy promotes understanding and creates an overview.

4.2 Goals and Rationale

A primary task of information security management is certainly to assign responsibilities and tasks and to orchestrate activities. This is made much easier if, instead of monolithic documents and technical terms, graphical diagrams are used to illustrate the fields of activity and relate them to one another. Therefore, in the following a *Taxonomy* is presented, which compared to the original version [2] has been significantly changed and improved.

The Taxonomy shall

- be a small-format illustration that provides an overview of ALL topics,
- standardize terminology as well as the understanding of the topic areas,
- support the division of labor and guide stakeholder collaboration to be able to create an integrated secure whole.

There are some principles that should determine the structure of the Taxonomy. They are explained below, first presenting the situation, and then describing the principle.

When the areas of activity to be orchestrated by information security management are broken down, IT security solutions or product groups are often chosen, such as firewall management, encryption, or access control. However, it is not these solutions or product groups that deserve our primary attention. Rather, it is about

securing the IT used and the data that is stored, processed, and transmitted there. Moreover, in almost all cases it is not the IT security experts who use, install, and maintain these products, but IT architects and IT administrators. This gives rise to the first principle:

1.) In order for the protection of IT and data to come to the fore and for IT staff to be able to find their way around, an organization and orchestration scheme (graphical diagram, taxonomy) should primarily start from IT and use its structure.

In order to save costs and increase quality, as many activities as possible should run in the same way and be defined independently of the IT systems to be protected. The IT Service Management (ITSM) processes as defined in ISO/IEC 20000 [4] provide a good model for this approach. Also, in many processes such as Incident Management, it is not initially known what type of IT components are involved. Monitoring and software updates (patching) should also follow similar procedures, since it is the overall system or IT service that is involved, which must have and retain assured IT security properties. This results in the second principle:

2) The Taxonomy presented in the following separates technology and practices and thus supports the implementation of the principle 'Secured by Definition' [5].

The choice of technology areas should be made in such a way that, as far as possible, all relevant IT services can be composed from them. This is very important because the focus should be on IT service security and not on protecting the enterprise. This brings us to the point that IT services are nowadays often purchased and produced by third parties. So, we are dealing with two parties: the user organization or a business unit such as HR on one side and an IT service provider or IT department on the other. It is a matter of fact that both parties must do their part in IT security. The activities are interrelated and must be coordinated with each other in terms of *Joint Security Management (JSM)*, which has to be defined across the organization [6]. This results in the third principle:

3) The Taxonomy presented below supports collaboration in the sense of *Joint Security Management (JSM)* by defining and ordering fields of activity along a life cycle, for which in most cases tasks for the user organization and for the IT service provider are defined in turn [6].

Based on the three goals and the first three principles, the Taxonomy is given the structure illustrated in Fig. 4.2.

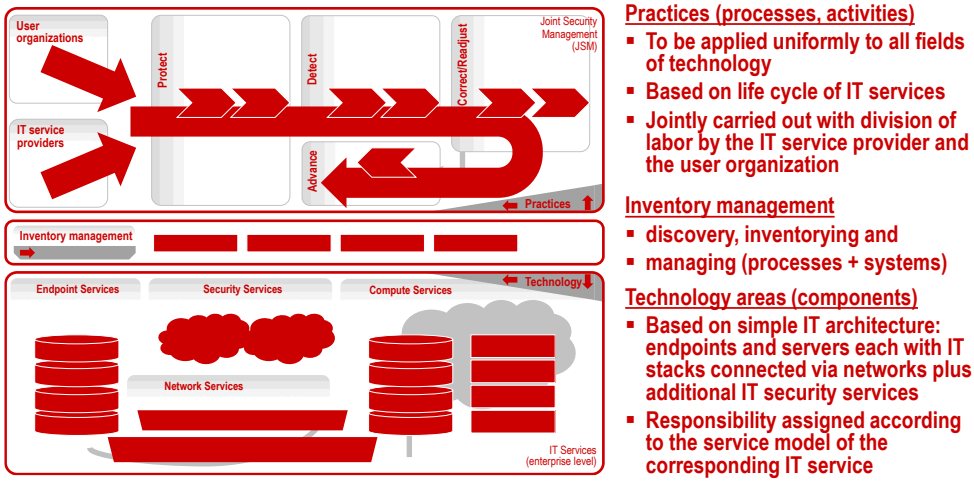


Fig. 4.2: Illustration of the basic structure of the Taxonomy

With regard to the IT service provider, the Taxonomy focuses not only on producing secure IT services, but also on providing security-related information. For internal purposes of the IT service provider, this is taken for granted, but user organizations also need detailed information - not only during procurement, but throughout the entire life cycle. The task is so complex that one can speak of *Assurance Management* as a separate discipline, in addition to the classic 'IT security management' [7]. This is the fourth principle:

4) The *Assurance Management*, which deals with the provision and use of information about IT security, is considered in the design of the Taxonomy.

4.3 Overview

The Taxonomy, now shown in its final form in Fig. 4.3, consists of three groups:

1. Practices (upper half, see Fig. 4.3),
2. Technologies (lower half) and
3. Combinations of practices and technologies for collecting and managing inventory data ('inventory management' in Fig. 4.3).

The groups contain clusters ('Inventory management' is its own) and each of the eleven clusters contains topic areas. There are 41 topic areas in total.

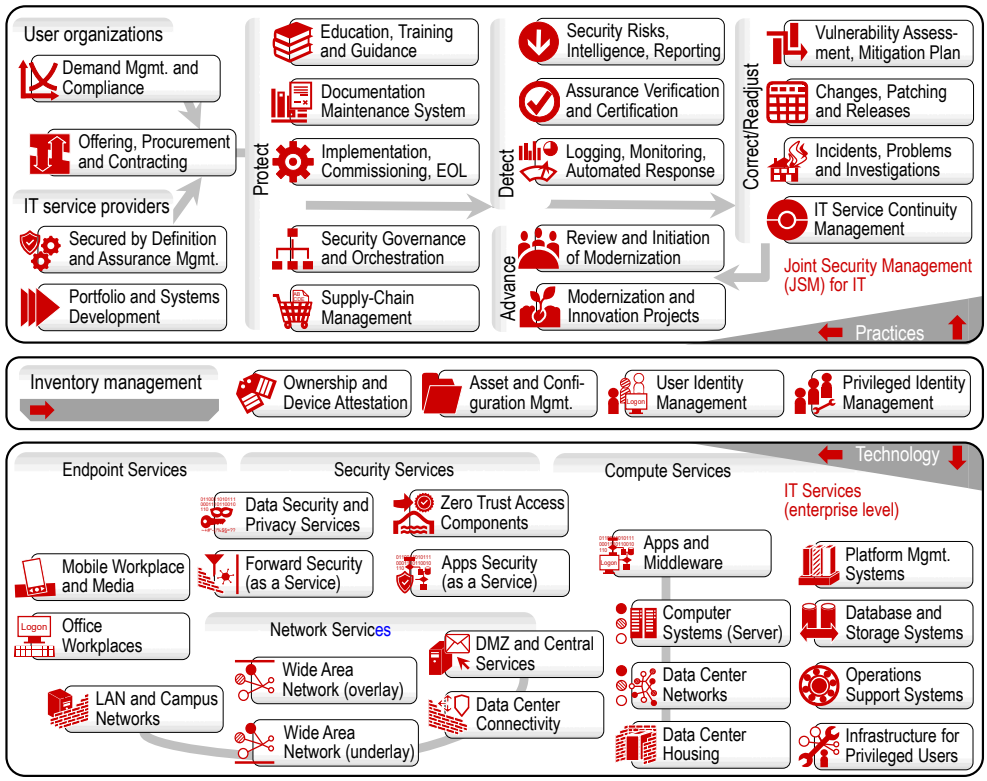


Fig. 4.3: Taxonomy IT service security (enterprise level)

Group 1: The practices (upper half, see Fig. 4.3) are arranged in five columns, with the fifth column below the third to save space. Following the arrows, the five columns form a life cycle of the business relationship between the user organization and the IT service provider and, at the same time, address cycles inspired by PDCA. The five columns are Initiate (unlabeled), Protect, Detect, Correct/Readjust, and Advance.

Only at the very beginning (column/phase 1: 'Initiate') do both parties still act largely independently of each other. In the further course, there is hardly any activity that does not require the cooperation and coordination of both parties as well as the definition of concrete tasks with interfaces and responsibilities. This logic and structure originate from the *Joint Security Management (JSM)* [6]. There are 18 topic areas with practices.

Group 2: The four topics on collecting and managing inventory data ('Inventory management') can be found in the middle of Fig. 4.3. At their core, these are practices which not only require various specific IT systems (technologies), but are also closely related to both other practices (upper half) and other technologies (lower half). This

explains their position in the middle between practices and technologies. At the same time, their central importance as a basis for operational IT security management is emphasized. There are 4 topic areas in this group.

Group 3: The arrangement of the technology areas (lower half, see Fig. 4.3) is based on a simple technical IT architecture or division of IT services into 'Workplace' or 'Endpoint Services' (end devices) on the left, 'Compute' or 'Computing Services' (applications with underlying IT infrastructure from the data center/cloud) on the right and the connecting 'Network Services' (network connections) in the bottom center. The latter consider that wide area connections are also offered virtualized as SD-WAN. Added to this are 'Security Services' (center above 'Network Services') as a fourth cluster, since security services are now being centralized more and more and are moving 'into the cloud'. There are 19 topic areas on technologies.

4.4 Application

The Taxonomy contains a total of 41 topic areas. It consists of two halves (practices and technologies) and is further divided into clusters: six in the practices, four in the technologies plus one between the two halves.

Each specific IT service builds on or uses different technologies. Therefore, depending on the IT service, other technology areas may or may not be relevant. For example, an end device (workplace computer) is not always part of the IT service provided by the IT service provider. If one is additionally required, which is usually the case, the user organization bears responsibility for its procurement and use. I.e., a technology area can be relevant for the IT service provider or for the user organization. Responsibility for the application is another common example. It is often provided by the user organization (possibly with the help of another IT service provider). Only in the case of Software-as-a-Service (SaaS) does the cloud service provider also bears responsibility for the application.

In the case of practices, too, responsibility (for topic areas) corresponds with the contractually agreed or offered IT service. As a rule, the IT service provider also manages the technology areas for which it is responsible, and, which are therefore relevant to it. However, there are also 'unmanaged' services for which this does not apply or only applies to a limited extent. What is more, the IT service provider can take over certain 'management' services for technology areas without being responsible for the technology area itself because the user organization (possibly with the help of another IT service provider) selects and installs the relevant IT systems and components.

Looking at each individual topic area therefore helps to determine the exact distribution of responsibilities and tasks and to establish which shares are assumed by the

user organization and which by the IT service provider (or its supplier). According to this division of labor the internal and external supply chain is organized. If a topic area of the Taxonomy falls within the IT service provider's area of responsibility, it must apply the standards/documents assigned to the topic area. (The handling of its suppliers is detailed in Chapter 7.) The selection process just described is called *Provider Scope of Control* [2].

For an 'unmanaged service', for example, some of the practices describing the maintenance and care of IT security do not apply or apply only to a limited extent because they are not the subject of the contractually agreed service. And obviously, certain technology areas are only relevant if the corresponding technology is also installed in the IT service in question. If a topic area is relevant, the standards/documents assigned to it must be applied. At the same time, clarity is created for contracts to be concluded.

The main applications of the Taxonomy are:

- Gain an overview and support communication and understanding,
- Organize documentation (documents/standards) and find them more easily,
- Identify tasks and assign responsibilities,
- Division of labor in the provision of IT services and manage supply chains internally and with suppliers and customers,
- Organize cooperation between IT service provider and user organization in the sense of *Joint Security Management (JSM)*,
- Compilation of documents/standards relevant (i.e., to be applied) to a particular IT service as a basis for implementation, operations, and contractual agreements in the supply chain,
- Orchestrate activities.

In this way, the Taxonomy becomes a practically usable tool for information security management or, more precisely, IT service security management.

4.5 Details

The following sections describe each topic area in the form of a brief profile. The individual security aspects and security measures are not described. This is reserved for the documents/standards of the respective organization to be assigned to each topic area. In order to achieve a common understanding and to facilitate coordination, only a brief outline is given of which processes, tasks, products, solutions, etc. each area covers.

NOTE: A simple structure with user organization and IT service provider is used in the descriptions. Of course, the IT service provider has suppliers, and the user organization may use IT services from more than one IT service provider. This is not discussed further in this chapter. The structure and descriptions must be adapted and applied accordingly to reflect these cases. Details are provided later in Chapter 7 headed 'Supply-Chain Relationship Management'.

4.5.1 Practices

The *Taxonomy* can be used equally by the IT service provider and by user organizations. Problems and solutions for IT service security affect both parties, and both parties must be involved in and contribute to these along the entire life cycle of the business relationship. This is the principle of *Joint Security Management* (JSM):

Joint Security Management (JSM)

> Joint Security Management (JSM) is a cross-organizational security management system that brings together user organizations and IT service providers, with an a priori focus on the interaction between legally distinct organizations [6].
>
> Joint Security Management is designed to take account of the fact that today's IT industry is organized based on division of labor and that several companies and institutions must make their contribution so that IT services are adequately secured and security incidents are adequately handled. Joint Security Management builds security management along the industrial, market-based processes and value chains characteristic of modern IT [6].

In the following presentation and outline of practices it should be considered that all involved parties, including the user organization, must make their contribution to IT service security and develop standards for IT service security that address the topics and aspects that the *Taxonomy* contains.

The practices (upper half of the Taxonomy, see Fig. 4.3) are organized into five phases that correspond to the life cycle of the business relationship between the user organization and the IT service provider while addressing cycles inspired by PDCA. The five phases (and thus clusters of the Taxonomy) are: 'Initiate' (not labeled), 'Protect', 'Detect', 'Correct/Readjust', and 'Advance'.

Following the idea and logic of *Joint Security Management (JSM)* [6], it is necessary in almost all topic areas that both parties cooperate and coordinate as well as define the specific tasks with interfaces and responsibilities. - Eighteen topic areas with practices have been defined, which are outlined in Tab. 4.1.

Tab. 4.1 : Brief profiles of the 'Practices' topic areas

Cluster: Initiate	Relevant for the user organization
Demand Mgmt. and Compliance » DMC «	In the business initiation phase, the user organization is primarily concerned with knowing its own requirements and documenting them. The need for security and the general security requirements are identified by analyzing legal regulations, industry-specific requirements, and internal corporate specifications. Procurement is prepared by investigating possible providers and their offerings (market analysis) and developing plans for organizing procurement.
Cluster: Initiate	**Relevant for the IT service provider**
Secured by Definition and Assurance Mgmt. » SDA «	Before customers come into play, the IT service provider must align its security management with the core business of its industrialized IT production (*Secured by Definition* principle). However, the actual and central task in the context of *Joint Security Management (JSM)* is to align security management with IT services and customers. To this end, service and security specifications for customers are developed, and marketing, sales, and contract management are aligned toward meeting customers' information needs about IT security (*Assurance Management*).
Portfolio and Systems Development » PSD «	The IT services offered (offerings) and their descriptions form a basket called service offering portfolio or simply portfolio. The service catalog which describes the offerings is made available to the user organizations. The 'Systems Development Life cycle' is a process for the development of evidently reliable and secure IT systems and IT services. It includes activities that are carried out with the aim of ensuring that the IT systems and IT services meet the requirements by correctly providing the required functionality and nothing more. This means that the requirements are implemented correctly without creating vulnerabilities.

Cluster: Initiate	Relevant for the user organization and the IT service provider
Offering, Procurement and Contracting » OPC «	A procurement decision is based on a comprehensive comparison between the customer's own requirements and the security measures implemented by the provider. In a more complex deal or contract, this can only be put into practice with a systematic approach, because complex customer solutions are put together from various building blocks described in the service catalog. Both parties must define specific interfaces and assign roles in order to cooperate in the sense of *Joint Security Management (JSM)* also in the operational phase.
Cluster: Protect (5 areas)	Relevant for the IT service provider and also the user organization
Education, Training and Guidance » ETG «	Knowledge and skills are the prerequisite for achieving improvements and meeting new challenges. However, appropriate guidance, education, training, and the like also enable people to make appropriate use of the resources provided, to follow guidelines, rules and procedures, and to understand the consequences of deviations and violations.
Documentation Maintenance System » DMS «	The Documentation *Maintenance System* defines processes, procedures and roles for the development, modification, release, and distribution of IT service security documentation. This is a continuous task. An editorial board (team) orchestrates the maintenance of the documents, organizes the necessary quality checks and approves releases, and thus ensures that they are comprehensible, complete, consistent, and (formally) correct (C4 criteria). All documents are accessible via a central library.
Implementation, Commissioning, EOL » ICE «	Planning, communication, implementation, verification (testing), and commissioning (transition to operations) are carried out in such a way that all relevant technical and non-technical security aspects are taken into account, including hardening. Prior to commissioning, operations is prepared, including all activities for maintenance and continuous improvement. Provisions are made for secure end-of-life (EOL, decommissioning).

Security Governance and Orchestration » SGO «	Governance is achieved through a system for effective management and control that includes guidelines and methods for control (in the sense of management and auditing) as well as a corporate organization and suitable corporate processes (ISMS). The essential tasks also include the coordination of a wide range of activities and responsibilities with one another (orchestration).
Supply-Chain Management » SCM «	The IT service provider integrates components, systems, and services that it procures from suppliers. The security properties and other characteristics of these components, systems, and services, as well as the possibility of corrections and the process to achieve them, must be analyzed and contractually agreed. But even the selection of suppliers has an impact on IT security.
Cluster: Detect (3 areas)	Relevant for the IT service provider and also the user organization
Security Risks, Intelligence, Reporting » RIR «	IT security and compliance can be compromised by a variety of circumstances. Security risk management includes the identification of risks, the analysis and categorization of risks, and the definition of measures for risk treatment, which includes reducing risks to an acceptable level. Intelligence encompasses the collection, analysis, and exploitation of information to create a picture of the situation for example, on current threats and security problems or the identification of phenomena that require special attention. The term is used here in the sense of reconnaissance and investigation. Security reporting includes the provision and evaluation of various information for users and operators helping them getting a picture of the situation (security posture) and to plan corrective and improvement measures.

Assurance Verification and Certification » AVC «	Audits, reviews, and assessments lead to a higher degree of knowledge/confidence that there are no unaccepted risks and that contractual promises are being met (*assurance*). Audits that strive for completeness often lead to confirmations in the form of certificates (certification). However, there are a large number of random, usually less formalized checks such as design reviews, audits and penetration tests.
Logging, Monitoring, Automated Response » LMR «	Logging and monitoring include all activities and tools for central log management and analysis (SIM), monitoring (SEM) during operations, and automated checking of systems and components, including applications (using scanners) to detect vulnerabilities and deviations from specifications (compliance violations). Security Information Management (SIM) includes the collection, central storage, filtering, normalization, correlation, and analysis of log data. Security Event Management (SEM) includes the processing of log data and event data from multiple sources in near real time and the correlation and analysis of events. A Security Operations Center (SOC) uses all these functions (SIM+SEM=SIEM as well as the problems detected by scanners) to detect attacks on IT and initiate countermeasures. Automated Response includes functions for automated reaction to security problems, such as eliminating known problems, performing routine tasks, or providing targeted information to operating personnel.
Cluster: Correct/Readjust (4 areas)	Relevant for the IT service provider and also the user organization
Vulnerability Assessment and Mitigation Planning » VAM «	This process ensures that vulnerabilities are systematically identified and tracked, they are assessed in particular with regard to their potential impact, and mitigation measures are planned. The planning of remedial measures initiates the remediation/elimination of vulnerabilities (mitigation). Remediation/elimination is performed using other operational processes (Incident, Change, and Problem Management). The process includes CERT info services or their use, as well as the

	processing of information from the 'Detect' cluster (from logging and monitoring according to » LMR «, findings of checks according to » AVC «, and certain results from » RIR «).
Changes, Patching and Releases » CPR «	**Changes** are modifications to IT components that are mainly requested as a result of orders, inquiries, incidents or problems. Change Management is the life cycle process from request and analysis to implementation and final review. Changes also include 'patching'. **Releases** comprise all systems and components that are or were implemented as a result of various, combined changes. Releases are often associated with a version designation.
Incidents, Problems and Investigations » IPI «	**Incident Management** includes all procedures and means used to address and respond to security-related circumstances that have or may have a significant impact and require timely resolution through the implementation of temporary solutions (work-around) or the elimination of the root cause. The search for the 'root cause' branches out into the Problem Management. **Problems** are the cause of failures or incidents in the provision of IT services. **Problem management** is the life cycle process from occurrence, notification, analysis and identification of the cause to the planning of remedial measures and changes. In most cases, failures or incidents are first handled provisionally (work around), so that only the elimination of the actual problem leads to an improvement. However, customer requests etc. can also be the reason for improvements. Investigations are examinations or inquiries. This also includes forensics which reconstructs past (security-relevant) events with the aim of finding the originators (accountability) or causes.
IT Service Continuity Management » ISC «	IT Service Continuity Management (ITSCM) takes precautions to minimize the impact of possible interruptions in the provision of IT services or data loss, which includes timely and complete recovery of services and data.

Cluster: Advance (2 areas)	Relevant for the IT service provider and the user organization
Review and Initiation of Modernization » RIM «	There are very many and very different reasons why renewed agreement between the user organization and the IT service provider is also necessary in the operational phase. Both parties continuously compare what has been achieved with current expectations (review) and develop proposals for improvements. Often, however, technical progress or changes in the business environment are also the reason for initiating improvements. In the broadest sense, this is about relationship and contract management as a component of the business that must be prepared for and master such situations.
Modernization and Innovation Projects » MIP «	One of the most important goals in improving IT services or their security is to increase effectiveness and efficiency. It is often the case that the corresponding development and realization projects go beyond the existing contract and are carried out additionally or lead to changes in the existing contract. While improvements in the direction of efficiency are usually initiated by the IT service provider in order to remain competitive, projects to increase effectiveness are often also initiated by the user organization. This topic area is about the implementation of the projects initiated according to » RIM «.

NOTE on the topic area 'Secured by Definition and Assurance Management (SDA)': The principle of 'Secured by Definition' [5] is described in detail in Chapter 6. The *Joint Security Management (JSM)* [6] is defined and briefly discussed at the beginning of this section. Explanations on 'Assurance Management' [7] can be found in Chapter 3.

4.5.2 Inventory Management

The four areas on the topic of collecting and managing inventory data ('inventory management' cluster) in the middle of the Taxonomy form the basis for many of the practices in the upper half of the Taxonomy. However, they are also closely related to technologies in the lower half of the Taxonomy. The four topic areas are outlined in Tab. 4.2.

Tab. 4.2 : Brief profiles of the ‘Inventory management’ topics

Cluster: Inventory management (4 areas)	Relevant for the IT service provider and also the user organization
Ownership and Device Attestation » ODA «	Especially in the environment of Internet of Things (IoT) and operational technology (OT) but also in data center-centric IT (enterprise IT or office IT), many, often different devices, but also systems, components, etc. are used as end-points outside the data center. They receive connections and access to other systems and components. It must therefore be ensured that they are only used after an initial check of certain parameters (device attestation), which is usually repeated on a regular basis. This presupposes that ownership is clarified.
Asset and Configuration Management » ACM «	Asset Management is the process responsible for tracking and reporting on the value and ownership of IT systems and components throughout their life cycle. Configuration Management is the process responsible for maintaining information about all components required to provide an IT service, including their relationships.
User Identity Management » UIM «	This includes all procedures and regulations, systems and services used for the creation and management of digital identities including rights (entitlements) and other attributes for users. A person's digital identities are described as ‘personalized identity objects’ associated with other identity objects such as location, organization, legal entity, and so on. These identities are managed throughout their life cycle. The digital identities and their management are the basis for ‘access management’ (granting of rights in operations).

Privileged Identity Management » PIM «	This includes all procedures and regulations, IT systems and services used for the creation and management of digital identities including rights (entitlements) and other attributes for operational personnel (administrators; privileged users)) and automated processes. Digital identities are described as 'personalized identity objects' associated with other identity objects such as location, organization, legal entity, etc. These identities are managed throughout their life cycle. The digital identities and their management are the basis for 'access management' (granting of rights in operations).

4.5.3 Technologies

The arrangement of the technology areas (lower half of the Taxonomy, see Fig. 4.3) is based on a simple technical IT architecture with the 'clients' on the left, the 'servers' on the right and the connecting 'networks' in the middle. Added to this are 'Security Services' (center above Network Services) as a fourth cluster. - There are 19 topic areas of technologies, which are outlined in Tab. 4.3.

Note that the clusters are mainly used to support orientation. The networks in the data center are considered part of the IT stack. However, the external network interface of the data center is described in the 'Network services' cluster. The definition and arrangement of the areas is intended to allow as many concrete installations as possible to be covered.

Tab. 4.3 : Brief profiles of the 'Technologies' topics

Cluster: Endpoint Services (3 areas)	Relevant for the IT service provider and/or the user organization
Mobile Workplaces » MWP «	Computer equipment and associated software with a control unit for one person, which is designed for mobile use and enables connection mostly also to public wireless networks. This includes notebooks, tablet computers and various types of smartphones. The workplace software can also be provided virtualized and hosted as an 'application' in the data center. The focus is on protecting the data stored and processed on the device.

Office Workplaces » OWP «	Computer equipment and associated software with a control unit for one person, which is designed for stationary use and usually uses a connection to a local fixed or wireless network. This includes desktop computers in various designs. Workstation software can also be provided virtualized and hosted as an 'application' in the data center. The focus is on protecting the data stored and processed on the device.
LAN and Campus Networks » LCN «	All devices between users' computing devices (see » OWP « and » MWP « used on the premises) and a wide area network (» WAN «), i.e., in the users' central communications periphery. This includes the components of local area networks as well as site-to-site gateways, firewalls, intrusion detection/prevention solutions (IDS/IPS), domain services, etc.
Cluster: Network Services (4 areas)	Relevant for the IT service provider and/or the user organization
Wide Area Network (underlay) » WAN «	Physical-logical network that overcomes geographically larger distances with all components for the transmission of data between users and between users and IT systems in data centers. Wide-area networks include the Internet, but also leased lines and other transport networks such as MPLS and mobile communications.
Wide Area Network (overlay) » SDW «	This includes all components of an additional control layer (overlay: control layer, data plane), which is located above a system of physical-logical wide-area networks (see » WAN «) or wide-area network services based on them (underlay: data layer, data plane) and which are used to provide combined wide-area services. This network architecture (SD-WAN) implements network virtualization for wide-area services on a large scale.

Data Center Connectivity » DCC «	This technology complex forms the outer logical network interface of the data center for users and contains components that connect the internal networks (» DCN «) in the data center with wide area networks (» WAN «). The area plays an important role in connecting users with the IT systems in the data center and thus with their applications. For example, the area includes VPN gateways, MPLS gateways, load balancers, routers, IDS/IPS solutions and DDoS protection.
DMZ and Central Services » DCS «	This technology area contains components that are centrally provisioned to support or enable user communications over the data center external logical network interface (» DCC «). Included components comprise directory services such as LDAP, Active Directory, other authentication servers, web SSO and identity federation services, application-level gateways including proxies and reverse proxies, and web application firewalls (WAF).
Cluster: Compute Services (8 areas)	Relevant for the IT service provider and/or the user organization
Data Center Housing » DCH «	The building of the data center including the land, insofar as facilities located thereon such as fences, surveillance systems, etc. serve to secure the data center. The area includes all physical and environmental security aspects of the data center and its facility. It does not include network and computing technology (IT) with the exception of facilities for access control and monitoring, i.e., those serving physical protection.
Data Center Networks » DCN «	All networks and network equipment within the data center that transport user data and connect computer systems to each other, to the external logical network interface of the data center (» DCC «) and central storage. The entire network and network equipment is located 'inside the firewall'. Connectivity between data centers is also included, insofar as they are dedicated networks used for this purpose. Does not include facilities for connecting operational personnel (administrators; privileged users) to computer systems, storage, and systems supporting the operation and

	maintenance of networks, computer systems, and storage (storage). For this, see *Infrastructure for Privileged Users (IPU)*.
Computer Systems (Server) » CSS «	This technology area includes all parts of the IT stack with the exception of applications (software for business process automation, for example), central storage and middleware (runtime environments and database management systems). The domain thus includes the physical computers, operating systems, system virtualization software such as hypervisors for cloud computing, and local software for hardware abstraction and networking for distributed container solutions. The domain essentially corresponds to a 'host system' on which 'guest machines', 'virtual machines', 'workloads' or 'containers' (see » APP «) are executed.
Apps and Middleware » APP «	This technology complex contains all the software that provides the primary IT services for users (application layer). The complex essentially corresponds to a 'guest machine', a 'virtual machine', a 'workload' or a 'container', but does not contain an operating system, since this is provided centrally as an image except in certain dedicated systems. The complex does not include platforms and infrastructure services. For this, see *Computer Systems (Server) (CSS)*. Middleware such as runtime environments (for example, .NET) is also included. Exceptions are those for containers (see » CSS «) and database management systems (see » DSS «).
Platform Mgmt. Systems » PMS «	This includes all central components such as management software, databases, archives, toolsets, and utilities to provision, start, stop, move, and otherwise manage 'guest machines', 'virtual machines', 'workloads' or 'containers' (see » APP «). These central components are used by operations personnel (administrators; privileged users) who manage the overall IT infrastructure. Access can also be provided, for example in the form of self-service portals, in whole or in part to less privileged user groups at the user's premises. Also included in this area are all procedures, toolsets, utilities, and background systems used for the creation and configuration (engineering) as well as the inventory and archiving of required software components.

Database and Storage Systems » DSS «	All central storage systems (storage) and related software accessed by computer systems (» CSS «) via data center networks (» DCN «). The scope also includes database management systems (DBMS), even if they run on the computer systems. Database management systems (DBMS) have been excluded from the *Apps and Middleware (APP)* domain. The scope also includes all resources for backup and disaster recovery.
Operations Support Systems » OSS «	This includes all central components such as management software, databases, archives, toolsets, and utilities that are used by the operating personnel (administrators; privileged users) for the basic operation of the data center and the management and maintenance of the IT infrastructure. This includes the technology (hardware, software) for IT Service Management (ITSM, for example, ticketing systems) including Asset and Configuration Management (the CMDB), Release and Deployment Management (for example, software repositories), log management, service availability and performance management, and for ordering and project management. The processes and use of the systems are not included.
Infrastructure for Privileged Users » IPU «	This technical infrastructure includes all networks and network equipment as well as other devices and facilities that enable operating personnel (administrators; privileged users) to remotely access the data center and its components to perform management and maintenance tasks. This includes facilities such as jump servers and centrally provided services for authentication and authorization, for example. It does not include the administrators' workstations (see » MWP «, » OWP «) and workplace extensions used for secure communication over a WAN and to gain access to networks in the data center.

Cluster: Security Services (4 areas)	Relevant for the IT service provider and/or the user organization
Data Security and Privacy Services » DSP «	This technology complex comprises security services that are put in front of third-party IT services and supplement the security services that these IT services (mostly cloud computing services at the application level, see » APP «) do not have themselves. Security services include data encryption, various forms of data masking as well as authentication and authorization services including single sign-on and the like. The solutions summarized here work as proxies and are often referred to as cloud security gateways.
Forward Security (as a Service) » FWS «	Combination solutions provided centrally as an IT service and not on the endpoint that protect users against threats from the network and applications available there. The components include content filters and anti-malware (e.g., in the form of Secure Web Gateways, SWG), proxy services, and firewall-as-a-service (FWaaS) or cloud firewalls, in which all data traffic is redirected to a cloud service of the provider and checked and controlled there.
Apps Security (as a Service) » APS «	Combination solutions provided centrally as an IT service that protect applications (see » APP «) in reverse proxy mode against threats from the network and provide security services for these applications (see » APP «), also referred to as cloud app security. They include, for example, services for log management, traffic analysis (cloud discovery), API protection, or discovery solutions for finding unauthorized applications (shadow IT).
Zero Trust Access Components » ZTA «	Solutions that act as sole intermediaries to control access to specific IT services (usually applications, see » APP «) by authenticating users and, where applicable, the devices they use each time they access them, as well as checking context and other rules. The architecture and components used differ depending on whether the Zero Trust principle is initiated by the endpoint or the IT service.

Many components and solutions, including IT security, were not mentioned in the brief descriptions. But all components and solutions should be able to be assigned to the topic areas in the Taxonomy. Here are two examples of IT security solutions and their assignment:

CASB (Cloud Access Security Broker) combines components of *Forward Security (as a Service) (FWS)* and *Apps Security (as a Service) (APS)*.

SASE (Secure Access Service Edge) is an architecture. It comprises various components and solutions that lie logically between the cloud services (which can be accessed via the Internet; Internet edge) and the user (who wants to use such a cloud service or application; service edge). These components and solutions include network services and security services (see Fig. 4.3). Network services include components from the *Wide Area Network (underlay) (WAN)* and *Wide Area Network (overlay) (SDW)* topic areas, as well as from access points such as » LCN «, » DCN « and » DCS «). Security Services include security services of the form *Forward Security (as a Service) (FWS)* and *Apps Security (as a Service) (APS)* as well as access control with *Zero Trust Access Components (ZTA)*.

4.6 Summary and Outlook

Threat actors do not tamper with our most protected areas, but look for our weakest points. Therefore, a comprehensive picture is needed to create and maintain a secure integrated whole. The chain is as strong as its weakest link. This means that any activity along the in-house (self-controlled) and external supply chain (with suppliers and customers) can be a source of errors (vulnerabilities) that can lead to IT security risks. To prevent this, not only are security standards required, but suitable tools are needed to gain and maintain an overview. These must be kept simple, so graphical representations such as the *Taxonomy* presented in this chapter are suitable. It must be remembered that the value chain or supply chain is not rigid: Rather, it almost always depends on the IT service in question and often also on the contractually fixed division of labor (*Service Model* [8]) between the IT service provider and the user organization. Thus, the Taxonomy also becomes a tool that helps to organize the cooperation between IT service provider and user organization (*Joint Security Management, JSM*) and allows the security standards associated with an IT service to be identified and applied.

For operational use, the *Taxonomy* should be part of a broader architecture. In particular, it should be assigned to a *Documentation Hierarchy*. Furthermore, the modular and hierarchical way of describing should be continued in the individual documents/standards [2]. This not only makes information easier to find, but also allows it to be updated flexibly and with less effort. An appropriate system of identifiers (codes, IDs) facilitates referencing. This will be discussed in Chapter 5 in more detail.

Complexity is the adversary of good IT security or cybersecurity. With the help of a Taxonomy, it can be reduced and made manageable. An overview is gained and communication and understanding are supported. Tasks can be identified more easily, gaps recognized and responsibilities assigned. This makes it an essential element of the ESARIS security architecture and an important management tool in practice.

Bibliography

The first list below contains the literature referred to in this chapter. Some of the sources are only available in German. A second list of recommended reading has been added, containing only English references.

References (Sources)

[1] Klaus Hünecke: Die Technik des modernen Verkehrsflugzeuges, Motorbuch Verlag, 2017, ISBN 978-3-613-03893-6.

[2] Eberhard von Faber and Wolfgang Behnsen: Secure ICT Service Provisioning for Cloud, Mobile and Beyond (ESARIS: The Answer to the Demands of Industrialized IT Production Balancing Between Buyers and Providers); Springer Vieweg, Wiesbaden 2017, 2nd updated and extended edition, 382 pages, 159 figures, ISBN 978-3-658-16481-2, https://doi.org/10.1007/978-3-658-16482-9

[3] Eberhard von Faber: Taxonomy for Systematic IT Service Security Along the Entire Supply Chain; November 2022, 25 pages, https://zero-outage.com/news/taxonomy-for-systematic-it-service-security-along-the-entire-supply chain/, accessed December 13, 2023

[4] ISO/IEC 20000 – Information technology – Service management – Part 1: Service management system requirements, Part 2: Guidance on the application of service management systems

[5] Eberhard von Faber: Methods: "Secured by definition" and the utilization of quality management principles, Seamless IT security through integration within IT-production processes; translation of article (https://doi.org/10.1007/s11623-019-1136-0) originally published in: Datenschutz und Datensicherheit - DuD, 43(7), July 2019, Springer Fachmedien, Wiesbaden 2019, ISSN 1614-0702, pages 410-417, https://zero-outage.com/opinion/methods-secured-by-definition-and-the-utilization-of-quality-management-principles/, accessed December 13, 2023

[6] Eberhard von Faber and Wolfgang Behnsen: Joint Security Management: organisationsübergreifend handeln (Mehr Sicherheit im Zeitalter von Cloud computing, IT-Dienstleistungen und industrialisierter IT-Produktion);

Springer Vieweg, Wiesbaden 2018, 246 pages, 60 figures, ISBN 978-3-658-20833-2, https://doi.org/10.1007/978-3-658-20834-9

[7] Eberhard von Faber: On the future of IT security management in the face of changes in technology and service delivery; translation of the article (https://doi.org/10.1007/s11623-021-1516-0) published in: Datenschutz und Datensicherheit - DuD, 45(10), October 2021; https://zero-outage.com/opinion/on-the-future-of-it-security-management-in-the-face-of-changes-in-technology-and-service-delivery/, accessed December 13, 2023

[8] Eberhard von Faber: Concept for improving cloud security standards, Consideration of the very diverse Service and Deployment Models with only two requirements; translation of the article (https://doi.org/10.1007/s11623-022-1559-x) published in: Datenschutz und Datensicherheit - DuD, 46, January 2022, https://zero-outage.com/opinion/concept-for-improving-cloud-security-standards/, accessed December 13, 2023

Further Literature (Recommendations)

A Taxonomy was presented and published for the first here:

[9] Eberhard von Faber and Wolfgang Behnsen: A Systematic Holistic Approach for Providers to Deliver Secure ICT Services; in: ISSE 2012 Securing Electronic Business Processes, Highlights of the Information Security Solutions Europe, ISSE 2012, Springer Vieweg, Wiesbaden, 2012, pages 80-88, ISBN 978-3-658-00332-6, https://doi.org/10.1007/978-3-658-00333-3_9

Details about using (an early version of) the Taxonomy and elaborating related standards can be found in Chapter 12 of:

[10] Eberhard von Faber and Wolfgang Behnsen: Secure ICT Service Provisioning for Cloud, Mobile and Beyond (ESARIS: The Answer to the Demands of Industrialized IT Production Balancing Between Buyers and Providers); Springer Vieweg, Wiesbaden 2017, 2nd updated and extended edition, 382 pages, 159 figures, ISBN 978-3-658-16481-2, https://doi.org/10.1007/978-3-658-16482-9

ELECTRONIC SUPPLEMENTARY MATERIAL
The figures are available as a PowerPoint file.
Contact the author by email or via LinkedIn.

5 Document and Library Structure

Major projects must be approached systematically. The organization needs its own plan. External plans must at least be declared as the organizations' own, but in most cases, they must be adapted to the organizations' own needs. In large projects, vast amounts of documents are created: Requirements definitions, schedules, project plans, functional specifications, architectural designs, detailed designs, special construction drawings, parts lists, production plans, work plans, and so on and so forth. Fig. 5.1 traces the development of the world's largest passenger aircraft, the Airbus A380. In many phases, many people have performed and documented a wide variety of activities on many subjects. It is no different in IT and IT security. Documentation is the basis for producing uniform and consistent results of high quality. Documentation helps with the review and improvement of designs. Documentation is the basis for the communication between teams and larger organizations and the conclusion agreements. But what should all these documents look like and how should they be organized and managed? How are all these documents distributed and shared? Who shall produce them and who serves for approval and publication? This chapter outlines elements of a document management or *Maintenance System* for IT service security management developed as part of the ESARIS security architecture.

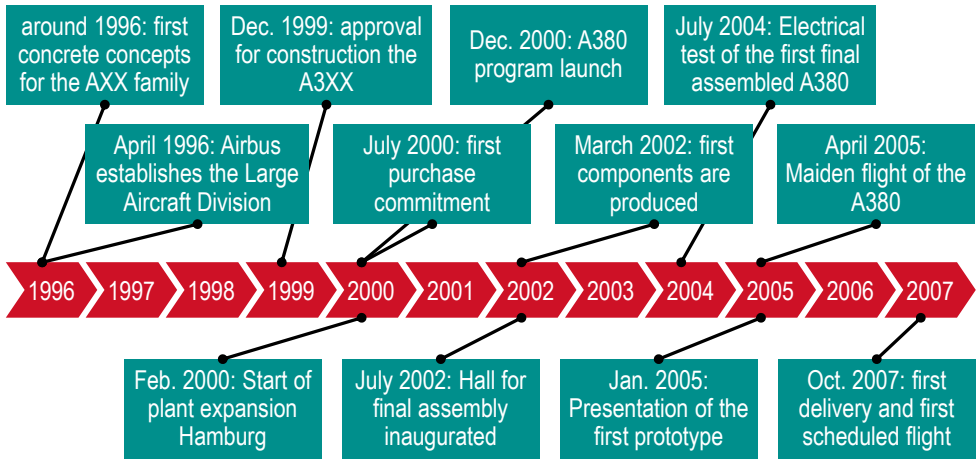


Fig. 5.1: Design, development, and construction of the world's largest commercial aircraft (A380) (Source of data: [1])

© The Author(s), under exclusive license to Springer Nature Switzerland AG 2024
E. von Faber, *Managing IT Service Security*, https://doi.org/10.1007/978-3-031-55533-6_5

5.1 Goals and Document-Related Solutions

Larger organizations must have autonomy, be independent, and document the basis and results of their work. Reproducibility is otherwise not possible. This also applies to continuous improvement. For this reason, organizations define plans and specifications in the form of their own documents (standards). The term 'corporate standards' has already been discussed in Section 2.3.1 (from page 33). The following, second definition focuses more strongly on the need to develop and use such proprietary (organization-specific) standards for IT service security:

Corporate Standards (necessity)

> Documents (standards for IT service security) that define procedures and measures to be applied or implemented on a mandatory or rule-based basis. They are needed to be able to produce uniform and consistent results of high quality.
>
> Even if third-party material is used, the company's own standards have a clear and higher degree of binding nature and obligation within the organization and make it possible to improve and expand them independently and continuously in accordance with the organization's requirements, or to leave them unchanged.
>
> Own standards are the basis and document the results of the organization's work and development. They are therefore indispensable for maintaining and improving competitiveness as well as achieving the organization's goals and sustainable success.

Basically, the above list is self-evident. However, they underline the importance of the documents (standards for IT service security), which some organizations acting in short terms and not strategically should remember.

But not all documents are the same, and the mere existence of documents says nothing. But how to create 'good' documents and a library of many documents that significantly support the organization in being successful? A concept is needed for the creation, management, and use, i.e., a document management system.

Note: This document management or *Maintenance System* of the ESARIS security architecture is one of the topics areas in the *Taxonomy* for IT service security. This topic area is part of the 'practices' in the cluster 'protect' called *Documentation Maintenance System (DMS)*. Refer to Fig. 4.3 on page 69 and Tab. 4.1 starting on page 73.

Before creating a system for managing documents or starting to produce documents, one should consider what one actually wants to achieve. Fig. 5.2 (left) shows six goals or expectations of the users, where two goals are related to each other and therefore stand closer together.

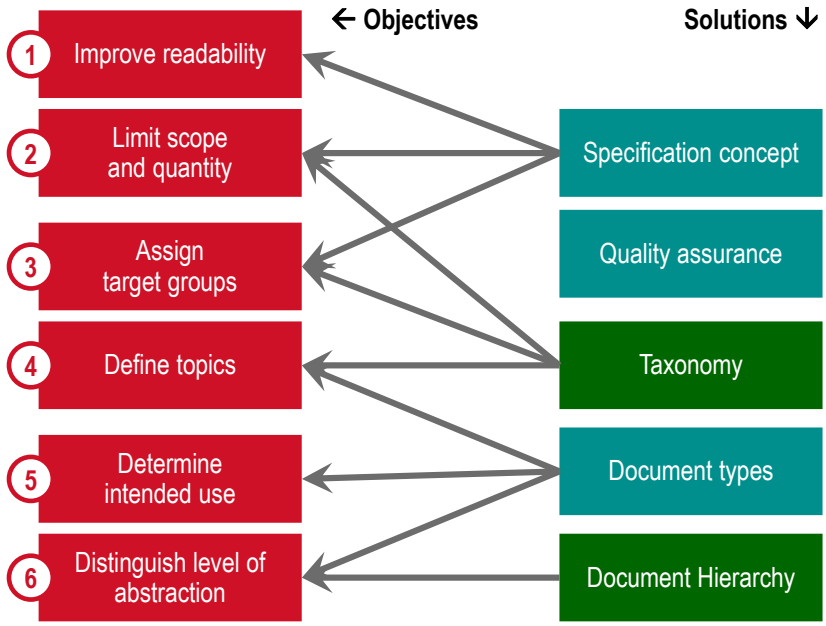


Fig. 5.2: Goals and solutions for document management

What counts in novels and stories is originality, surprise, and difference. This applies to the overall structure as well as to the mode of expression. If, on the other hand, you want to orient and inform yourself, familiar, recurring patterns, and structures help. This is achieved through a concept that contains guidelines and provides support for authors:

Specification concept

> The specification concept offers authors of *corporate standards* assistance regarding the structure of documents (standards for IT service security) and the presentation of content, and ensures that documents for similar purposes and target groups are structured and written in a similar way and fit correctly into the library structure (*Documentation Hierarchy* and *Taxonomy*). This improves the transfer of information, facilitates the assimilation and processing of what is learned, and thus increases the chance that the standards will have their intended effect.

The 'specification concept' also provides templates (for office programs and web pages) to be used in order to comply with the guidelines for a uniform corporate presentation (corporate design). Such guidelines determine how the logo and which font, font size, etc. should be used. However, the guideline or specification concept also shows how the content is best structured and communicated.

One simple and very effective measure in the *specification concept* is to specify the structure for certain documents. Fig. 5.3 shows an example of the important standards in the→ *Orchestration Layer* which is introduced and explained below.

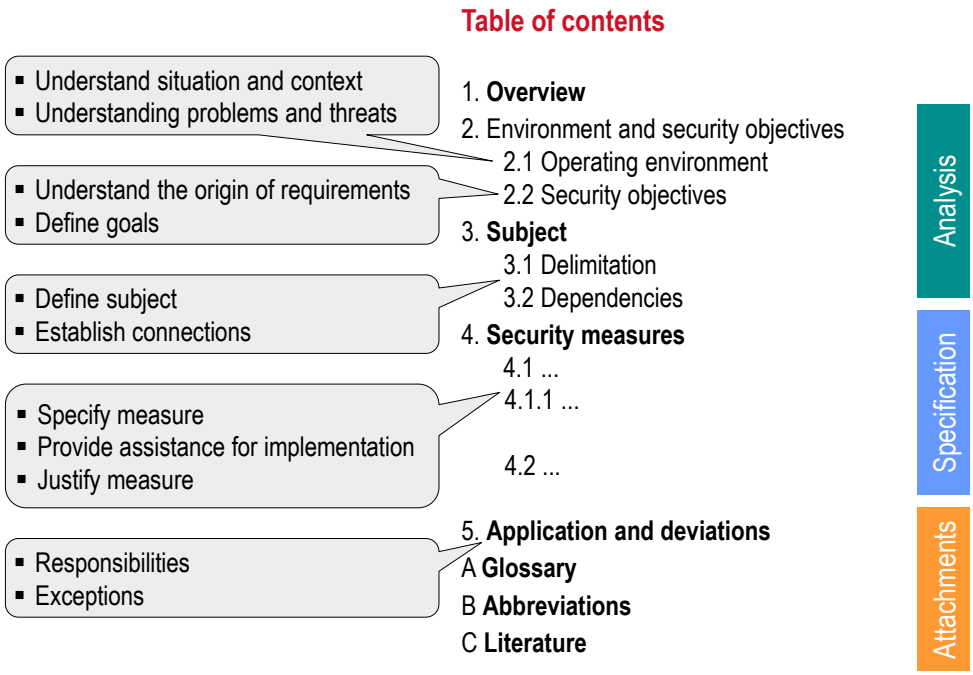


Fig. 5.3: Typical structure of a standard (level/layer 4, source: [2])

Users very often want to know the source of the *security measures* they are supposed to implement and enforce. Those who define the security measures should also be accountable for them and derive them in a comprehensible way. Often, the analysis of the deployment or operating environment is omitted unfortunately. The threats to IT security that are relevant to them are not properly understood, which is also inherited by the measures because no security objectives are defined.

Standards for IT service security (mainly on level/layer 4) should therefore always contain three parts, if possible:

- an introduction (topic, target group, purpose, etc.),
- the *analysis part*,
- the *specification part*.

See Fig. 5.3.

Analysis part (of standards)

The analysis section first describes the IT and its operating environment. For process-oriented standards, tasks and scenarios are described. This narrows down the topic and shows the scope of the standard.

In both cases, this is followed by a (qualitative) analysis of the threats or a problem analysis, i.e., a description of possible negative effects in the event that no (counter)measures are taken. In addition to the classic IT security threats, problems such as non-compliance with laws, regulations, customer requirements, etc. should also be considered. If important problem areas are not identified, the definition of the necessary (counter)measures may be incomplete.

From the problem analysis, security objectives are derived. This step is important to steer the presentation in a constructive direction and to prepare the subsequent specification of (counter)measures. The achievement of security objectives is verifiable and more suitable as a basis for the *specification part (of standards)*.

This part of a standard can be relatively short. It is important that the analysis is done so that users can also see why which security measures are required. Users also see what is to be achieved (positively), which increases their motivation and helps improving the quality of their involvement.

The analysis part is followed by the specification part (see Fig. 5.3).

Specification part (of standards)

The specification part contains the measures to be implemented for IT service security. Security measures are precautions taken to reduce risks. Security measure is synonymous with security control. Security measures can be administrative, organizational, process-related, technical, or legal in nature.

Checking and monitoring whether other security measures, for example technical security measures, have been implemented and are effective should also be defined as a security measure. Only then will a complete catalog of security measures be created.

The term security measure is not precisely defined in terms of the level of abstraction or detail. Security measures can be very comprehensive or very close to implementation.

At level (layer) 4 (→ *Orchestration Layer*) of the hierarchy (*Documentation Hierarchy)* the specification should follow fixed rules so that all descriptions are written in the same way and are referenceable. At Level 4, a distinction should also be made between measures that must always be implemented and enforced and those for which this only applies under certain conditions, for example to meet

specific national or industry-specific requirements. There may also be measures that are only implemented at the customer's request. This must be identified accordingly, for example with the identifiers ‘standard’, ‘option’ and ‘add-on’.

It is recommended to write the specification part in the form of statements (facts) rather than requirements. With the help of **security requirements**, properties of security measures are described so that flexibility in the selection and design of security measures is maintained, while ‘security measures’ give direct instructions on what and how something should be implemented and enforced.[14]

Nevertheless, the specification at level (layer) 4 in form of statements (facts) shall be product-independent and leave enough room and flexibility for maintenance, technical progress, and improvements provided that the security objectives are still met.

It is very important to understand that documents, as well as other media such as films, should not provide more information than is relevant to the target audience and necessary for the topic. See Fig. 5.2 on page 91. Such considerations should lead to the definition and differentiation of classes or types of documents. If each document is assigned to such a ‘document type’ (Fig. 5.2), users can find the documents that are important and relevant to them more easily.

Document type

Documents differ in terms of their character (concept, work instruction, etc.) or purpose (type of use). Each ‘document type’ encodes a character or a purpose. The number of different ‘document types’ should not be too high.

The document type can be coded with two letters, for example. It is also possible to additionally encode data such as the target group, the media type, and the confidentiality level. It is important that the letter combination remains short and easy to understand.

The document type becomes part of the→ *Document ID* with which the documents are labeled.

Each document should go into depth on a topic and have a certain level of abstraction, which is also related to the purpose and the target group audience. This brings us to the library structure which will be described in the next section.

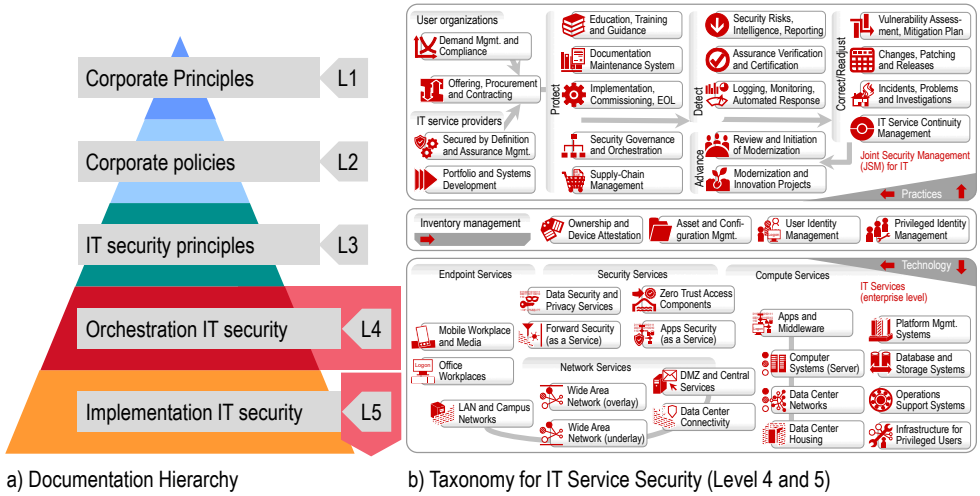
---

[14] However, the term ‘security requirement’ is also used in the sense of technical specifications that precisely describe the manner of implementation (realization).

5.2 Goals and Library-Related Solutions

In order to achieve the results shown in Fig. 5.2 (page 91), we need two further principles of organization and structuring: Already in Section 2.3.1 (from page 33), we explained how the library of standards for IT service security is structured using the *Document Hierarchy* and the *Taxonomy*. The description of the *Taxonomy* was given a whole main Chapter 4 (from page 65). As proposed in the last Section 5.1 these two principles should also be encoded in the *Document ID* because of their fundamental importance for the management of IT service security.

Fig. 5.4 shows an overview of the library structure. The documents are arranged hierarchically with increasing levels of detail downwards. At Levels 4 and 5, the documents are arranged thematically using the *Taxonomy*.



a) Documentation Hierarchy b) Taxonomy for IT Service Security (Level 4 and 5)

Fig. 5.4: Documentation Hierarchy and Taxonomy

The following is a brief description of the two ordering principles in which the achievement of the goals set out in Fig. 5.2 (page 91) is given special attention.

Hierarchy and Taxonomy (necessity)

The documents (standards for IT service security) are arranged hierarchically. This means that general organizational guidelines on security topics are broken down to IT service security and specified in more detail for this topic. And the guidelines and more general standards for IT service security are in turn refined down to detailed, technical instructions.

The hierarchy of the documents also reflects an organizational hierarchy in the IT organization, leading from control and management (upper Level 3) to

execution and implementation (lower Level 5). Decisively on Level 4 (*Orchestration Layer*) is the active overall design of IT service security and the tuning and adjusting of measures to each other. The levels thus also support target group orientation.

The target group orientation is also supported by the *Taxonomy* used on Levels 4 and 5, which divides the field of IT service security into various topics.

Hierarchy and *Taxonomy* are also visually comprehensible and descriptive instruments. In this way, the abstract construct of 'IT service security' is broken down into comprehensible units, with each unit being presented in individual documents in a way that is specific to the purpose and target group. This also significantly reduces the amount of information provided, which helps to improve acceptance and implementation.

Of course, the hierarchy can also have three or four levels, for example. What is important is that there is a middle level, which we call the *Orchestration Layer* in the hierarchy. In the hierarchy shown in Fig. 5.4, it is located at level 4 and has several special functions.

Orchestration Layer

Level in the hierarchy of documents with a dual function. ON THE ONE HAND, the documents (standards for IT service security) at this level of detail or abstraction are used to inform the user organizations (customers) about the many measures for IT service security, to advise them, possibly to conduct negotiations about them, and finally to agree them contractually.

The *security measures* in this layer are therefore specified implementation-independently in the broader sense (no products and versions), so that the IT service provider has a certain amount of freedom to implement the agreed IT security. This flexibility benefits both sides. But it is also necessary in order to be able to successfully implement and maintain IT security in a very dynamic market and changing technological environment.

ON THE OTHER HAND, the documents (standards for IT service security) assigned to the Orchestration Layer are used as specifications and blueprints for the implementation of IT security by the IT service provider. It is important that the level of detail or abstraction is still high enough to ensure that the amount of information is manageable, that an overview of all security measures is possible and that it is feasible to check completeness and interaction. The Orchestration Layer therefore marks the level at which creative, comprehensive, and active security management is still possible. Each deeper and therefore more detailed level serves the implementation (correct realization) of the specifications in the Orchestration Layer.

> In order to best support the interaction with the user organizations on the one hand and the active management of IT service security by the IT service provider on the other, the Orchestration Layer itself is once again hierarchical and modular: The *Taxonomy* divides it into, for example, 41 individual topic areas, each of which is detailed in a document in the form of an average of 10-20 individual *security measures*.

The structure of the documents was described in Section 5.1.

But what good is a library that contains documents for every topic, every target group, and every purpose, but in which it is difficult or impossible to find what is needed? If the search takes too long, people give up. If it seems difficult to find what they are looking for, they do not even consult the library.

In most cases, the solution is an electronic search. The Internet shows the way. But even electronic searches are only useful and efficient if terms are standardized and understood in the same way. (This book contributes to this and provides valuable material.) However, equal understanding and use cannot necessarily be assumed. Terms are ambiguous, and people are often not particularly disciplined in learning technical terms and consistently using them correctly. In a larger organization, this generally cannot be assumed. Nevertheless, all documents in the electronic library should be labeled with tags so that searching for them leads to the correct documents.

Another very powerful solution is the construction of *Document IDs*, in which the hierarchy level, the topic area in the Taxonomy and other properties of the document are encoded.

Document ID

> Document IDs are tags for documents and consist of unique combinations of letters, numbers, and special characters. Document IDs are FIRSTLY used to uniquely identify a document and easily reference it regardless of the title, which may change. In this respect, they are similar to an ISBN number (International Standard Book Number). References to documents are thus very easy and unambiguous in written communication (e.g., via email) and even when speaking.
>
> Document IDs SECONDLY encode the *document type* (character and/or purpose) as well as the subject (according to the *Taxonomy*) and the position in the *Document Hierarchy* or in the library structure.
>
> The documents are labeled with their respective document ID, which is easily recognizable from the outside. In this way, it is easy to quickly identify the type of document.

The *Document ID* is part of the file name (if it is a file) and appears on all pages of the document or prominently, for example, at the beginning and end for videos or web pages.

After a bit of getting used to it, people know which documents belong to their own work and task area, how to find them and how to communicate with others about them.

Fig. 5.5 shows an example of a *Document ID*.

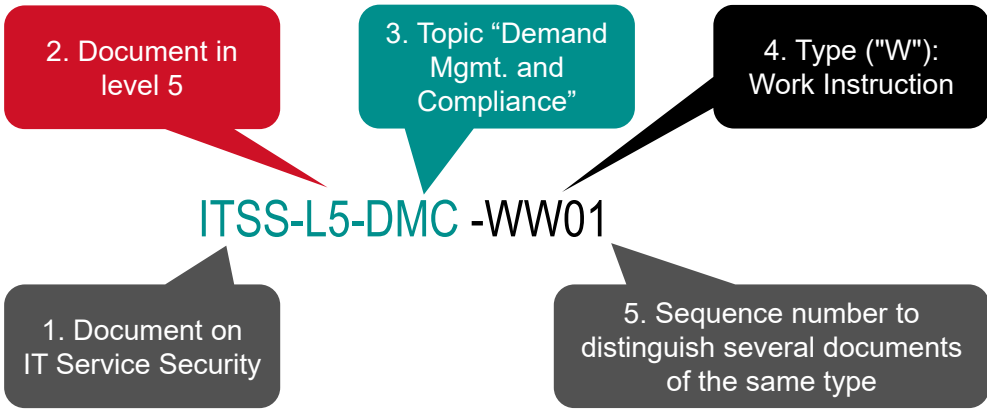


Fig. 5.5: Example of a Document ID with explanation

These few letters alone provide a lot of useful information that allows the document to be classified and located. The file name could then be, for example:

ITSS-L5-DMC-WW01 - Security Requirements Business Applications.pdf

If files are sorted alphabetically in directories on servers or in search result lists, documents of the same type appear next to or below each other, so that cross-references can also be easily identified.

In addition, all documents should be systematically labeled with tags (terms). It is recommended to create a collection of basic terms (thesaurus) with most of them explained in a glossary. The terms contained there should be used with priority. If the thesaurus is standardized, the same terms will be used and it will be easier to find documents with similar references. However, other terms can be used in addition, and the thesaurus can also be supplemented at any time.

5.3 More Suggestions

To ensure that the solutions proposed above are really used and implemented, help is needed for the authors of the documents as well as quality assurance. Both can be taken over by an *editorial board*.

Editorial board (team)

The editorial board is a small, continuously working team (not a project or a committee that meets when required) that oversees the creation and updating of documents (of various media) until they are published within the organization. It supports authors who produce content and approvers who review and approve documents and content, but does not itself determine what exactly the organization makes the standard for IT service security. It primarily ensures consistency, quality, and timeliness of standards for IT service security. The quality criteria of the editorial board include comprehensibility, completeness, consistency, and correctness of form (called C4 criteria).

It is important to understand that, on the one hand, the editorial board (team) is supposed to influence the elaboration of documents, but on the other hand, it is not determining the security specification. The editorial board of a newspaper or magazine usually also accepts the contributions of journalists. At best, it puts them into the version suitable for publication or provides support in this process.

The editorial board (team) for IT service security works with a network of IT service security experts. For this purpose, it is useful or even necessary that the editors have generalist knowledge of IT, IT services and IT security. Editors should be able to deal with terminology. The editorial board (team) is an essential part of the → *Maintenance System* which is briefly described already in Section 2.3.1.

Other ideas that support document management activities and library use follow:

Change Type (Documents)

To facilitate the planning and implementation of changes to a document (standard for IT service security), the scope, significance or severity, and impact are estimated and measured as a 'change type' on a scale with, for example, three levels. Depending on the value of the 'change type', quality assurance, checks and approvals are designed differently in terms of scope and depth. Editorial changes require less effort than small and large changes. Major changes may require follow-up activities such as a project that prepares and supports the implementation of the new specifications in the organization.

Bibliography (documents)

A bibliography is a library index that lists all available documents (possibly of different media) with all metadata as required and useful for citations and for finding the documents. Metadata is data that characterizes and describes the document.

Library History (Documents)

A version history is kept for and, where appropriate, in each document, describing not only the version number and the date of the change, but also a description of the changes made to the document itself. The Library History makes this information from all documents available in one place, for example, in the form of another document or in a data base. The Library History provides information about all changes (in the area of IT service security) and should make it possible to filter them by topic and time period. Authors and users can use it to get an overview of changes that affect their area of responsibility or interest.

The explanations should be understood as suggestions. Full implementation may not be necessary. In any case, organizations should adapt the suggestions to their own circumstances and implement them accordingly. Since justifications have been given in each case and the purpose of a method is evident, organizations may also be encouraged to develop their own and better methods.

At the end of this chapter two tables are given to support the elaboration of the standards for IT service security on Level 4 (*Orchestration Layer*). Tab. 5.1 contains a template (example) for the core specification of each standard on Level 4. Such a profile is the starting point for the security specification and becomes part of the *analysis part*. Each standard stipulates security measures in the *specification part*. Tab. 5.2 provides a template (example) how the security measures can look like.

Tab. 5.1: Template (example) for the core specifications of the standards on Level 4 (Orchestration Layer)

[cluster of Taxonomy]		[short description of cluster]
Area in Taxonomy	**Code**	**IT components, procedures, and other subjects**
[area name plus icon]	[code]	[short description of the subject: What is covered? What are main issues? Not more than approx. 50 characters]

Scope and Content:

- [Add a couple of bullet points helping to understand the subject: What are the technical components or activities/practices for which security will be specified? Specify technologies or technical components such as product groups. Mention products without mentioning product names and vendors. Enumerate activities or refer to business processes like the ones defined in ISO/IEC 20000.]

Goals and Objectives:

- [Provide a bulleted list of several security objectives (neither threats, problems, and issues nor requirements or solutions). Specify what needs to be achieved. Outline the secure state and describe briefly what one shall pursue and aim at.]
- [In this way, we are close to stating solutions. The specification of actual solutions is almost impossible without any knowledge about the specific IT system. However, stating security objectives provides the reader with helpful information on what he or she must care for.]
- [The specification of security objectives is always highly recommended since only this allows checking if a specification and an implementation of *security measures* (technologies and practices) is actually suitable and appropriate.]

Primary external support:

- [Provide the name of the area and outline what type of security service is required from there for this measure. The description should be a short reference only. Do not describe full problems and solutions. Only state inputs (services that are required) and not outputs (areas that utilize the area describe in this structure.]
- [More than one dependency may occur. [icon]

When defining a security measure indicate if it a) must always be implemented and enforced ('standard'), b) only applies under certain conditions, for example to meet specific national or industry-specific requirements ('option'), or c) is only implemented at the customer's request ('add-on').

Tab. 5.2: Template (example) for the specification of security measures in the standards on Level 4 (Orchestration Layer)

Security measure: [description/name] ([Code of area]-[Code of measure])
[This is the contract relevant part. Each security measure is given a name which is unique (refer to the line above). Here a specification of the security measure is given by stating security related facts. Instead of "XYZ shall be implemented in order to ensure that…", the description shall be provided as "XYZ is implemented in order to ensure that…" Make also clear if this measure builds upon another (in the same topic area) which shall be referred to using its six-digit code such as TTE-ABC.]

Implementation Guidance:

- [Provide further details and substantiation with examples of implementation or technical detail. Readers are therefore helped to associate the security measure with their own practical experience and knowledge.]

- [The implementation guidance can refer to specific solutions as examples. It can provide tips or explanations. Several bullets can be added as appropriate.]

Rationale:

[A rationale is provided for each security measure which provides justification and additional information about the purpose and benefit of the security measure. Through this, it is also shown that the measures are complete and working together. The rationale feeds back to the definition of security objectives.]

Bibliography

The first list below contains the literature referred to in this chapter. Some of the sources are only available in German. A second list of recommended reading has been added, containing only English references.

References (Sources)

[1] Andreas Spaeth: Airbus A380, der letzte Riese; Motorbuch-Verlag, Stuttgart, 2021, ISBN 978-3-613-04348-0

[2] Eberhard von Faber and Wolfgang Behnsen: A security taxonomy that facilitates protecting an industrial ICT production and how it really provides transparency; in: ISSE 2013 Securing Electronic Business Processes, Highlights of the Information Security Solutions Europe 2013 Conference, Springer Vieweg, Wiesbaden, 2013, pages 87-98, ISBN 978-3-658-03370-5, https://doi.org/10.1007/978-3-658-03371-2_8

Further Literature (Recommendations)

The following book provides an extensive description of the architectural building blocks (chapters 3 and 7-8) as well as of the Maintenance System (chapter 10):

[3] Eberhard von Faber and Wolfgang Behnsen: Secure ICT Service Provisioning for Cloud, Mobile and Beyond (ESARIS: The Answer to the Demands of Industrialized IT Production Balancing Between Buyers and Providers); Springer Vieweg, Wiesbaden 2017, 2nd updated and extended edition, 382 pages, 159 figures, ISBN 978-3-658-16481-2, https://doi.org/10.1007/978-3-658-16482-9

ELECTRONIC SUPPLEMENTARY MATERIAL
The figures are available as a PowerPoint file.
Contact the author by email or via LinkedIn.

6 Secured by Definition

Does the right column in Tab. 6.1 reflect what we perceive as the lived and experienced practice of IT security management? Not a good sign, because this seems to contradict the principles that W. Edwards Deming, pioneer of quality management, formulated. Or is IT security not quality after all? At the very least, it requires quality. If IT security is a quality, a reorientation of IT security management is required. Quality management shows us what is needed. The idea of 'Secured by Definition' is quite simple: Abandon to focus on inspections, audits, warnings, full control, and awareness. Instead, concentrate on creating the conditions that foster good IT security and make securing IT services an inseparable, ordinary part of designing, implementing, delivering, and maintaining IT services. An entire arsenal of measures is required to achieve this.

Tab. 6.1 : Deming's management principles versus practices in IT security management (Source: [1])

Management Principles by W. Edwards Deming	Practice in IT security management
3. "Cease dependence on inspections to achieve quality. Eliminate the need for inspection on a mass basis by building quality into the product in the first place"	Audits, audits, audits; checklists; evaluation; certification; control
7. "…help people and machines and gadgets to do a better job." 10. "…the bulk of the causes of low quality and low productivity belong to the system and thus lie beyond the power of the work force."	Requirements documents: ('what to do') dominate; experience without theory prevails; 'best practices'
8. "Drive out fear, so that everyone may work effectively for the company."	Hacker demonstrations; Threat scenarios
10. "Eliminate slogans, exhortations, and targets for the work force asking for zero defects and new levels of productivity. Such exhortations only create adversarial relationships, as the bulk of the causes of low quality and low productivity belong to the system and thus lie beyond the power of the work force."	Awareness programs; awareness training; newsletters.

© The Author(s), under exclusive license to Springer Nature Switzerland AG 2024
E. von Faber, *Managing IT Service Security*, https://doi.org/10.1007/978-3-031-55533-6_6

6.1 IT Security and Quality Management

What is quality? Sometimes quality is simply understood as the best. Companies claim quality leadership for themselves. However, this idea of quality is difficult to ascertain. That is why quality is often used comparatively. In chess, quality is gained by exchanging a knight for a rook. This understanding also has a disadvantage. You need a loser or you can only ever improve. Where is the goal, when is it enough? If one defines quality as the characteristic that the requirements and expectations of the users (customers) are fulfilled, one shifts the question to the customer and mixes it with sales and sales success. This also makes it unnecessarily complicated. Quality management does not need to worry about the origin of the requirements. Most definitions, however, talk generally about the fulfillment of requirements. But then botch can also have quality: One wanted to do it cheaply and quickly. So, you do not really gain much with such definitions.

But one can also understand quality in this way:

Quality

> Products or services possess quality if they have predefined properties that have been produced in a targeted, repeated, repeatable, and consistent manner. 'Targeted' means that methods have been applied to achieve this. 'Repeated and repeatable' means that the necessary conditions can be produced at any time. In other words, the properties can be produced in a reproducible manner. And 'consistent' means that deviations do not exceed certain threshold values.

This conception has the advantage that it implies a clearly definable task. The attribute 'targeted by applying methods' excludes botch, because botch is characterized by the fact that the purposeful application of methods is missing. The attribute 'repeated and repeatable' demands to understand the conditions that produce certain properties. And the attribute 'consistent' sets the standard, i.e., the conformity with the predefinition within certain limits.

Why do we limit the term quality in this way? Quality management is supposed to be a discipline that depends little on context and gets by without transcendence, complicated market-based feedback, individual assessments, and logical short-cuts.

Quality management

> Quality management encompasses all methods of producing and measuring *quality*, as well as the planning and implementation of measures that are suitable for increasing *quality*. The measures (for increasing quality) influence the methods (for producing quality). The measures influence the conditions of the production of the products or services. These include, for example, work processes, organization, equipment, machines and tools, qualifications of the workforce,

assistance through instructions and training, and resources such as money and size of the workforce.

We do not know whether W. Edwards Deming would agree with such definitions. But they help us to trim the model or metasystem (ESARIS) for IT service security for effectiveness (achieve goals) and efficiency (minimize effort).

W. Edwards Deming is an authority on business management and quality management. His ideas were first implemented very successfully in Japan. Only then did they gain international attention and become the basis for many other management methods. The four points in the left column of Tab. 6.1 are a selection from 14 principles [2] which the author found suitable. The German Wikipedia quotes Deming as saying "Experience without theory doesn't teach management a thing about what to do to improve quality and competitive position." This is also the view of management consultant Eliyahu M. Goldratt, who has become known worldwide for his best-selling novels on business management and process management. They are listed in the bibliography at the end of this chapter and are highly recommended reading.

The essence of quality management is therefore to KNOW EXACTLY why you do what and what effect it has in order to then change conditions in a targeted manner. This is exactly what should be done when it comes to implementing IT security.

However, the definition of requirements ('what has to be done') often predominates. Quality management, however, calls for helping people do their jobs better. See point 7 in Tab. 6.1 (above). We therefore need work instructions ('How to do something') and must design the conditions in such a way that quality (IT security) is produced.

To solve quality problems in IT, task areas were defined and broken down into individual activities to be performed in sequence. IT Service Management (ITSM) was born, and in the form of ITIL®[15] and later ISO/IEC 20000 [3] described. However, ISO/IEC 20000 does not contain any real process descriptions, but provides material for them. Something similar has not been quite attempted for IT security, but it is not necessary. IT security does not need its own manufacturing process, it can and should be part of the provision of IT. And this in turn requires processes, as will be explained in the next section.

---

[15] IT Infrastructure Library®, a collection of predefined processes, activities, and roles along the life cycle of IT services, with particular attention to the operational phase. ITIL and IT Infrastructure Library are registered trademarks of Axelos Ltd.

6.2 IT Security and Processes

Process orientation is not yet old and is a child of industrialized production. IT did not take this step until around the turn of the millennium (not earlier, rather somewhat later). It is therefore worthwhile to look briefly at the transition to industrialized production as a whole. Frederick Taylor (1856-1915) analyzed work methods and processes and divided them into individual activities, each of which was described in detail. He separated the executive and the planning work. Henry Ford (1863-1947) perfected assembly line production in the construction of his cars. Complex work processes were broken down into small activities, the execution of which was prescribed and had to be executed precisely. The assembly line also illustrates the emerging process orientation. But it was not until the 1930s that Fritz Nordsieck (1906-1984) and Karl Wilhelm Henning developed the concept of a process-oriented organization.

In the 1980s, the Total Quality Management (TQM) management method became widespread. It is a synthesis of diverse methods, which were developed in particular by W. Edwards Deming (1900-1993), Joseph M. Juran (1904-2008) and Kaoru Ishikawa (1915-1989), and the path of small steps (Kaizen). In Europe, and especially in Germany, Total Quality Management (TQM) is mainly used in the form of the EFQM Model of the European Foundation for Quality Management (EFQM). In this model, too, processes are important elements of quality management.

Many organizations build their Information Security Management System (ISMS) according to ISO/IEC 27001 [4] and integrate the implementation of this standard into the operational organizational structure in the form of a security management process. This may be sufficient and sensible for activities to ensure corporate security, but it does not apply to the establishment and maintenance of IT service security. The individual security-related tasks are too diverse and different. In addition, they are interwoven with various activities for the provision of IT services.

IT security management is usually under particular pressure: deficits only become apparent when it may already be too late to remedy them. So, one must be very proactive. This in turn is made more difficult by the fact that results are not immediately visible. A vicious circle? At the very least, however, there is another parallel between 'quality' and 'IT service security'.

There are two ways to escape this 'vicious circle':

- Combine (bundle activities) and
- Automate (make activities run automatically).

When combining, one ties the activity that contributes to quality to another that is essential in the sense that it will be performed anyway or with a high probability, or

its absence would be noticeable in any case. For example, one combines a quality-related activity (IT security) with one for the production of a basic functionality (IT service is available).

Automation can be understood as a special form of combining. The clockwork mechanism runs and takes quality-related activities with it. But it also largely eliminates dependence on the availability, motivation, and qualifications of the workforce. It is therefore not necessary to constantly provide them with awareness programs for good IT security (see item 10 in Tab. 6.1 above).

Generally, the rule in quality management is:

- Steer with the help of processes!

The application of these principles leads to a solution that seems unfamiliar to many IT security experts or even meets with their rejection: Let the IT people do it! ...But not entirely without guidance and control.

6.3 The Method

The principle 'Secured by Definition' (definition also in Section 1.5) uses PROCESSES and primarily COMBINING (see above) and relies on ASSISTANCE and SYSTEM CHANGES instead of requirements and controls:

Secured by Definition

> The development, implementation, review, and improvement of all measures to secure IT services, IT systems and IT components is integrated into the development, provisioning, and operating processes of IT along the entire life cycle. IT SECURITY management and *IT Service Management* are merged, and IT service security becomes part of the IT development, provisioning, and operating processes.

IT security does not function as a healing plaster that is prescribed and applied retrospectively. Of course, one must have security in mind right from the start ('Security by Design'). But that is not enough, because today's deployment processes are very multi-layered and operations activities play an important role. The field-proven approach *Secured by Definition* views IT security as a quality that is not created by controls and corrections, but by people following predefined rules at every point in the supply or value chain. This requires an arsenal of measures.

First of all, the division of labor must be discussed, i.e., who is to perform which tasks. This is shown in the upper half of Fig. 6.1.

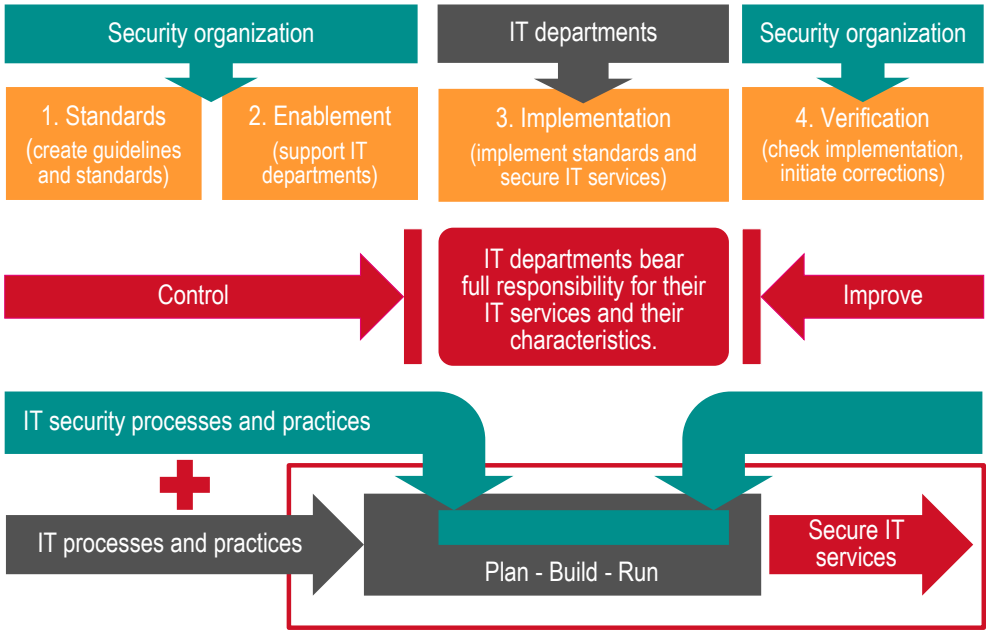


Fig. 6.1: 'Secured by Definition' illustration

The IT departments bear responsibility for the quality of the IT services they provide. IT security can be regarded as one property or quality among others. Producing and maintaining IT service security is thus the responsibility of IT departments. Quality must be generated as part of the development, provisioning and operational processes and cannot be delegated externally and added as a healing band-aid.

Of course, there must be a central IT security organization that defines an overarching security level and ensures that it is achieved. Fig. 6.1 shows the distribution of tasks between a (central) IT security organization on the one hand (No. 1, 2 and 4) and the IT departments (sales, IT production, service management, etc.) on the other (No. 3).

This model (upper half of the Fig. 6.1) is an important basis for *Secured by Definition*. The 'IT departments' (No. 3) provide various services, for the quality of which they are each responsible. If we talk about the 'IT security organization' (see Fig. 6.1), this refers to a (central) IT security organization, which may, however, have its own local units.

NOTE: The following part of this section uses text from [5].

The model only works if there is a clear separation in terms of personnel, defined by roles, between 1, 2 and 4 on the one hand and 3 on the other with regard to IT security. Consequently, security experts should not be assigned primarily to 'topics' but to 'tasks within topics' in compliance with the separation requirement mentioned

above. This is important because otherwise there is a risk that 'IT' will not assume its responsibilities and 'IT security' will not be able or willing to do so, for example, because it is unable to do so in terms of numbers alone. There is also the danger of back delegation: 'IT' (No. 3 in Fig. 6.1) is made aware of the need for corrections by the controlling instance (No. 4). But instead of carrying out the corrections itself, it sees this as the task of the security organization (No. 4). This contradicts fundamental management principles and is not expedient.

Principles from quality management and experience in the industrialization of production can be summarized as follows:

A1 The working methods and the procedures must be determined by a systematic analysis and not by tradition and experience.

A2 The producing, manual work is separated from the creating, mental work. A best method is developed that serves as a rule for all workers.

A3 Supervision of the producing, manual work (by management) is of high importance.

A4 A process-oriented or workflow organization is required in addition to the vertical, product-oriented one.

A5 Quality must be generated, not just measured and verified. Management must define a framework that enables quality.

Applied to IT security, this means the following: A systematic analysis (see A1) is a prerequisite for the quality of all technical, procedural, and organizational security standards. This is to be supported by separating task No. 1 from the others. The separation of design and implementation (see A2) is facilitated by separating task No. 2. And it is common practice (see A3) to see monitoring as a separate task that should not be mixed with the others. In addition to the basic organizational structure, processes are needed (see A4). *Secured by Definition* uses the processes of *IT Service Management (ITSM)* and extends them to include IT security. In this way, IT service security becomes part of the IT development, provisioning, and operational processes. The processes of *IT Service Management (ITSM)* and their extensions for IT service security form the framework specified by corporate management (see A5).

The *Secured by Definition* principle goes far beyond the familiar 'Security by Design', as the latter simply refers to the inclusion of security requirements in unspecified development processes, whereas 'Secured by Definition' integrates security management into IT Service Management processes and subordinates it to them.

Moreover, the traditional design that starts with a blank sheet and primarily considers an application with its associated IT stack hardly exists anymore. This is one reason why activities around IT security are being pushed back in time, since, for example, in the provisioning process of cloud services, prefabricated components are

assembled in a wide variety of ways to form an IT service.[16] Another reason is that IT and its security are anything but error-free and therefore need to be constantly improved. Also, the requirements for IT security are often not so clearly defined at the beginning, or they must always be adapted to the changing circumstances. IT changes due to changes in business processes, which results in changes to IT security. And IT security must follow new threats.

6.4 Implementation

The system of processes as defined by ISO/IEC 20000 [3] is shown in Fig. 6.2. Many of these processes (sequence of activities that pursue a common purpose) must be extended to include aspects of IT security in accordance with the principle of *Secured by Definition*. However, both ITIL and ISO/IEC 20000 remain very vague and make hardly any statements about IT security.

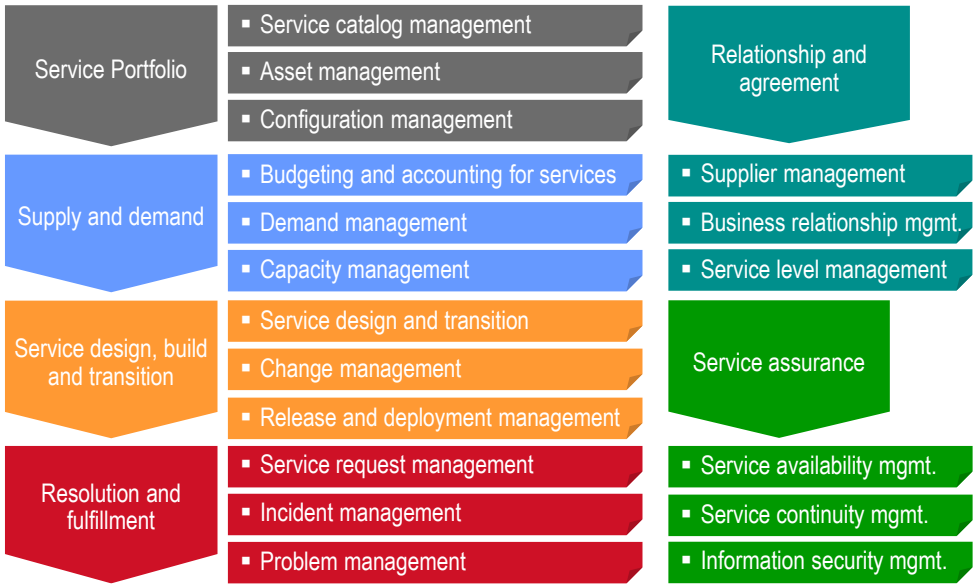


Fig. 6.2: Basic structure of ITSM processes according to ISO/IEC 20000 [3] (Source: [6])

Here are some examples showing how the necessary extensions can look like.

[16] This does not contradict to the principle called 'Shift-left' demanding to do things as early as possible, i.e., during design and development.

Incident Management

- It must be possible to indicate in the tickets that a security incident has occurred, and there must be categories to choose from that allow the type of security incident to be characterized. Predefined categories instead of free text are not only necessary for later evaluation, but also support and accelerate the treatment of the incident by quickly identifying the subject, cause, and the like. This eliminates ambiguities and the need for interpretation at an early stage. The categories also make it easier to assign an incident to a specific team for further processing.
- It must be possible to assess the severity or urgency of treating the security incident by estimating it using a predefined scale. This assessment is necessary to prevent less important incidents from delaying the processing of particularly urgent cases. After all, there are always limited resources available. The assessment of severity or urgency refers to the loss of confidentiality, integrity, or availability and, if possible, includes user dependency.
- It must be possible for relevant groups to report a security incident so that it is then followed up and dealt with. Relevant groups include, for example, contact persons for customers and operating personnel. When automated processes 'report' (register) a security incident, it must be ensured that they are categorized and prioritized as described above and can then be processed.
- Regarding the assignment of tickets, it is recommended to distinguish between responsibility and expertise and to allow to select persons or teams (assignment groups) for both.

Changes (Change Management)

- It must be standard to indicate the source of the requirement. For vulnerabilities in IT products and IT components, the sources of requirements are CERT Advisories (reports from CERT information services) usually identified using a CVE number. This makes it possible to obtain further information, for example, during the review and approval of the change.
- Every change is always checked and approved with regard to possible implementation risks. Approval must not be given if there can be any doubt that the requester has not considered IT security aspects, such as effects on IT security, compliance with applicable standards, contractual obligations, and so on. This applies in particular to major changes and those that have been bundled as part of a release.
- Prior to release (by a so-called Change Advisory Board), it must be possible and explicitly foreseen to involve security experts if this is deemed necessary.
- The above procedure must also function in the case of emergency changes (time-critical changes) and must be applied in a possibly modified form. An

emergency change is usually requested by submitting an incident ticket with the appropriate priority. Emergency changes are used, for example, to implement so-called hot fixes.

Problem Management

- It should be possible to assign the problem or problem ticket to a topic by selecting a predefined category. This makes it easier to identify the processor or the corresponding team (assignment group) and to assign the ticket.
- Regarding the assignment of tickets, it is recommended to distinguish between responsibility and expertise and to allow to select persons or teams (assignment groups) for both. Here, too, it is helpful if the ticket clearly indicates that it is (also) about IT security, which can be easily achieved by selecting an appropriate category.
- Again, prioritization is recommended to prevent the search for causes and solutions for less important cases from delaying the processing of more important cases.
- It should be possible to address a problem (open tickets) even if no damage has occurred or is likely to occur. So, this proactive problem management is not based on a security incident.

Release and Deployment Management

- Current IT service management standards make little or no mention of 'patching' and do not describe what is required for this. This is surprising, because this defect removal by updating the software seems to be necessary almost every day. It is therefore necessary to define a patch procedure consisting of elements such as collection, quality check, packaging, scheduling, testing and initiation of the change (by a 'change').
- Deadlines for updating systems (by means of patching) must be defined. These must be defined for various cases in the form of *Operational Level Agreements (OLA)*, i.e., agreements at the operational level. Otherwise, no Service Level Agreements (SLA) can be defined for customers. The same applies to other changes.
- Provision must be made for customers (user organizations) to be notified of any downtimes due to updates and, if contractually agreed, must also give their consent.
- Before a new 'release' is released, an appropriate 'board' must check whether the IT security requirements are and remain met.

More detailed descriptions and examples can be found in another book by the author ([7], German only).

Summary: In order to implement *Secured by Definition*, the following must be implemented in the Incident, Problem and Change Management processes:

- It must be possible to specify in each ticket that it relates to IT security,
- It must be possible to select an IT security category,
- It must be possible to prioritize the ticket using a metric appropriate for IT security cases.
- Guidance is provided on how to proceed in the event of an IT security incident, problem, or change.

These are perhaps the most important main processes. Of course, other processes must also be expanded and supplemented in order to meet the requirements of IT security. In this book, which is designed as a compendium, we essentially want to leave it at the examples given and only add one more area:

Business Relationship Management

- This process relates to the business aspects and shapes the IT service provider's relationship with its customers, i.e., user organizations. The IT service provider should understand the business environment of the user organizations with its security and compliance requirements. This requires the IT service provider to actively deal with national, international or industry-specific norms, standards, legal regulations and the like, as is to be done within the framework of the → *Endorsement Framework* which represents a special type of Demand Management.
- Relationship management begins with the initiation of business. Marketing and sales must be appropriately adjusted to selling IT service security and work with the existing → *Assurance material*. Contract conclusions must also be based on these materials.
- New customers (user organizations) do not usually start from scratch, but bring with them data and also applications that have to be migrated to the infrastructure of the new IT service provider. Measures are needed to ensure IT security during this transition phase, and these must be defined accordingly.
- However, relationship management also includes interaction in the operational phase. Here, arrangements must be made for how contract changes and major improvement projects are handled. (Interaction in the handling of incidents, problems, and the like, on the other hand, is dealt with in the processes specifically designed for this purpose).

The interactions between the user organization and the IT service provider and the interfaces and processes required for this are diverse and affect the entire life cycle of the business relationship but more than just the business relationship. The author has dedicated an entire book on *Joint Security Management (JSM)* to the organization and processes, the topics and tasks, the interfaces and roles, and the interaction and individual tasks [7].

The *Secured by Definition* approach integrates IT service security into the production or provisioning processes of IT services. The latter can be designed as described in ISO/IEC 20000 [3] and shown in Fig. 6.2 above. The security architecture or metasystem (ESARIS) for IT service security described in this book makes use of the *Taxonomy* described in Chapter 4. It structures the relevant processes or practices somewhat differently. Fig. 6.3 shows relationships between the areas from ISO/IEC 20000 (according to Fig. 6.2) on the one hand and the *Taxonomy* for IT service security on the other.

Fig. 6.3: Important relationships between the Taxonomy (from Chapter 4) and the structure of the ITSM processes from ISO/IEC 20000 (according to Fig. 6.2)

The upper half of the *Taxonomy* described in Chapter 4 contains diverse areas that include all relevant practices along the life cycle of the business relationship between the user organization and the IT service provider as well as all practices for the design, implementation, operation, and continuous repair and improvement of IT services. In addition, the practices on the left and right in Fig. 6.3 concern both the IT service provider and the user organization (the customer). Aspects of particular

importance for IT service security are highlighted and not simply subsumed in an 'information security management' area. All this distinguishes the approach in the *Taxonomy* from that in ISO/IEC 20000, and also provides reasons for the fact that the upper half of the *Taxonomy* does not simply use the processes from ISO/IEC 20000.

Fig. 6.3 therefore does not show any assignment in the direction of equivalence or equality. The figure is intended to facilitate orientation and to show which processes from ISO/IEC 20000 are to be extended by which practices of the *Taxonomy* for IT service security in the sense of *Secured by Definition*..

6.5 Advantages and Final Remarks

So far, the focus has been on the need to integrate IT security and IT service management, and arguments have been made on the basis of experience gained in quality management. By implementing the *Secured by Definition* approach, a basic idea and concept from earlier versions of the ESARIS security architecture, organizations can, however, also benefit significantly. The main arguments are:

- IT service management and IT security management are no longer parallel processes, so that
  - they do not interfere with each other,
  - the process landscape becomes simpler and thus easier to maintain,
  - fewer staff (e.g., ticket agents) are needed.
- It is often impossible to distinguish between IT security and IT functionality/quality anyway (e.g., hardening, incident, patch). This means the following:
  - IT experts (architects, administrators, engineers) have to support, implement and repair the IT security measures (largely or completely) anyway.
  - IT experts are used to follow IT service management (ITSM) processes. It would be problematic and not efficient if they had to follow a different model for IT security simultaneously.
- When IT professionals implement IT security measures, IT security experts can focus on the following:
  - on the development of security policies (which define the level of IT security),
  - on providing guidance and training (to enable IT professionals to implement IT security), and
  - on monitoring implementation, measuring the level of IT security achieved, and providing feedback for improvement.

  This division of labor makes the provision of IT services more effective and efficient. IT security is no longer the cause of delays and an obstacle for IT.

- IT security is moved close to the core IT competencies (and the core business). Therefore, less friction losses are expected and IT security is actually managed and continuously improved.
- IT and IT security professionals are often required to work together. Integration promotes mutual understanding, and both parties begin to speak the same language.
- IT security receives (for example with ISO/IEC 20000 [3]) a tried and tested process model for design, implementation, operation and continuous repair and improvement. Up to now, there is no comparable, universal process model for IT information security or IT security.

The last comment about processes should be discussed a little further. Is there really no process model for IT security? The PDCA cycle adopted from quality management was removed from ISO/IEC 27001 [4] and is not as complete and widely accepted as ISO/IEC 20000 [3] and ITIL for IT Service Management (ITSM). From 2015, NIST has, in the form of the 'Cybersecurity Framework' [8], introduced a simple model that defines five steps, but these are 'concurrent and continuous functions' and do not take the form of a process model.

But with ISO/IEC 27013 [9] there is a standard that provides guidelines for the integrated or joint implementation of ISO/IEC 27001 [4] and ISO/IEC 20000-1 [3]. This standard points to benefits for organizations such as improved external credibility, cost savings and efficiency, elimination of unnecessary duplication of effort, and better mutual understanding of the two domains. In great detail, the standard describes how to prepare and plan the implementation of both systems (sequentially or simultaneously). However, when it comes to the scenario of integrating the two systems, the paper remains quite vague. Essentially, similarities and differences are analyzed. The use of IT service management processes to ensure IT security (as in 'Secured by Definition') is not described and is probably not the aim of the standard.

Bibliography

The first list below contains the literature referred to in this chapter. Some of the sources are only available in German. A second list of recommended reading has been added, containing only English references.

References (Sources)

[1] The W. Edwards Deming Institute, DemingNext, https://deming.org/explore/fourteen-points/, accessed December 13, 2023

[2] W. Edwards Deming: Out of the Crisis; MIT Press, 524 pages, ISBN-13: 978-0-2622-9718-9

[3] ISO/IEC 20000 – Information technology – Service management – Part 1: Service management system requirements, Part 2: Guidance on the application of service management systems

[4] ISO/IEC 27001 – Information technology – Security techniques – Information security management systems – Requirements

[5] Eberhard von Faber: Methods: "Secured by definition" and the utilization of quality management principles, Seamless IT security through integration within IT-production processes; translation of article (https://doi.org/10.1007/s11623-019-1136-0) originally published in: Datenschutz und Datensicherheit - DuD, 43(7), July 2019, Springer Fachmedien, Wiesbaden 2019, ISSN 1614-0702, pages 410-417, https://zero-outage.com/opinion/methods-secured-by-definition-and-the-utilization-of-quality-management-principles/, accessed December 13, 2023

[6] Eberhard von Faber: IT und IT-Sicherheit in Begriffen und Zusammenhängen, Thematisch sortiertes Lexikon mit alphabetischem Register zum Nachschlagen; Springer Vieweg, Wiesbaden 2021, 289 pages, 64 figures, ISBN 978-3-658-33430-7, https://doi.org/10.1007/978-3-658-33431-4

[7] Eberhard von Faber and Wolfgang Behnsen: Joint Security Management: organisationsübergreifend handeln (Mehr Sicherheit im Zeitalter von Cloud computing, IT-Dienstleistungen und industrialisierter IT-Produktion); Springer Vieweg, Wiesbaden 2018, 246 pages, 60 figures, ISBN 978-3-658-20833-2, https://doi.org/10.1007/978-3-658-20834-9

[8] NIST (National Institute of Standards and Technology): Framework for Improving Critical Infrastructure Cybersecurity; Version 1.1; April 16, 2018; https://www.nist.gov/cyberframework, accessed December 13, 2023

[9] ISO/IEC 27013 – Information security, cybersecurity and privacy protection – Guidance on the integrated implementation of ISO/IEC 27001 and ISO/IEC 20000-1

Further Literature (Recommendations)

[10] Edward Russel-Walling: 50 Management Ideas You Really Need to Know; Quercus Publishing, 2012, 240 pages, ISBN 978-1-78087-583-5

[11] ISO/IEC 20000 – Information technology – Service management – Part 1: Service management system requirements

[12] IT Process Wiki - the ITIL® Wiki: This Wiki is about the IT Infrastructure Library ITIL® (ITIL 4, ITIL V3 & V2) and IT Service Management (ITSM): https://wiki.en.it-processmaps.com/, accessed December 13, 2023

[13] Eliyahu M. Goldratt, Jeff Fox: The Goal, A Process of Ongoing Improvement; Gower Publishing Ltd, 2004, 3rd edition, 374 pages, ISBN 978-0-566-08665-6

[14] Eliyahu M. Goldratt: It's Not Luck; Campus, Gower Publishing Ltd, 2002, 388 pages, ISBN 978-0-566-07627-5

[15] Gene Kim, Kevin Behr, George Spafford: The Phoenix Project, A Novel about IT, DevOps, and Helping Your Business Win; It Revolution Press, 2018, 5th edition, 432 pages, ISBN 978-1-942-78829-4

[16] Eberhard von Faber: Methods: "Secured by definition" and the utilization of quality management principles, Seamless IT security through integration within IT-production processes; translation of article (https://doi.org/10.1007/s11623-019-1136-0) originally published in: Datenschutz und Datensicherheit - DuD, 43(7), July 2019, Springer Fachmedien, Wiesbaden 2019, ISSN 1614-0702, pages 410-417, https://zero-outage.com/opinion/methods-secured-by-definition-and-the-utilization-of-quality-management-principles/, accessed December 13, 2023

[17] Chapters 5 and 12 in: Eberhard von Faber and Wolfgang Behnsen: Secure ICT Service Provisioning for Cloud, Mobile and Beyond (ESARIS: The Answer to the Demands of Industrialized IT Production Balancing Between Buyers and Providers); Springer Vieweg, Wiesbaden 2017, 2nd updated and extended edition, 382 pages, 159 figures, ISBN 978-3-658-16481-2, https://doi.org/10.1007/978-3-658-16482-9

ELECTRONIC SUPPLEMENTARY MATERIAL
The figures are available as a PowerPoint file.
Contact the author by email or via LinkedIn.

7 Supply-Chain Relationship Management

The term 'supply chain' can be misleading. A system like the airplane shown in Fig. 7.1 consists of multiple components which in turn are assembled from many components. As a result, the 'chain' is rather 'a tree' though many of the smaller branches may later come together again since they have a common origin and producer. A defect or weakness in any component may spread up to the root causing a serious problem with the airplane in our example. To ensure proper assembly and function, detailed agreements between the participating parties are necessary throughout the supply chain, supply tree or supplier network. The same is true for the equipment and its security used to produce IT services. This chapter presents a systematic approach helping to ensure that appropriate arrangements about IT security are elaborated and agreed. Such agreements require to exactly define the scope of the delivery item and its security features and services.

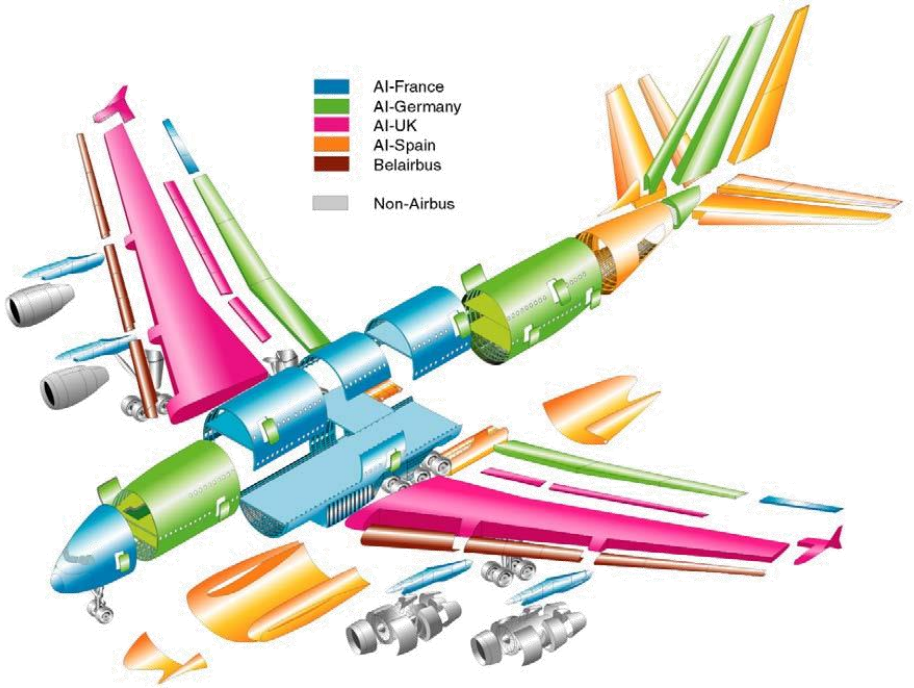


Fig. 7.1: Sources of main components of the A380 airplane (source [1])

© The Author(s), under exclusive license to Springer Nature Switzerland AG 2024
E. von Faber, *Managing IT Service Security*, https://doi.org/10.1007/978-3-031-55533-6_7

It is almost impossible to draw a rather complete picture showing all systems, assemblies and components of a typical IT infrastructure used to produce IT services. Not only that the components used may differ for different IT services, there are too many components in a hierarchy consisting of many levels each with more elements than the one above it. This means that a main question is how deep one zooms in. And this is a question of what the picture should tell.

Most IT architecture diagrams show logical elements because they provide functionality and process data. However, when it comes to procuring equipment for IT service provisioning hardware and software components need to be considered primarily. Fig. 7.2 provides some examples and shall mainly show the hierarchical nesting of the many components. The supply-chain is a complex tree. Many organizations (mostly companies) are involved since most suppliers are specialized and only provide hardware and software components in a few areas.

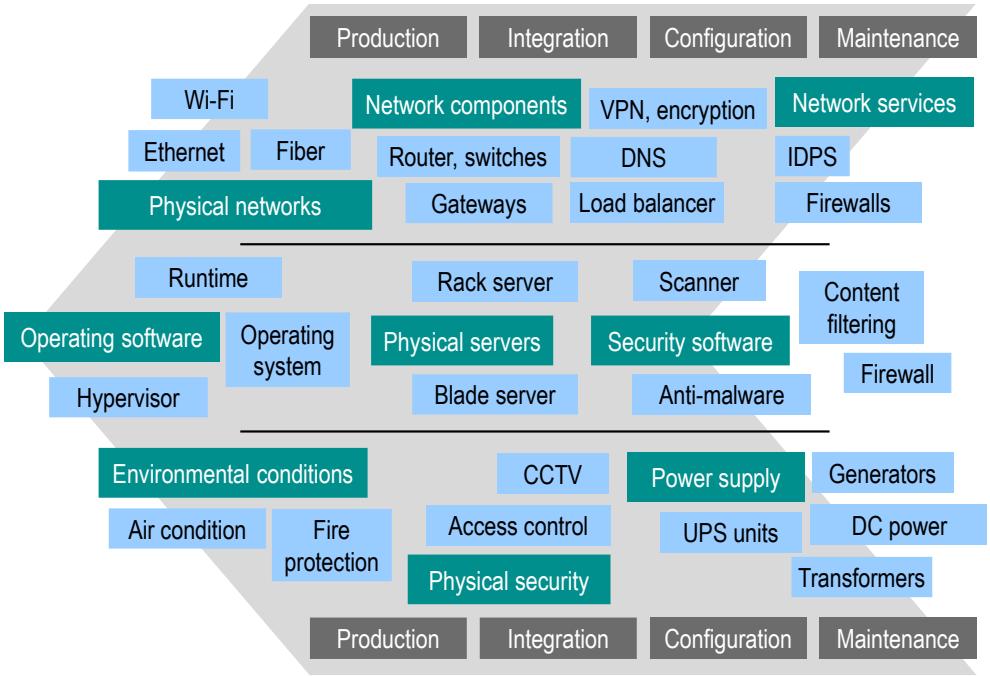


Fig. 7.2: Components of a part of an IT infrastructure with areas and assemblies (dark green) and components (light green) as well as activities (gray) valid for all components

For being able to examine the business relationships in supply chains with multiple tiers, the whole chain or tree will be split into pairs of relationships each with a 'supplier' as the organization that delivers and an 'acquirer' as the organization that procures, receives, and uses the delivered item (product or service).

7.1 Subject Matter and Relation to the Taxonomy

At its core, this chapter describes the so-called *Third-Party Integration Model* which is a constituent part of the security architecture ESARIS (Enterprise Security Architecture for Reliable ICT Services). The model partly overlaps with *Attainment* described earlier in this book (Chapter 2) but focuses on the business relationships in the supply chain. It provides the definition of the so-called *Provider Scope of Control (PSC)* which is an essential concept within *Attainment* to systematically identify the relevant security features of an offering which are then summarized in form of a *Security Proposition*. This term has also been introduced earlier in this book. It is detailed for using it in all stages of the supply chain as a basis for contracting.

NOTE: The Third-Party Integration Model has been totally reworked and fundamentally improved for this book. Nevertheless, this chapter uses material from the publication [2] (with [3] and [4]) of the industry association Zero Outage Industry Standard (ZOIS) and Chapter 9 of the author's book [5]. The standards [2] and [3] were elaborated by the author and brought into final form by him after intensive discussion by members of the association, consideration of feedback and their approval.

The concrete implementation of the *Third-Party Integration Model* shall be specified in a *corporate standard* on IT security assigned to the *Taxonomy* area 'Supply-Chain Management (SCM)'. Refer to Tab. 7.1 (from Section 4.5.1, first term was modified).

Tab. 7.1: Taxonomy area Supply-chain management (from Section 4.5.1)

Taxonomy cluster: Protect	Relevant for supplying parties and also for consuming parties
Supply-Chain Management » SCM «	Organizations integrate components, systems, and services that they procure from supplying parties. The security properties and other characteristics of these components, systems, and services, as well as the possibility of corrections and the process to achieve them, must be analyzed and contractually agreed. But even the selection of suppliers has an impact on IT security.

In addition to the *Third-Party Integration Model* (detailed in Sections 7.2 - 7.5), the standard » SCM « shall specify

- preparatory, continuous activities such as market research,
- preparation of marketing and sales material, as well as
- activities around contracting.

This will be set out in Section 7.6.

7.2 Environment and Problem Statement

Today's IT service provision is characterized by a high degree of division of labor, specialization, and standardization. An apparent element of this division of labor is the fact that user organizations draw on the IT services of specialized IT service providers. This process, referred to as 'IT outsourcing', transfers the responsibility for IT service provision, including security, to the IT service provider.

However, there are other elements. Division of labor can be observed in the internal organizations of large-scale, industrialized IT production, but it expands to the whole supply chain, since partners and suppliers are decisively involved in modern IT service provisioning ('industrialization of IT'). Many hardware manufacturers, software manufacturers, system integrators and service providers are involved for an IT service provided to a *user organization* and ultimately used by it. The latter demand getting secure IT services. It is a challenge to orchestrate the provisioning of *IT services* in a way that every constituent contributes to the overall security so that a secure integrated whole is delivered to the user organization.

Hardware components and software systems are provided by vendors. Moreover, such components are maybe managed by different companies after their initial installation. This means that IT service management activities are not only part of the IT service but provided by companies different from the primary IT service provider holding the contract with the user organization. Today vendors also deliver their systems often as a managed service and no longer as a product that is basically managed by the IT service provider. Storage systems, for example, are offered 'as-a-Service'. The IT service provider purchases the 'Storage as-a-Service' from the manufacturer that is now fully responsible for many IT service management activities relating to the storage system. Typical examples are diagnosis and repair services. This is quite more than software for which the vendor delivers updates and patches. The supplier has direct access to the storage system in the infrastructure of the IT service provider. The same is true for complex data center networks.

The situation is as follows:

- The IT service provider purchases products and services from third parties (suppliers of the IT service provider).
- These third-party products and services are integrated into IT services of the IT service provider.
- The composite IT services are delivered to customers (user organizations).
- The IT service provider is responsible for the composite IT service including the third-party products and services.

Every component, technology, or service, may guarantee an appropriate level of security or even have vulnerabilities. The chain is only as strong as its weakest link.

Eventually, it is the IT service provider being responsible for all IT services according to the contract with the user organization regardless if the services and components are produced by the IT service provider or by one of its subcontractors.

Without a methodology it is likely that security gaps are introduced in such a complex environment. Even if security specifications exist, there is the risk that they are inconsistently applied, interpreted differently, or incompletely implemented. Even if all involved parties do their best with respect to integrating security, there is the risk that not all relevant security requirements are considered and that the combination of components and services is not secure or does not meet the expectations. Current security standards do not provide sufficient guidance to deal with this situation.

IMPORTANT: The methodology described in this chapter shall cover and be applicable to the whole supply chain. This means that the *Third-Party Integration Model* [2]

- covers the entire supply chain end-to-end
- by applying the same methods to all pairs of parties.

Fig. 7.3 shows the generic supply chain (lower part, see also Fig. 1.4) and the pairs of parties in the tiers of the supply chain. From now on, the parties are called 'acquirer' and 'supplier' to generalize the model. The 'acquirer' procures, receives, and uses the product or service which is offered and delivered by the 'supplier'.

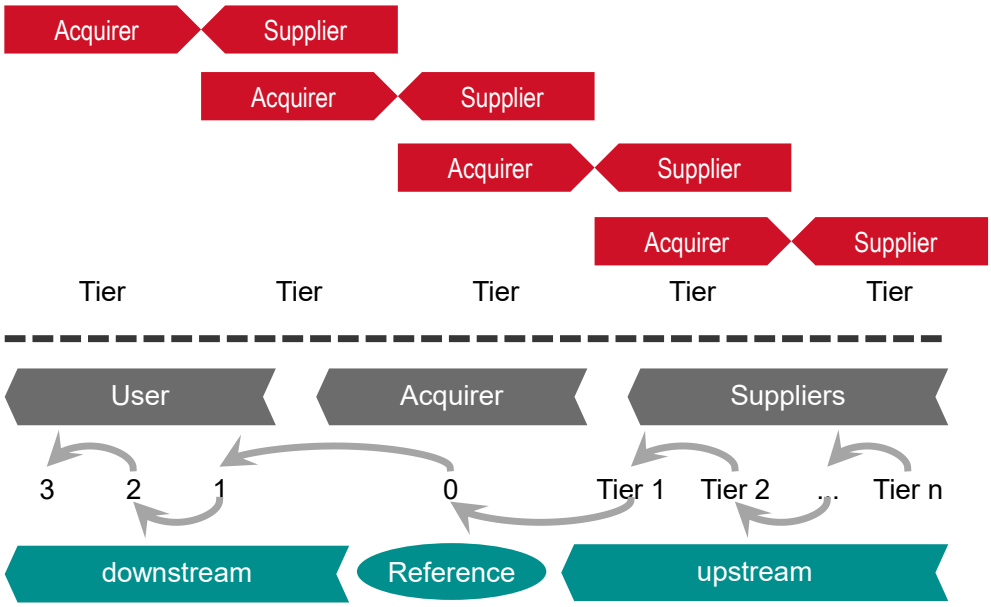


Fig. 7.3: Generic supply chain (lower part) and pairs in Tiers (upper part)

Main problems with respect to IT security include:

- The acquirer
  - assumes that the supplier has adequately integrated a technical security measure,
  - assumes that the supplier has performed activities to provides a security configuration (often called hardening), or
  - assumes that the supplier performs activities to uphold the required level of security (e. g. through patching)

  BUT THE SUPPLIER DID NOT.
- The supplier MISTAKENLY ASSUMES that the acquirer
  - will securely configure the product,
  - will care for upholding the required level of security.

  But the acquirer is not aware or not able to do this.
- The acquirer uses the products or service from the supplier in an unsecure way since
  - the acquirer is not aware that guidance needs to be observed,
  - no guidance was provided.

Problems due to unclear division of labor are visualized in Fig. 7.4.

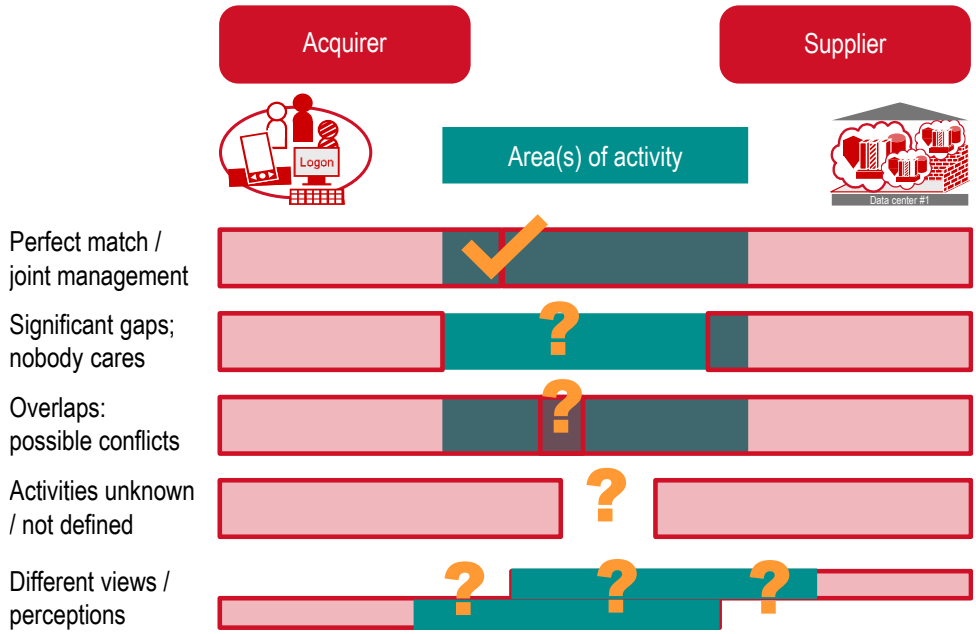


Fig. 7.4: Problems due to unclear division of labor

Note that it is not obvious identifying the right and relevant security measures for a given product, component, or service. Their identification depends e.g. on the application context, on risk appetite and often different solutions are possible. Moreover, in many cases security measures relating to activities during development, integration and operations/maintenance are forgotten; or different scenarios exist since depending on the division of labor (provisioning model or Service Model) either the acquirer or the supplier is responsible for implementing security. It may also happen that both parties share this task.

7.3 Elements of the Concept

IMPORTANT: In the following we assume an open business-to-business (B2B) market with suppliers operating in a one-to-many business model which means that the suppliers offer their products and/or IT services to multiple customers (on the market). For economic reasons and efficiency, it is therefore assumed and recommended that agreements between the parties are based on offers of the supplier (called *Security Proposition*). This does not mean that the acquirer should not issue a Request for Proposals (tender). The point is that customer-driven contracts increase the transaction costs and represents an obstacle to standardization.

Now, the Third-Party Integration Model is explained. Its five constituents are shown in Fig. 7.5 and shall be specified in a corporate standard 'Supply-Chain Management (SCM)' as indicated on the right-hand side of the figure.

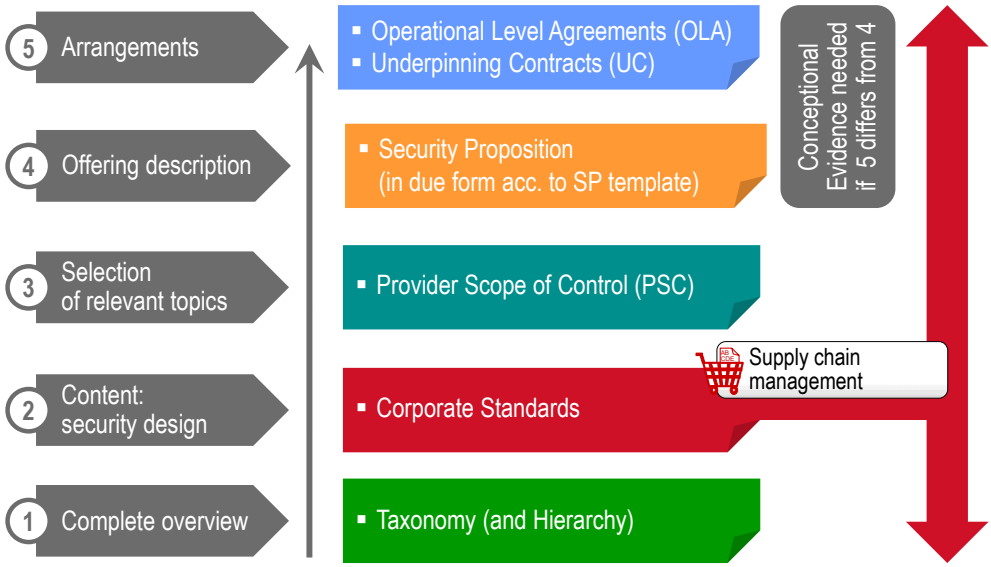


Fig. 7.5: Major elements of the Third-Party Integration Model

Third-Party Integration Model

The equipment used to deliver *IT services* consists of multiple technical components, and various activities are required to design, implement, operate, and maintain the equipment so that the delivered IT service is secure and meets the users' security requirements. Although the IT service is delivered by an *IT service provider*, many components are provided and many activities are performed by third parties (manufacturers, vendors, other IT Service Providers). These third parties (called *suppliers* in the following) usually in turn have suppliers so that the supply chain or network is multi-tier.

The Third-Party Integration Model is a systematic approach that ensures that appropriate arrangements about IT security are elaborated and agreed between acquirers and suppliers. (The 'acquirer' procures, receives, and uses the product or service which is offered and delivered by the 'supplier'.)

There are five constituents in this process. The agreements (No. 5) are based on *Security Propositions* (No. 4) for which security features are selected using a method called *Provider Scope of Control* (No. 3) from *corporate standards* (No. 2) organized using the *Taxonomy* (No. 1) for IT service security. Refer to Fig. 7.5.

1. The *Taxonomy* for IT service security (Chapter 4) provides an overview about all major technologies (lower half) and practices (upper half) that could be required and used to provide the IT service.
2. Whereas the Taxonomy and the specification of its areas provide a rough understanding only, there are *corporate standards* (from both parties) that deliver the security details for each area. These standards are organized in a *Documentation Hierarchy*. The Third-Party Integration Model primarily uses those from the *Orchestration Layer* since these are rather implementation-independent specifications in the broader sense (no products and versions), so that there is a certain amount of freedom to implement the specified IT security.
3. The areas from the *Taxonomy* for IT service security that are relevant to the IT service under review are now selected. Details about related security technologies and practices are provided by *corporate standards* which are assigned to the selected areas. They are examined. This determines the → *Provider Scope of Control*. Provider Scope of Control is also the name of the method for the selection and analysis of details.
4. The above is part of a task called *Attainment* (refer to Chapter 2). A prominent end-result of Attainment is the production of a *Security Proposition*. The Security Proposition enables acquirers (customers) to understand the security features of the offered product or IT service and to make a decision whether to purchase and use the product or IT service from the third party.

To raise efficiency and quality and to decrease transaction costs, the Security Proposition shall be standardized in its structure und subject matter. Therefore, a *Security Proposition Template* is used that standardizes structure und subject matter so that the *Security Propositions* from different suppliers are comparable at least for similar products and IT services.

5. In *IT Service Management (ITSM)*, agreements between internal departments of the IT service provider are called *Operational Level Agreements (OLA)*. If the suppliers are external, independent companies or organizations, contracts are usually signed which are referred to as *Underpinning Contracts (UC)*. The Third-Party Integration Model proposes using these forms of arrangements and enhance them to cover all necessary aspects of IT security. The preparation of such agreements goes hand in hand with the development of a concept for the integration of the supplier's product or IT service into the system or IT service of its contractual partner.

NOTE that the *Security Proposition* of the supplier was called Product Requirement Document (PRD) in earlier versions of the *Third-Party Integration Model* [5] and [2]. The Template for a PRD is now called *Security Proposition Template* . The Third-Party Integration Model is also called Supplier Management Model in [2]. Note that the earlier versions were also considerably extended and improved for this book.

7.4 Provider Scope of Control

The term *Provider Scope of Control (PSC)* could also be 'Supplier Scope of Control'. We continue using the first term. The Provider's Scope of Control (as well as the method to determine it) is relevant both for IT service providers serving user organizations and for any other supplier earlier in the supply chain.

The determination of the Provider Scope of Control (PSC) is necessary for two reasons. Firstly, some technical parts may not be delivered by a supplier. The acquirer needs to know this because it needs to care about these missing parts. For an Infrastructure-as-a-Service (IaaS), it needs to be clear whether the operating system is part of this cloud computing service. And if the user organization provides the (licenses of the) operating system, it may not be clear if it will be securely configured by the cloud computing provider. Secondly, nobody can expect that desktop security standards are adhered to when purchasing a cloud storage service. Sounds strange? I have often seen customers come in with a full list of security requirements, most of which were not at all relevant to the IT service they wanted to buy. But in fact, the tricky issues mostly relate to (security) management activities. Providers say that they prevent and manage security incidents. What does this mean in detail?

The examples are simple cases. In reality, drawing the boundary between the duty of the supplier on the one hand and the duty of the acquirer on the other is one of the most critical questions when it comes to IT service security.

Having a supply chain and division of labor means that no party is providing all functionality and performing all activities. Every party in the supply chain only contributes some functionality and activity. Thus, in order to identify the security features or measures that need to be implemented by the supplier, one must identify the technical components and their functionality as well as the activities or practices relating to providing them.

Here is a definition of the Provider Scope of Control (PSC) in the sense of 'range'. Later another definition is provided for the methodology for determining the PSC.

Provider Scope of Control (PSC): Range

> The Provider Scope of Control (PSC) is determined while the product, system or IT service is developed. It is part of the *Attainment* phase. The results form the basis for implementing IT security measures which in turn are summarized in the *Security Proposition* used to inform the acquirer.
>
> The determination of the Provider Scope of Control (PSC) is the basis for understanding and organizing the division of labor between the supplier and the acquirer. Everything that is outside the Provider Scope of Control (PSC) is either not relevant to the IT service or IT system under consideration or left to any other party in a later stage (tier) of the supply chain.
>
> Provider Scope of Control (PSC) denotes the range within information technology that is provided and ruled by the supplier (or provider). The expression 'range within information technology' refers to both technology (providing functionality) and activities or practices (providing for the quality of the technology that includes IT security).
>
> Relating to a rather complex IT system or IT service, the supplier may only deliver a part of the complex IT system. This part (hardware and software) determines the boundary of its Provider Scope of Control (PSC). The supplier may also not perform or not take responsibility for all activities and practices in design, implementation, integration, operations, and maintenance (of the technology part). This part (activities and practices) also determines the boundary of its Provider Scope of Control (PSC).

Now a methodology is described to determine the Provider Scope of Control (PSC). The best and most straightforward way to understand the PSC is to exactly define the *Service Model* understood in its broader sense (refer to Section 1.1). Here is a short definition using the terms used in this chapter.

Service Model (short)

> The Service Model allows to distinguish different IT services that may appear similar since finally the same functionality is used though the parties involved contribute to this differently. In a more general sense, it implicitly determines the IT components and activities for which the supplier bears responsibility.

For example, IaaS, PaaS and SaaS are all cloud computing services, though they differ in their Service Model. Service Model in its broader sense means that the very details about IT components and their design, implementation, integration, operation, and maintenance are looked at. Often such activities and related practices overlap and are partly assigned to both the supplier and the acquirer. In cloud computing this is often referred to as the Shared Responsibility model [6]. For a more detailed discussion about this model refer to Section 1.6. The *Service Model* (in its broader sense) would provide the necessary detail and indicate which party is responsible for what and what it provides exactly.

A methodology is required that asks the right questions that enable the determination of the Provider Scope of Control (PSC). We now focus on IT security and use means already developed and described earlier in this book. Specifically, we use the *Taxonomy* for IT service security and the *corporate standards* on IT security. Fig. 7.6 provides an overview about the methodology.

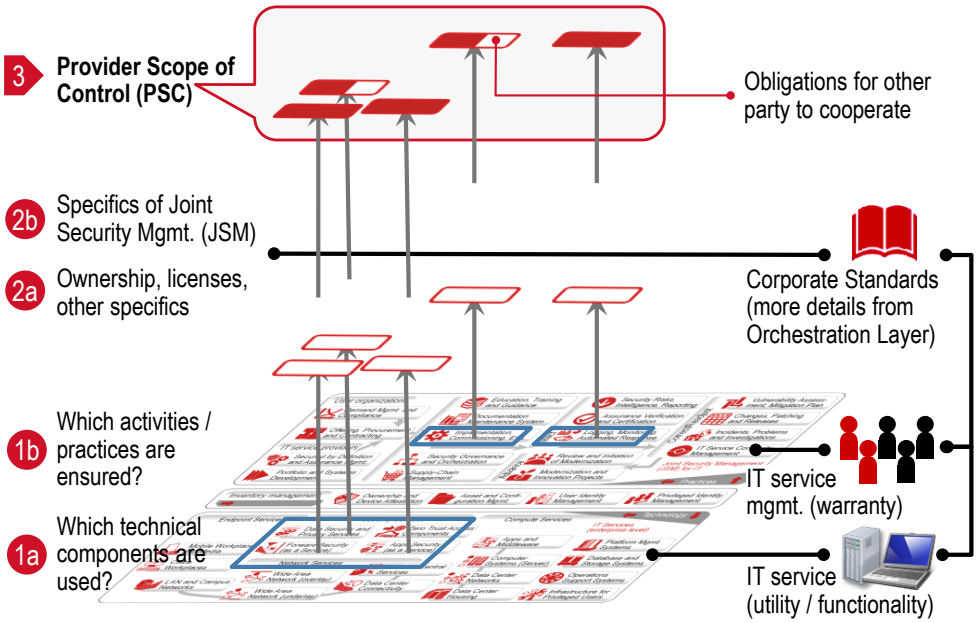


Fig. 7.6: Determination of the Provider Scope of Control (PSC)

Provider Scope of Control (PSC): Methodology

Provider Scope of Control (PSC) is a methodology to determine the IT components and activities for which the supplier bears responsibility. It provides this information relating to IT service security when the *Taxonomy* for IT service security and the *corporate standards* on IT security are used. The methodology defines two steps, each of them being split into two sub-steps.

1a. This step answers the following question: What are the technical components, provided and ruled by the supplier, that are used to deliver the IT system, product, or IT service under consideration? This step is about the functionality called 'utility' in ITIL®[17]. Each area in the lower half of the *Taxonomy* for IT service security is inspected using the definition of the area and maybe associated parts of the *corporate standards* on IT security. All functional elements which are provided and ruled by the supplier are part of the Provider Scope of Control (PSC) understood as range.

1b. This step answers the following question: What are the activities and practices ruled and carried out by the supplier, so that the IT system, product, or IT service under consideration is delivered in time and quality? This step is about how the functionality is designed, implemented, and maybe operated and maintained. This is called 'warranty' in ITIL. Each area in the upper half of the *Taxonomy* for IT service security is inspected using the definition of the area and maybe associated parts of the *corporate standards* on IT security. All activity or practice-oriented elements which are directed and conducted by the supplying party are part of the Provider Scope of Control (PSC) understood as range.

Some finetuning is done after these initial selections.

2a. Regarding the technical components delivering functionality there are maybe other aspects that require consideration. Examples are ownership and licenses as well as options of the offering. In addition, some components may fully be managed but other technical constituents may not. This means that in this step the combination of technical area (lower half of Taxonomy) and practice or activity (upper half) is analyzed again to verify if the supplier actually guarantees adherence to procedural standards for each technical element. There might be exceptions since the supplier itself gets parts from its suppliers and may not take full responsibility for these parts or cannot guarantee the same service levels.

---

[17] IT Infrastructure Library®, a collection of predefined processes, activities and roles along the lifecycle of IT services, with particular attention to the operational phase. ITIL and IT Infrastructure Library are registered trademarks of Axelos Ltd.

2b. The procedural part may also require a more detailed analysis using details from selected *corporate standards* on IT security. The division of labor in the sense of *Joint Security Management* if often more complex than expected. The security of technical components may require the acquirer to follow provided guidance for installation or use. Management activities may require the acquirer to actively contribute. Such aspects are of superior importance and need to be identified.

Note that the *corporate standards* used in the above steps do not tell directly what parts are to be selected. They provide the detailed aspects that are checked for the corresponding offering (IT system, product, IT service) to identify the parts that are within the Provider Scope of Control (PSC).

The determination of the Provider Scope of Control (PSC) results in having a complete security specification of the offering (IT system, product, IT service). It specifies the IT security features guaranteed by the supplier as well as the required contributions from the acquirer plus possible conditions and constraints.

The material is edited to produce the *Security Proposition*. This is detailed in the next section.

7.5 Security Proposition

Role in contract initiation

The acquirer and the supplier must agree upon IT security when the acquirer purchases an IT system, product, or IT service from the supplier. There are different ways for coming to such an agreement. The acquirer can issue a list of requirements (Request for Proposal, RfP) and the supplier can reply with a proposal that is accepted or rejected. In this case, the contract can be based on the RfP, on the proposal or created using both sources and negotiated afterwards. Alternatively, the supplier can specify the security characteristics of the IT system, product, or service whereas the acquirer takes this as the basis for its buying decision. In more complex environments, both parties may again influence the agreement.

Suppliers like product or system manufactures or vendors develop and produce their offerings for a larger market und have multiple customers. Their business model is one-to-many. With increasing industrialization and maturity of the markets many offerings become highly standardized which reduces the complexity of the offerings and the options available. In this case, it is more appropriate that the supplier describes the IT security features of its offering and the mutual contract is based upon this specification that is called *Security Proposition* in this book. This approach reduces the transaction costs for both sides. Transaction costs are the costs for making trade on markets, i.e., costs for offering, researching, and concluding the trade.

For the sake of efficiency, we therefore assume an open business-to-business (B2B) market with suppliers operating a one-to-many business model and contracts are concluded based on the supplier's security specification for IT security (*Security Proposition*). Customer-driven contracts would increase the transaction costs and represents an obstacle to standardization.

Nevertheless, the *Security Proposition* (which was called Product Requirement Document (PRD) in [5] and in [2] with [3] and [4]) may also contain customer-specific features since in IT one size does not fit all.

Security Proposition template

To further reduce the transaction costs and to ease comparing different offerings, it is highly recommended that *Security Propositions* are standardized in content, structure, and level of detail. (For similar reasons, this requirement was also formulated for *corporate standards*.) This can be achieved with a template for the Security Proposition. The template shall define content and structure on the one hand and the level of details on the other hand. Industry associations can develop multiple templates for specific groups of IT systems, products, and IT services. In the following, some general requirements or characteristics are outlined only.

Security Proposition template

Provides guidance for writing a *Security Propositions* and standardizes it to ease its use and reduce transaction costs. A Security Proposition may have five chapters. The minimum content and a possible structure (defined by the template) can be as follows:

1. Description of IT system, product, or IT service including
   - functionality and
   - related IT service management activities

   (This information is usually produced for IT service catalogs or product fact sheets and can be reused here. This chapter defines the offering and does not have to contain any information about IT security.)
2. Identification of relevant security measures:
   - enumeration of the areas (and subareas) from the *Taxonomy* for IT service security with a short outline if required plus
   - short description of associated security measures on the level of detail of the *Orchestration Layer* taken from *corporate standards* and/or from international or industry-specific norms, standards etc.

   (In conjunction with the Chapter 1, this Chapter 2 defines the *Provider Scope of Control (PSC)*. The description is focused in detail on IT security, as the supplier must specify the corresponding measures to ensure IT security.)

3. Assignment of responsibilities for areas and/or security measure
   - in case the contribution of the supplier is incomplete and/or
   - in case the acquirer needs to contribute (duty to cooperate).

   (This Chapter 3 identifies and considers areas of activity, where specific attention is required, and details the division of labor in specific areas. The acquirer may require further help or get prepared for contributing, and/or the parties must carefully adjust jointly managing IT security.)
4. Guidance required by the acquirer (for administrators or privileged users as well as for other users) plus other constraints for the use (if any).

   (This Chapter 4 shall provide or refer to operating instructions for the technical integration of the IT system, product, or IT service into its operating environment, the configuration and maintenance by administrative personnel, and/or the secure usage by end-users. The material provided or referred to herein is essential to prevent the IT system, product, or IT service from being used in an unsecure or vulnerable state.)
5. Role and use of this document.

   (Chapter 5 of the *Security Proposition* provides a short guidance on how to use the document and how it relates to other activities. The chapter can also be used to add legal notices, disclaimers, and provide other information such as exceptions, deviations and compensating measures, options, and general advice.

Both the acquirer and the supplier should be interested in *Security Propositions* that are highly standardized in its structure and general content although marketing and sales departments are often interested in having documents which make general, barely verifiable promises, leave plenty of room for interpretation, stimulate the imagination and focus on real or imagined differences to all other offers especially from competitors. Maybe such a strategy works during the sales phase, but suppliers sometimes forget that they will pay a price afterwards when all the open questions need to be clarified. Missing features produce frustration and friction, and the first security audit may cause everybody to face the facts. Acquirers should insist on clear and tangible contract clauses and encourage their suppliers to be fair, open, and clear. IT security is nothing you can playing games with.

But what does clear and tangible mean? The level of detail (or degree of abstraction) is a decisive point and need to be defined in advance together with structure and content in the *Security proposition template*.

If the level of detail is low (security measures are general), the supplier has much freedom but the acquirer may be provided with too little information for its own risk management, for securely integrating the IT system, product, or IT services in its

operating environment, or for promising security features to the next party in the supply chain.

If the level of detail is high (security measures are detailed), the supplier has little freedom for the implementation. Technical progress requires updating the contract that is based on the *Security proposition*, and the latter cannot be used for products, components and services which serve the identical purpose. These examples clearly show that it is necessary and advantageous to define a level of detail (or degree of abstraction) for the definition of security measures.

The *Third-Party Integration Model* of the security architecture ESARIS (Enterprise Security Architecture for Reliable ICT Services) propose that the security measures should meet the requirements defined for the *Orchestration Layer* in the *Documentation Hierarchy*. Here are requirements for describing the *security measures*:

- The *security measures* and their specification shall respond to a real and tangible issue. The description of the measure shall be a clear and understandable and indicate what the supplier has implemented.
  (Hereby, the focus is on the security outcome and how it is achieved.)
- The *security measures* and their specification shall provide directions / guidance to the supplier for the implementation of security measures
  - in a way that is concrete enough to avoid errors,
  - but flexible enough to allow for technical progress and improvements as well as maintenance and organizational changes in production.
- The *security measures* and their specification shall be suitable for any IT system, product or IT service which shall respond a similar or identical security challenge.
  (This means that the description of the security measures and their implementation can be reused for multiple offerings within the portfolio of the supplier or even on the market.)
- All specified *security measures* and their specifications shall be mutually supportive and have small overlap. The complete set of security measures shall be comprehensive and complete in the given context.

Possible sources for defining such security measures include numerous ISO standards, best practice catalogs as well as solutions developed by the supplier. The methodology described in this book does not prescribe any of those.

7.6 Application

Multi-tier supply chains

It is important that the *Third-Party Integration Model* supports multiple tiers in the supply chain and supports supplier networks as well. This is due to the nature of concepts behind it, namely the *Taxonomy*. The Taxonomy is covering every IT-related area and is highly modular; it organizes security in different areas which can be split into subareas. The specification of security in each area is done in form of single *security measures*. Each security measure defines a feature or activity which can be assigned to an entity (such as a team or a company).

The Third-Party Integration Model is applied to every pair of parties in the supply chain. This is shown in Fig. 7.7.

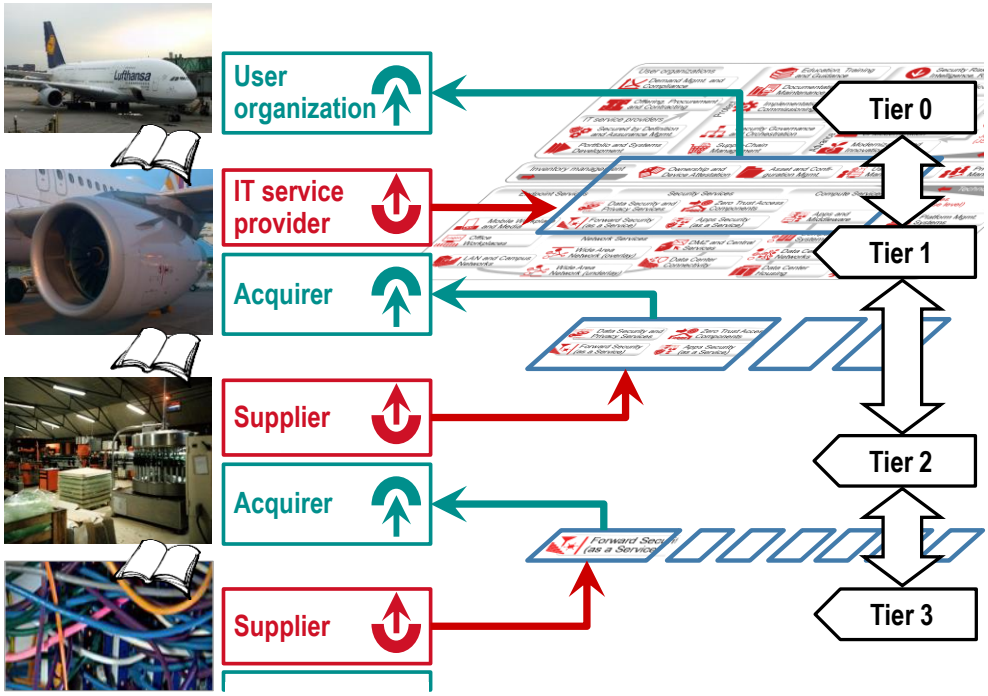


Fig. 7.7: Multi-tier supply chain

When moving deeper into the supply chain, the scope of security specifications becomes narrower and narrower (see Fig. 7.7). In this simple diagram there are four companies (pictures on the left) located in four tiers (indicated on the right). All companies (organizations) act as acquirer and receive an IT system, product, or IT service from the tier below them. All companies (organizations) except the *user organization* are also delivering an IT system, product, or IT service. For each delivering activity,

the *Provider Scope of Control (PSC)* is determined, a *Security Proposition* is elaborated and contracts (either *Operational Level Agreements (OLA)* or *Underpinning Contracts (UC)*) are concluded.

Note that such support is based on rigorous modularity provided by the *ESARIS Security Taxonomy*, by the standardized structure of the underlying *corporate standards* for IT security, by the decision to define all security aspects by means of *security measures* (both technical and procedural) and by the structure and characteristics of the security measures.

The scheme is very flexible and dynamic. The actual security standards are not defined in this book nor the security measures defined in those standards. Here different sources may be used. Only the level of detail of the security measures is defined. Though the *Taxonomy* covers all possible aspects, the filter (called *Provider Scope of Control, PSC*)) ensures that those security measures are used which relate to the IT system, product, or IT service being provided by the supplier and purchased by the acquirer in the supplier chain. Note that every party in the supply chain may have several suppliers. The chain looks more like a tree. This means that an acquirer applies the methods described above to each supplier it is making business with.

Standards for purchasing

All companies (organizations) in the supply chain except the *user organization* act as a supplier and deliver an IT system, product, or IT service. Fig. 7.8 shows to companies A and B. Both are suppliers having their *corporate standards* for IT security which are, on the right in Fig. 7.8, represented by the upper left part of the *Taxonomy*. Their corporate security standards specify activities and practices that need to be observed by company A and B, respectively. Nevertheless, they also define activities and practices (especially in later stages of the life cycle) which may be taken over by the acquirer, i.e. their customers.

Company A and B also have a procurement department and act as acquirer since they require IT components or even IT services from suppliers. The security standards for the procurement department and the procurement process in general can be found in the Taxonomy area denoted 'Supply-Chain Management (SCM)'. Refer to the ellipses in Fig. 7.8.

When company A buys something from company B, company A acts as an acquirer observing its security standards in the area 'Supply-Chain Management (SCM)' (upper half of Fig. 7.8). Company B in turn views company A as its customer (user). This relation is indicated by the big arrow in the middle of Fig. 7.8.

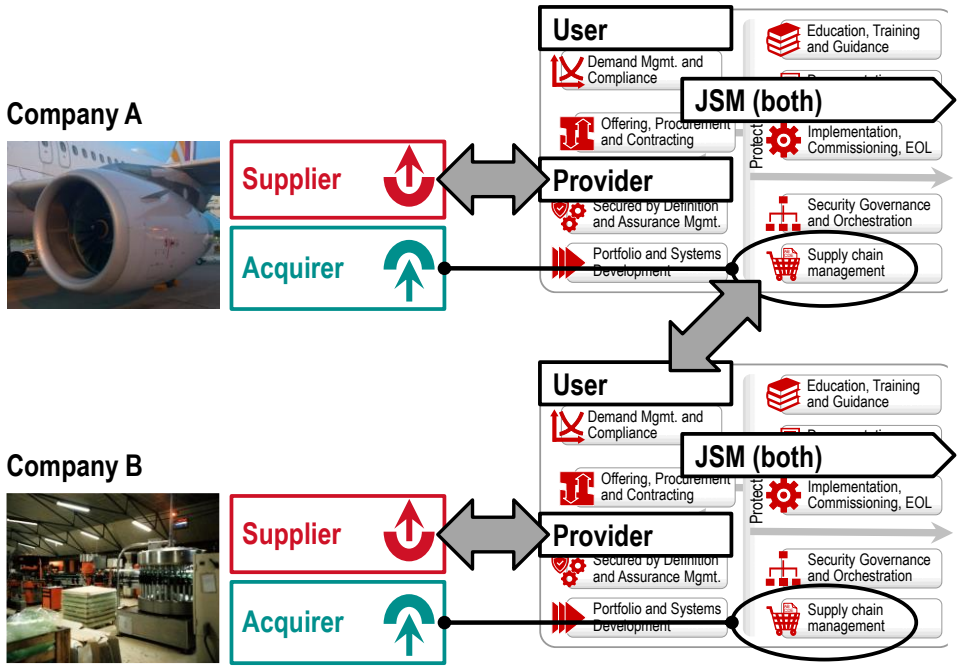


Fig. 7.8: Two companies and their standards in the upper half of the Taxonomy

The corporate security standards in the Taxonomy area 'Supply-Chain Management (SCM)' define security measures to be implemented and observed in the procurement or purchasing process. The standards may again also define duties to cooperate for the supplier. Therefore, the corporate security standards cover own activities as well as the interaction with the supplier. The standards are used whenever IT systems, products or IT services are purchased or otherwise obtained from any third party with the goal to integrate them into a proprietary offering for customers.

As mentioned at the beginning of this chapter, the corporate security standards in the Taxonomy area 'Supply-Chain Management (SCM)' play a major role and define how the *Third-Party Integration Model* is implemented. Moreover, the acquirer must have a plan how to organize the procurement or purchasing process securely. This does not only relate to the provisioning of security requirements and to the agreement with the suppliers. Earlier activities include market research activities. Later activities include acceptance testing.

The security standards shall therefore also specify

- Preparatory, continuous activities such as market research that includes investigations of demands, technologies, products, and vendors,
- Activities of supplier management which help to evaluate, select, and develop vendors,

(The latter may include partner programs set-up to develop and intensify the co-operation between the acquirer and its suppliers to improve the gain from such a relationship.)

- Activities around contracting which includes the preparatory tasks as well as the initiation and the conclusion of contracts. The business relationship is maintained through its life-cycle here,
- Activities of quality inspection, in particular in the form of acceptance testing.

Of course, ensuring IT security is at the heart of all these activities.

Summary

Without a methodology it is likely that security gaps are introduced in such a complex environment like supplier networks in today's IT industry. Even if security specifications exist, there is the risk that they are inconsistently applied, interpreted differently, or incompletely implemented. Even if all involved parties do their best with respect to integrating security, there is the risk that not all relevant security requirements are considered and that the combination of components and services is not secure or does not meet the expectations. Current security standards do not provide sufficient guidance to deal with this situation.

The methodology described in this chapter provides guidance how to organize that IT systems, products, and IT services exchanged in the supplier network are secure and meet the security requirements of the corresponding customers (acquirers). It helps to agree upon security while maintaining the necessary flexibility. The methodology considerably helps to decompose and compose/integrate deliverables and their security features.

The *Third-Party Integration Model* allows managing external suppliers or partners, more specifically, the security of IT systems, products and IT services they are providing. It describes how the *corporate standards* for IT security (organized by means of the *Taxonomy*) are applied in the relationship between the supplier and the acquirer. The Taxonomy decomposes the 'whole world of security' into areas that relate to and can be assigned to individual businesses (i.e. production units like companies, organizations, departments, teams). In this way, it supports the division of labor.

The corporate security standards in the Taxonomy area 'Supply chain management (SCM)' define the sequence of actions for managing the IT security of third-party products and services. One of the security measures defined in these standards shall require defining a so-called *Security Proposition*. This document defines the security measures implemented to ensure delivering a secure IT systems, product, or IT service. The security measures should be defined with a level of detail (degree of abstraction) specified for the *Orchestration Layer*. Though, the Security Proposition

contains or refers to guidance which supports the secure integration of the offering into the user's operating environment and can therefore be very detailed and technical.

The methodology *Provider Scope of Control (PSC)* plays a major role to select the relevant and applicable security standards. The security measures contained therein comprise those relating to (a) functionality of hardware and software, (b) activities and practices ensuring quality and security of hardware and software, and (c) overarching aspects. In this way it can be ensured that all security aspects are considered when managing a supplier network. This is crucial since one of the main problems in complex supply chains is that the responsibility for performing activities in IT service management is not clearly defined and assigned to at least one of the parties.

Bibliography

References (Sources)

[1] Karl-Heinz Mühlnickel: Die Entwicklung des Airbus A380, presentation in Hamburg on November 11, 2004

[2] Zero Outage Industry Standard (ZOIS): Managing security in the supplier network – Third Party Integration Model; Zero Outage Industry Standard, May 2017, 20 pages, https://zero-outage.com/the-standard/security/, accessed December 13, 2023

[3] Zero Outage Industry Standard (ZOIS): Managing security in the supplier network – Template for a Product Requirement Document (PRD); Zero Outage Industry Standard, July 2017, 11 pages, https://zero-outage.com/the-standard/security/, accessed December 13, 2023

[4] Zero Outage Industry Standard (ZOIS): SUSE Linux Enterprise Server 12 - Product Requirement Document (PRD); Zero Outage Industry Standard, June 2018, 18 pages, https://zero-outage.com/the-standard/security/, accessed December 13, 2023

[5] Eberhard von Faber and Wolfgang Behnsen: Secure ICT Service Provisioning for Cloud, Mobile and Beyond (ESARIS: The Answer to the Demands of Industrialized IT Production Balancing Between Buyers and Providers); Springer Vieweg, Wiesbaden 2017, 2nd updated and extended edition, 382 pages, 159 figures, ISBN 978-3-658-16481-2, https://doi.org/10.1007/978-3-658-16482-9

[6] Cloud Security Alliance (CSA): Enterprise Architecture to CCM Shared Responsibility Model; 2020, https://cloudsecurityalliance.org/artifacts/enterprise-architecture-ccm-shared-responsibility-model/, accessed December 13, 2023

Further Literature (Recommendations)

[7] ISO/IEC 27036-1: Information technology – Security techniques – Information security for supplier relationships – Part 1: Overview and concepts

[8] Industrial and Financial Systems (IFS): IFS Information Security Requirements for Third Party Suppliers, IFS Global Policy, 2021

[9] Information Security Forum (ISF): The Standard of Good Practice for Information Security; Information Security Forum, 2018

[10] ISO/IEC 27002 – Information technology – Security techniques – Code of practice for information security management

ELECTRONIC SUPPLEMENTARY MATERIAL
The figures are available as a PowerPoint file.
Contact the author by email or via LinkedIn.

8 Cyber-Physical Systems (IoT and OT)

Engines of airplanes are continuously monitored to identify faults before they cause incidents. About one Terabyte of data is kept per engine and flight. Critical data are transferred to the ground service center during the flights, others after the flight. The data are assessed by the manufacturer of the engine. Maintenance activities are specified in detail and the division of labor between airline and manufacturer is contractually agreed. An engine manufacturer can generate about 50% of its revenue from engine maintenance services. The global expenses are about 25 billion Dollars (2015). Production processes in automotive, process industry and other industries are controlled using information technology and sensors and actuators in factories. Critical IT applications are by far not necessarily located in data centers. That is why, in addition to the organization and orchestration scheme (Taxonomy) for data center-centric IT, another Taxonomy is required that provides an overview of all topic areas for securing Operational Technology (OT) and the Internet of Things (IoT). At the same time, the Taxonomy is a means for assigning responsibilities and for organizing the division of labor. Other new concepts for OT and IoT will also be presented.

Fig. 8.1: IT on the move and in the factory

© The Author(s), under exclusive license to Springer Nature Switzerland AG 2024
E. von Faber, *Managing IT Service Security*, https://doi.org/10.1007/978-3-031-55533-6_8

NOTE: This chapter is based on the publication [1] of the industry association Zero Outage Industry Standard (ZOIS). The standard [2] was elaborated by the author and brought into final form by him after intensive discussion by members of the association, consideration of feedback and their final approval. The Taxonomy presented in this chapter was considerable modified and improved for this book.

8.1 Subject

This book has so far referred to enterprise or office IT which can also be called 'data center-centric IT' because a significant portion of the information and communication technology is housed in data centers. Computing and data storage is mostly data center-centric. Endpoint computers for users are in offices. Smartphones are carried around.

The information and communication technology spreads around and is used for other new purposes and in new environments. The terms Internet of Things (IoT) and Operational Technology (OT) have become established for these new applications.

Internet of Things (IoT)

System of information and communication technology dominated by a high number of physical objects (outside data centers) that have embedded electronics, sensors, actuators, often data processing software as well as network connectivity. The physical objects are endpoints called things. Sensors include cameras and may measure temperature, pressure, position, acceleration, proximity, and a lot more. Actuators typically control movement, position, speed, and other parameters. Typically, a high amount of data is produced that need to be aggregated and processed.

Operational Technology (OT)

System of information and communication technology built for monitoring and controlling industrial production processes and events (outside a data center). Industrial equipment (physical objects) has embedded electronics, sensors, actuators, often data processing software as well as network connectivity. Sensors include cameras and may measure temperature, pressure, position, acceleration, proximity, flow, filling level and a lot more. Actuators control movement, pneumatic and hydraulic pressure and flow, magnetic and electric fields, and other parameters. Typically, availability and low latency (real time) are requirements the system is optimized for.

In the following, the two types of systems are merged and denoted as Cyber-Physical Systems.

Cyber-Physical System

> System of information and communication technology for computing, communicating, sensing, and controlling that interacts significantly with the physical world. A considerable part of the information and communication technology is located outside data centers and is installed in factories, workshops, company campuses, public and private utility, public transportation vehicles and infrastructures, office environments, public spaces etc.

Most methodologies described in this book also apply to *Cyber-Physical Systems*. Though, managing IT security in such systems requires additional methods. Here are some characteristics of data center-centric IT (enterprise IT or office IT):

- Most components are provided by big corporations of the IT industry. Distributions of open-source software are also managed properly.
- IT companies (suppliers/vendors and operators/service providers) have quality standards in place.
- There is considerable control in the supply chain (suppliers are usually known; direct contracts exist between the parties; parties are used to cooperate e.g. in troubleshooting).
- Most of the technical components are located in an environment (data center, office building) that is physically protected. The risk of tampering, theft and manipulations is low especially for equipment in large professional data centers.

None of the above can be assumed for equipment in *Cyber-Physical Systems* (specifically for the elements outside data centers).

In this chapter, IT security is looked at from a comprehensive, wide-ranging perspective. Why? *Cyber-Physical Systems* consist of a multitude of different products and technologies requiring numerous procedures of managing them securely throughout their life cycle. However, we aim at helping to deliver the *how* and not only the *what*. Especially IT practitioners do not want to invest too much in IT security; they prefer advice that is directly actionable. IT security experts can then care about the details and customize the construction so that it finally corresponds with the concrete risk profile etc.

This chapter describes several concepts for securing *Cyber-Physical Systems*:

- A *Taxonomy for Cyber-Physical Systems* helping to manage complexity as well as the division of labor between the parties involved along the supply-chain. The Taxonomy is used to organize all security measures, comprising technology and management activities, stipulated in *corporate standards* on IT security.

- *Classes* helping to stipulate different security solutions for technical components with different capabilities for implementing security. Classes also help to define different procedures of managing security and to stipulate compensating measures.
- *Zones* helping to define greater areas of responsibilities that may also overlap between parties. Zones define the technical and logical boundaries between large subsystems.
- The 'integration stack' allows to restrict a *Zone* to stages of technical integration relating to the depth in the supply chain. Using the 'integration stack', general technical characteristic can be considered when defining *Zones*.

These concepts aim to assist in coping with complexity. The security of *Cyber-Physical Systems* is depending on correctly implementing a multitude of security measures. A single failure or deficiency can put the whole system at risk and compromise IT security completely. Dealing with specific issues too early and implementing point-solutions only will leave issues unsolved. Limiting the scope may result in solving single issues leaving others unchanged.

The concepts combine an overall approach (systems view) with the identification of single work areas (components and activity related view). By doing so, overarching aspects and interdependencies are being considered, and specific work areas are identified for which in turn individual, well-directed activities are stipulated. In this way, the division of labor is supported to combine and orchestrate activities of individual parties in a way that the system can become an integrated secure whole.

8.2 Taxonomy for Cyber-physical Systems

It is not enough specifying technical and procedural security measures. Components are often not developed with a 'Security by Design' approach in mind and many products will most probably not be developed in line with a comprehensive secure 'systems development life cycle' process. Taken this business reality into account, it is time for measures of confinement and compensation which in turn requires having an architectural approach making dependencies visible and showing ways of segregation. It is necessary speaking the language of engineers, developers, and businessmen and not the language of IT security experts. The latter will not be successful without getting the others to care for IT security while following the core practices of their business.

Similar to the *Taxonomy* for data center-centric IT (enterprise IT or office IT) described in Chapter 4, a new Taxonomy for *Cyber-Physical Systems* is introduced now.

IMPORTANT NOTE: This book is designed as a compendium. The two Taxonomies serve the same purpose and follow the same conceptual ideas. Consequently, the

explanations given in Chapter 4 are not repeated in this Chapter 8. Instead, a very short introduction is given and the focus is on explaining the new areas and differences between the two Taxonomies only.

Both Taxonomies follow and implement the same concept:

- The Taxonomy shows several topic areas. Each of them defines and covers a specific work area in which IT security needs to be observed. Thus, the Taxonomy helps navigating through the world of IT security and facilitates communication.
- For each topic area in the Taxonomy, *corporate standards* for IT security shall exist.
- These security standards are assigned to levels (layers) in a pyramid of gradual refinement. Security standards lower in the *Documentation Hierarchy* provide details about the security standards above them. The assignment to Taxonomy areas and related labeling eases the use of the standards.
- The security standards in the *Orchestration Layer*
  - describe major challenges and derive security objectives from them. This is based on a clear definition of the subject of each topic area and the description of possible dependencies to other topic areas.
  - describe *security measures* which comprise (i) properties or characteristics of technical components, (ii) practices and procedures on what and how something should be implemented and enforced, and (iii) combinations of practices and technologies for collecting and managing inventory data.
- The security standards below the *Orchestration Layer* comprise documents providing a specific target group with concrete instructions for designing, implementing, integrating, operating, and maintaining IT security in a specific work area.

Here are a couple of reasons why the Taxonomies have been introduced.

- Complexity: IT security is a multifaceted and sometimes intricate subject. That is why one schematic is required helping to manage this complexity and to digest the large number of security aspects and standards it organizes.
- Specialization: Not everybody, not every team, not every company need to observe all possible security aspects. The Taxonomy helps to identify the content which is relevant in the respective context.
- Definition of scope and security target: The selection of relevant areas, topics and measures from the Taxonomy helps to specify the security features of the IT service, product, or component under consideration. The selection method is called *Provider Scope of Control (PSC)* and the basis for the next topic.

- Supply chain management and contracting: User organizations must rely on IT service providers. The latter must rely on their partners and suppliers, and even those have their suppliers and vendors. Contracts are agreements which should describe all essential deliverables including IT security. The Taxonomy and the *specification concept* behind it serve as the basis for such contracting.
- Speed and flexibility: IT services are produced on a large scale to meet market expectations on cost and quality. Cloud computing is a synonym for this. An almost comprehensive security specification of this environment would fill thousands of pages. A library is required comprising a lot of small documents. This approach scales but requires a Taxonomy for ordering them. Monolithic documents cannot deliver the required information.
- Language and integration: Many frameworks are not easy to understand either for IT experts or for IT security specialists, though both must do their part and cooperate. The Taxonomy uses IT terms as a common language for both and for connecting IT security to the reality of production processes. The Taxonomy also fully integrates *IT Service Management (ITSM)* and IT security management for the first time. In this way, it paves the way to *Secured by Definition*.
- Technical detail and progress: Depending on the system, there are several types of networks which are totally different with respect to technology and security. The Taxonomy splits them – an approach which is not common to many standards. Due to the compound and modular nature of the Taxonomy and the related standards specific areas can simply be updated or even completely be replaced to consider technical progress.

Fig. 8.2 shows the *Documentation Hierarchy* (hierarchy of *the corporate standards* for IT security) and the *Taxonomy for Cyber-Physical Systems*. The areas which are different to the Taxonomy for data center-centric IT, introduced in Chapter 4, are marked with a black frame.

The *Taxonomy for Cyber-Physical Systems* can be used for the *Internet of Things (IoT)*. There are areas e.g. for the 'things' and specific networks. The Taxonomy can also be used for *Operational Technology (OT)*. There is an area called 'Operations Platform' which is essential in this environment since it provides real-time OT services such as abnormal event detection, automation, control, and optimization. Such a platform is connected to a real-time service bus to which all the sensors, actuators and more complex subsystems are connected to.

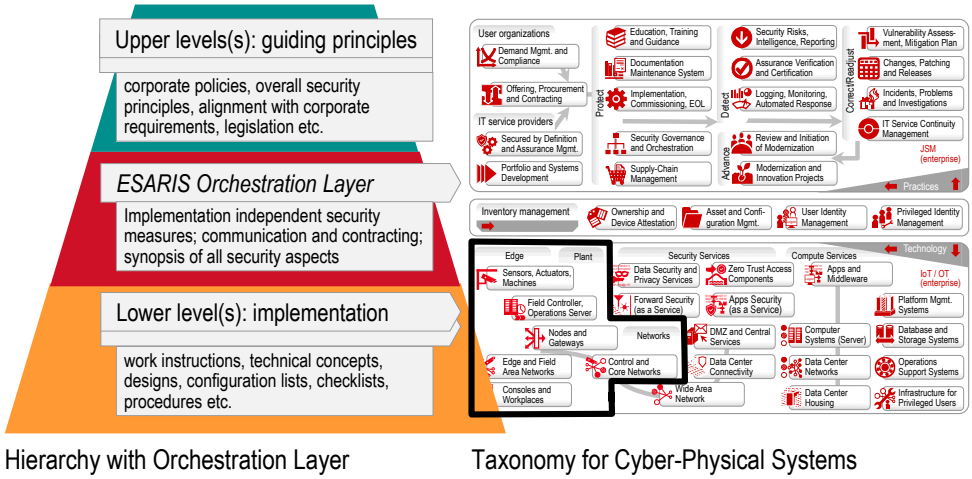


Fig. 8.2: Hierarchy and Taxonomy with areas adapted for IoT/OT framed in black

Fig. 8.3 shows the *Taxonomy for Cyber-Physical Systems* without the pyramid.

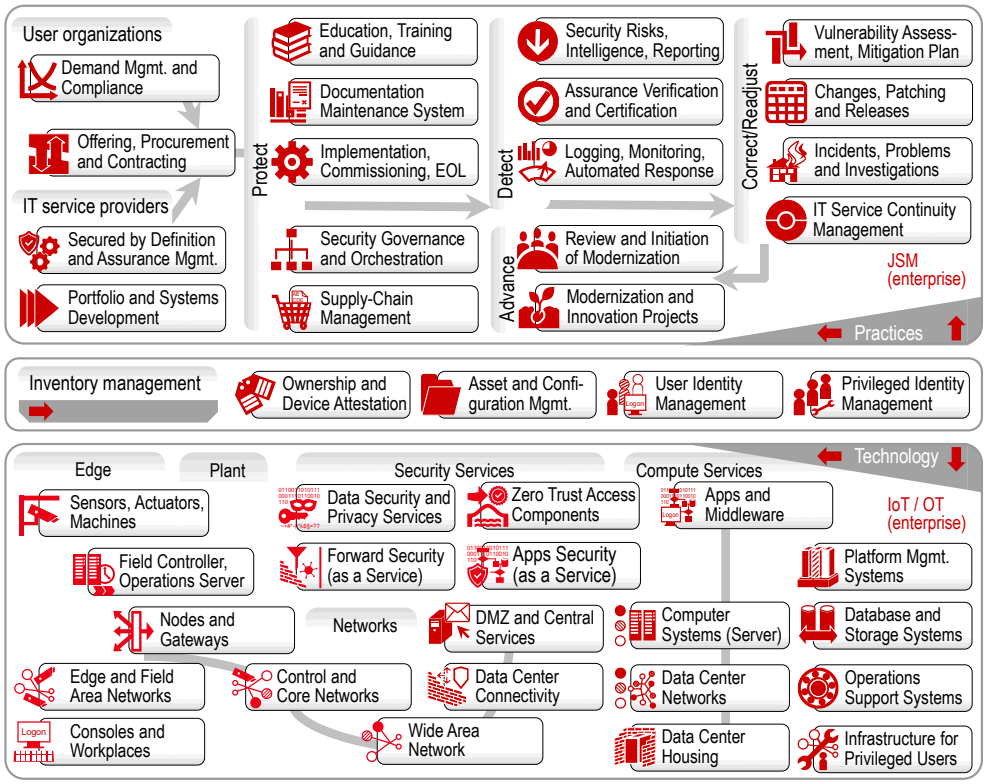


Fig. 8.3: Taxonomy for Cyber-Physical Systems (IoT/OT enterprise)

One can see the three groups of areas:

1. Practices (upper half, see Fig. 8.3, identical with the Taxonomy in Chapter 4),
2. Technologies (lower half) and
3. Combinations of practices and technologies for collecting and managing inventory data ('inventory management' in Fig. 8.3, identical with the Taxonomy in Chapter 4).

The three groups contain clusters ('Inventory management' is its own) and each of the twelve clusters contains topic areas. There are 43 topic areas in total.

The technology clusters and topic areas in the lower half are newly designed for *Cyber-Physical Systems*.

The cluster 'Compute Services' on the lower right has not been changed since the IT services (including cloud computing) delivered from within data centers are on this scale not specific to the *Internet of Things (IoT)* or *Operational Technology (OT)*.

The same is true for the cluster 'Security Services' in the lower middle of the Taxonomy. The 'Networks' cluster is also the same on the data center side (lower right in Fig. 8.3).

The other part of the 'Networks' cluster is modified. The clusters 'Edge' and 'Plant' are new and contain new areas. The areas in these clusters (Edge, Plant and partly Networks) are explained in detail in the next section.

8.3 Profiles of New Taxonomy Areas for Cyber-Physical Systems

The lower half of the *Taxonomy for Cyber-Physical Systems* shown in Fig. 8.3 shows technical areas arranged in two clusters on the left-hand side ('Edge' and 'Plant') as well as the data center areas on the right (cluster 'Compute Services'). Components located on the left deliver data into the data center and use IT services from there. Both sides are connected by networks located between them, especially the Wide Area Networks (WAN) such as the Internet. There are areas in the cluster 'Security Service' above the 'Networks' that provide central security services to protect components located at the 'Edge' and in the 'Plant' as well as in the data centers (cluster 'Compute Services').

The areas in the upper half of the Taxonomy (practices) and in the middle (cluster 'inventory management') may slightly differ in scope and content, goals and security objectives, and details of related security measures for

a) for data center-centric IT (enterprise IT or office IT) described in Chapter 4,
b) the *Internet of Things (IoT)* and
c) *Operational Technology (OT)*.

Though, on a more general level of description they are very similar. The details in the clusters 'Compute Services' and 'Security Services' may be identical. It is up to the related security standards to consider the differences.

Therefore, the only areas that are newly specified by a profile in this chapter are

- Sensors, Actuators, Machines (SAM),
- Field Controller, Operations Server (FCO),
- Edge and Field Area Networks (EFN),
- Consoles and Workplaces (CWP),
- Nodes and Gateways (NGW), and
- Control and Core Networks (CCN).

The profiles are provided in Tab. 8.1 summarizing the technologies, products, solutions, etc. covered by each topic area. The individual security aspects and security measures are not described. This is reserved for the documents/standards of the respective organization to be assigned to each topic area.

Tab. 8.1: Brief profiles of the 'Cyber-Physical' topics

Cluster: Edge, Plant and partly Networks (6 areas)	Relevant for the suppliers and/or the user organization
Sensors, Actuators, Machines » SAM «	De-centrally distributed components and devices such as sensors, actuators, cameras, controllers, home appliances, cars, medical equipment, machines, robots, production facilities, SCADA, PLC and so on. This may comprise systems with a very limited, medium, or even high computing capacity [2]. Many devices, however, are Embedded Systems [3] which are (a) IT systems (b) designed for a specific purpose and not freely programmable, (c) limited with respect to computing power, size, performance, power consumption, costs or the like and (d) interacting with their environments.
Edge and Field Area Networks » EFN «	This comprises networks that connect *Sensors, Actuators, Machines (SAM)* with one another, with *Field Controller, Operations Server (FCO)*, with *Nodes and Gateways (NGW)*, or even directly with *Control and Core Networks (CCN)*. Wired and wireless networks are used. In Operational Technology (OT), high-speed systems are used for the real-time service bus.

Consoles and Workplaces » CWP «	Computer equipment and associated software with a user interface for one person. Consoles mostly designed for stationary use are used by operating personnel to monitor and control devices, networks, and processes. Workstations are similar in terms of technology, but are used in a variety of applications. The workplace software can also be provided virtualized and hosted as an 'application' in the data center.
Field Controller, Operations Server » FCO «	Data center environment with small or medium complexity providing computing services which aggregates and/or preprocesses data from *Sensors, Actuators, Machines (SAM)*. That includes e.g. the collection, normalizing, storage, and computation of data. Other services include managing *Sensors, Actuators, Machines (SAM)*. The computation services of data can be real-time (as mostly required for Operational Technology, OT). The platform can also provide control functions and perform event detection and analysis. In an OT environment the tasks of the platform can be very complex since it controls production processes by controlling a variety of detectors and actuators. In IoT systems this part may not exist, and its functionality is fully provided by *Nodes and Gateways (NGW)*.
Nodes and Gateways » NGW «	These devices act as intermediaries between the *Sensors, Actuators, Machines (SAM)* and the IT services provided from within a data center ('Compute Services', refer to Fig. 8.3). *Nodes and Gateways (NGW)* usually reside between the *Edge and Field Area Networks (EFN)* on the one hand and the *Control and Core Networks (CCN)* or the *Wide Area Network (WAN)* on the other hand. They provide connectivity but also security services (such as authentication) and maybe also management services.
Control and Core Networks » CCN «	Networks that connect the Edge (typical for IoT) and the Plant (typical for OT) with the IT services provided from within a data center ('Compute Service', refer to Fig. 8.3). Often the Internet (referred as *Wide Area Network, WAN*) is directly used.

It is important to understand that there are dependencies between the areas in the upper half and those in the lower of the *Taxonomy for Cyber-Physical Systems* shown in Fig. 8.3 above. The topic 'log management' is a good example. It is located in the upper half of the Taxonomy to ensure that managing logs for IT security is implemented and performed following a global perspective as part of Security Information and Event Management (SIEM). However, local logging is the basis for this and needs still to be implemented or enabled in the technologies described in the lower half of the Taxonomy. Hence, both halves will touch upon the logging topic and define security measures accordingly.

In is worth noting, that even if the areas are identical and their profiles may look equal or similar, the *corporate standards* on IT security may be different for

a) for data center-centric IT (enterprise IT or office IT) described in Chapter 4,
b) the *Internet of Things (IoT)* and
c) *Operational Technology (OT)*.

This will especially be true for standards below the *Orchestration Layer* (describing the implementation) such as work instructions, technical concepts, designs, configuration lists, checklists, procedures etc.

8.4 Classes, Zones, and Integration Stack

Managing IT security in a complex environment such as *Cyber-Physical Systems* requires an organization and orchestration scheme. The *Taxonomy for Cyber-Physical Systems* reuses ideas and elements from the *Taxonomy* described in Chapter 4 which was developed for a different architecture used for the provisioning of office and enterprise IT services. Both Taxonomies use the composition of information technology and of IT Service Management (ITSM) activities. They are not using IT security terms in the first place and can therefore be understood by all involved experts. Nevertheless, *Cyber-Physical Systems* require additional concepts which are introduced in this chapter.

Classes

Classes is a new concept added for *Cyber-Physical Systems*.

Classes

> Classes split security specifications or topic areas of the *Taxonomy for Cyber-Physical Systems* into several parts. But contrary to *Zones*, Classes consider the fact that different security measures are required due to different capabilities for implementing them. Especially smaller devices (called 'things') have, for example, different levels of functional capabilities requiring different security measures to be put in place. If different security measures are implemented in different

devices or sub-systems, compensating measures might be additionally required for one Class of these devices or sub-systems but not in another.

Updating software (often called patching) is a good example for different capabilities. Updating software may not be possible for all types of devices. The execution of strong cryptographic algorithms may require computing power which is not available in some devices. Architectural decisions like connectivity aspects also play a role and determine if specific security measures are necessary as it will be detailed below.

Typical IoT devices ('things') as well as many devices used in OT systems are Embedded Systems.

Embedded System

Embedded Systems are [3]

- IT systems,
- which are designed for a specific purpose and not freely programmable,
- with limitations with respect to computing power, size, performance, power consumption, costs, or the like, AND
- which are interacting with their environment.

Many everyday objects are Embedded Systems or contain them. Examples include cameras, electronic toys, dishwashers, navigation systems, medical devices, monitors, chip cards and chip card terminals. Embedded systems are typical components of the Internet of Things (IoT)

In general, IoT devices may comprise three *Classes*:

Class 1. Plain devices offering a minimal functionality:

- They can, for instance, not be updated and therefore not be 'managed' as often needed to remove vulnerabilities and therefore being desired for better IT security.
- Such devices may, for instance, also not be able to perform complex cryptographic computations as required for secure protocols.
- Typical examples are webcams, 'smart' Bluetooth bulbs, light switches, smoke alarms, temperature sensors, RFID tags, dongles.

Class 2. Embedded Systems in a strict interpretation of the definition:

- They do offer IT functionality that usually includes cryptographic functions, though in a limited manner.
- Software of such devices can usually be updated though also this can be subject to restrictions.
- Typical examples are smartcards, washing machines and refrigerators and TVs (if connected to the Internet), medical devices, airplane components, car multimedia, navigation systems, cheap Internet routers (consumer market).

Class 3. 'Thick' endpoint devices that are not typical for IoT and not really 'Embedded Systems':

- They are provided with an update function and largely programmable. Hardware extensions can often be added e.g. using PC Card, USB and other interfaces.
- Typical examples are mobile personal computers including notebooks and tablets that are programmable and which can be managed.

A specific *Cyber-Physical Systems* may require splitting these *Classes* into further ones. Classes may also be defined differently. The definition of Classes given above shall be considered as a starting point only. In the above organization with three classes, the ability of managing the devices was mentioned as an example. The inability to remediate vulnerabilities by patching software leads to a different security concept and requires the implementation of compensating measures.

IoT devices and smaller components in OT may be located at different places in the overall architecture. Two cases are now distinguished leading to the need of considering the capabilities of implementing security measures in the devices:

A. Direct: The devices are directly connected to a network and reachable from within this network (Edge and Field Area Networks, EFN, or Control and Core Networks, CCN). As a result, there is the possibility that the devices can be manipulated or abused if the adversary has access to the network. This must be considered when analyzing the necessity of implementing security measures in the devices (Classes 1, 2 and 3) and may lead to modifications of implementing security measures.

B. Indirect: The devices are connected to a network (EFN, CCN) via another subsystem only. I.e., they have a direct connection to a Field Controller or Operations platform (FCO) or to Nodes and Gateways (NGW) only and can only be accessed by using functionality provided by FCO or NGW. This functionality limits the access to and interaction with the device. As a result, adversarial access originating from the networks poses the devices to a lower risk compared to case A. Moreover, FCO and NGW can implement compensating security measure which cannot be implemented in the devices due to constraints addressed by the Classes 1, 2 and 3.

The Classes 1, 2 and 3 should be used in conjunction with the two connectivity aspects (A and B) as appropriate. Mixed modes of connectivity may exist.

To summarize, the areas in the *Taxonomy for Cyber-Physical Systems* may specify different security measures (in a topic area) for different *Classes*. The *Classes* must be specified in one security standard of one area so that other security standards or topic areas can refer to it when stipulating security measures. *Classes* is a new

concept that is added for *Cyber-Physical Systems*. It can be necessary to enhance the indication of a *Class* with the connectivity type (direct or indirect).

Zones

Both Taxonomies cover elements which are delivered by different parties. But whereas the original *Taxonomy* for data center-centric IT services is primarily made for IT services delivered by an IT service provider to user organizations in a one-to-many service model, *Cyber-Physical Systems* (especially IoT systems) may consist of rather independent subsystems or, more precisely, combine systems from different areas of responsibilities. Whereas an IT service provider mostly takes full responsibility for the IT service delivered to user organizations, possession and responsibility may be more complex in IoT and OT environments.

To cope with this situation, the concept of *Zones* is added for *Cyber-Physical Systems*.

Zones

> Zones represent different areas of responsibility and define the technical and logical boundaries between them in very complex systems consisting of large subsystems that are developed, implemented, operated, and maintained relatively independently of each other. Zones are used to assign and understand responsibilities. The Zones concept comprises the identification of involved parties and the analysis of their roles.
>
> The Zones concept has similarities with the concept *Provider Scope of Control (PSC)*. The methodology Provider Scope of Control (PSC) is used to accurately characterize and delineate an IT service and to narrow down the scope of responsibility and the range of the contract. Zones are used, however, to roughly split a huge system into loosely coupled sub-systems that can be considered rather separately.

Appropriate separation can be advantageous relating to e.g. the 'Edge' (with the 'things' and related networks), the aggregation and pre-processing part (operations platform and gateways), and the business applications (computing in the data center). *Zones* may overlap.

It can also be useful or even necessary to define different security measures for different applications (which can also be called *Zones*). Defining different security measures for different Zones can be useful or necessary since technologies and risks are fundamentally different. An entertainment area and a traffic signaling system can, for example, show large differences here. Zones can also be considered to reflect the existence of numerous factories with different purpose and construction. Contrary to this, multiple instances of equal or similar factories shall follow one standard.

Integration Stack

Zones are used to assign and understand responsibilities and differentiate different applications which use the same or a similar infrastructure. Since design and implementation errors and related vulnerabilities are passed on to the next level of integration and building up the *Cyber-Physical Systems*, it is advantages to work with a life cycle-oriented, technical view of the system's composition. Such an 'integration stack' is shown in Tab. 8.2.

The integration stack allows to restrict a *Zone* to stages of technical integration relating to the depth in the supply chain. In this way, general technical characteristic (e.g. electronic versus device versus software level) can be considered when defining *Zones* and defining security measures. The stack also helps understanding how faults are passed on to higher stages. Moreover, it helps understanding how security measures should be designed to avoid this progression of faults and to at least allow to fix them afterwards.

Tab. 8.2: Integration stack

Stage	Party (name)	Activity (details)
12	User organization	End-user requiring IT support to run business processes / activities
11	Application management (business process)	Maintains the software that supports business activities; in many cases identical with the 'Application provider' (No. 8)
10	Top-of-stack application operator	Operates the whole IT stack and provides the IT/TC services for the user organization
9	Systems integrator (business process)	Configures and combines application software (for business activities) and infrastructure services
8	Application provider (business process)	Develops software (that will run on top of infrastructure services) that supports business activities
7	Systems orchestrator	Broker, reseller, and/or integrator of different IT or TC services; may add generic business application services
6	Systems operator (infrastructure)	Provides IT or TC services on an infrastructure level (no application software for specific business processes included)

5	Systems integrator (Infrastructure)	Configures components (products) and combines them building a classical IT system (like a network or a computing environment)
4	Component vendor	Delivers (sells) the component; often defines features and thereby takes over responsibility for some design and maintenance features
3	Component provider	Provides platform specific software (firmware) or customized multi-platform software as well as additional component or product specific software; combines this with No. 1 and possibly No. 2
2	Multi-platform software provider	Software that is designed to be used for several hardware platforms; operating systems (OS) or OS kernels are examples
1	Platform provider	Provides hardware (such as System-on-Chip, SoC, and computer motherboards) which executes software, or specific software is developed or adapted to utilize the hardware; also provides hardware specific software such as UEFI and drivers

The integration stack is designed as a generic one. It does not focus on a specific part of the overall supply chain since security issues occur and need to be treated everywhere. The stack is also not technology specific since all technologies can have insufficient security. – Note that the top of the stack is on the top of Tab. 8.2. This is indicated by the 'Stage'. The stack indicates parties or roles and not directly IT components: The parties or roles are contributing along the supply chain that builds the IT stack and finally the IT service consumed by a user organization. The latter is also added as the endpoint but also because it must integrate the IT service into its business which also requires consideration of security. Application management is also part of the chain. This comprises modernization and adaptation of the top-of-stack software but also of the data model and determination how data are processed.

Regarding IT security the integration stack (Tab. 8.2) should be read from bottom to top in the first place since upper layer inherit security features as well as vulnerabilities from layers beneath.

Though, theoretically, security requirements should primarily be defined for the business application (residing on top of the IT stack). These security requirements are then detailed defining security requirements for the layers beneath. This is done

in several steps downwards the IT stack. However, this approach does not really work in practice since siloed IT stacks with only one application on its top rarely exist anymore. In today's industrialized way of provisioning IT services, IT security is built from the bottom to the top and the IT stack should be read accordingly.

Correspondence between all layers is expected to be achieved by a standardization of IT security: This means that lower layers are built with appropriate assumptions on security requirements of layers above. Note that this approach is common practice for functionality and functional requirements. In detail the following is required:

Correspondence

Correspondence is the property that the set of elements of a given layer correctly meets the requirements defined for the layer above it and that both realize the same purpose. This also means that the requirements defined for the upper layer are correctly translated to the layer below it and implemented accordingly. Correspondence is a property of accordance between two layers with different level of abstraction.

Systems are composed of components that get smaller in each step of integration. Processes are structured according to the same principles of hierarchical composition. Security requirements and their translation into measures are gradually refined from the top-layer, usually the application, down to the smallest component. This is required to finally build a secure integrated whole ensuring that it meets the requirements and implements the measures defined for the whole system.

8.5 Application and Outlook

Security requirements for IT components can hardly be derived without knowing anything about the criticality of the data being processed. Moreover, data are retrieved, modified, aggregated, transformed, and processed. From a (high-level) data model one can learn if and how security issues are inherited ('passed on') from one type of data to the next in the data flow and if and how security requirements are inherited ('passed back') from the end-result to the original input values.

An application translates the data into services for defined business purposes. Security requirements (especially those relating to compliance with legislation, industry standards etc.) originate from the business and its environment. Specific details of security requirements depend on protection needs and risk appetite. The latter are different for different businesses and vary from organization to organization.

Though, it is not realistic to start elaborating *corporate standards* on IT security after all details of applications and the data being processed are known. The most IT components were also designed and produced before this (i.e., for multiple applications),

and there are 'infrastructures' used by different applications. Moreover, a great deal of the security measures are just standards and standard due care. These security measures shall be defined having 'typical' applications with 'typical' security requirements in mind. Other security measures can be defined as options which are added in case they are necessary.

The *corporate standards* on IT security in the *Orchestration Layer* play a major role and should be elaborated first:

1. For each topic area, its subject, related security issues and challenges are to be described.
2. Then, a few security objectives are derived and stipulated or specified unambiguously.
3. Dependencies to other topic areas in the Taxonomy as well as (a) limitations and (b) obligations are outlined.
4. Based on this, it is recommended to stipulate about 15 security measures for each area in a standardized manner.

The *security measures* are derived from security objectives for the topic area which in turn are derived from security issues and challenges such as addressing threats. Not more than 15 security measures per topic area would result in having about 600 security measures in total. Note that a given organization will usually not be active in all topic areas and therefore not be required to follow all of them. With these security measures it is possible to manage IT security in a complex environment.

The security standards and measures on the *Orchestration Layer* are providing a level of detail that allows and supports managing IT security comprehensively.

The definition of these security standards and measures, especially for the clusters 'Edge', 'Plant' and 'Networks' should consider *Classes* right from the beginning. *Classes* are mainly important to distinguish possibilities for integrating security measures. However, utilizing *Classes* has also advantages for the overall design. E.g., devices of one *Class* shall be connected to a gateway first since the latter can provide certain security services. Other devices (of another *Class*) may be directly connected to a core network. In this way, the security specification for different topic areas of the *Taxonomy for Cyber-Physical Systems* can easily refer to *Classes* instead of referring to specific products. This eases the specification and avoids frequent updates due to changes in the installed base of devices.

People require directly actionable instructions which are to the point and only providing the information that is just needed for this group of people in a given context. The security measures (or sets of them) are therefore refined and put into the form of work instructions, technical concepts, designs, configuration lists, checklists, procedures etc.

If specific applications and implementations of *Cyber-Physical Systems* are considered, *Zones* may come into play. Areas in the *Taxonomy for Cyber-Physical Systems* may be split into or assigned to different *Zones*. The installed base of IoT devices ('things') may comprise, for example, devices that are in the public domain and others located in a corporate environment. The installation and maintenance of the two groups of devices and related network components may also be performed by two service providers. Assigning the devices to *Zones* makes this fact transparent to systems designers and operators. The so-called 'integration stack' allows to restrict a *Zone* to stages of technical integration relating to the depth in the supply chain.

The *Internet of Things (IoT)* and *Operational Technology (OT)*, subsumed under the generic term *Cyber-Physical Systems* in this chapter, are very diverse and can be more complex than the IT, consisting in a simplified way of client computers, servers, and networks between them, that was called data center-centric IT. Additional concepts like *Classes* and *Zones* were introduced to cope with this reality. Other methodologies described in this book may also require modifications, though this is outside the scope of this book.

Bibliography

References (Sources)

[1] Zero Outage Industry Standard (ZOIS): Security Taxonomy for IoT – Cope with Complexity and Supply Chain; Zero Outage Industry Standard, May 2020, 29 pages, https://zero-outage.com/the-standard/security/, accessed December 13, 2023

[2] Eberhard von Faber and Walter Sedlacek: Using Game Theory to Improve IT Security in the Internet of Things, The Idea of a Durability Date or: What happens if nobody cares?; translation of article (https://doi.org/10.1007/s11623-017-0808-x) originally published in: Datenschutz und Datensicherheit - DuD, 41(7), July 2017, Springer Fachmedien, Wiesbaden 2017, ISSN 1614-0702, pages 440–447, November 2017, https://zero-outage.com/whitepaper/using-game-theory-to-improve-it-security-in-the-internet-of-things/, accessed December 13, 2023

[3] Frank Vahid and Tony Givargis: Embedded Systems, A unified Hardware/Software Introduction; John Wiley & Sons, Inc., 2002, 345 pages, ISBN 0-471-38678-2

Further Literature (Recommendations)

[4] Pallavi Sethi and Smruti R. Sarangi: Internet of Things: Architectures, Protocols, and Applications (Review Article); Journal of Electrical and Computer

Engineering, Volume 2017, Article ID 9324035, 25 pages, https://doi.org/10.1155/2017/9324035

[5] Anthony Sabella, Rik Irons-Mclean, Marcelo Yannuzzi: Orchestrating and Automating Security for the Internet of Things, Delivering Advanced Security Capabilities from Edge to Cloud for IoT; Cisco Press, 2018, 968 pages, ISBN 978-1-5714-503-2

[6] Armando W. Colombo et al (Eds.): Industrial Cloud-Based Cyber-Physical Systems, The IMC-AESOP Approach; Springer International Publishing Switzerland 2014, 265 pages, ISBN 978-3-319-05623-4, https://doi.org/10.1007/978-3-319-05624-1

ELECTRONIC SUPPLEMENTARY MATERIAL

The figures are available as a PowerPoint file.
Contact the author by email or via LinkedIn.

9 Perception, Knowledge, Competencies

Fig. 9.1 shows IT security news from almost a work week. Do you want to work in the field of IT security? Do you want to get involved there? The messages suggest Sisyphean work and a battle that cannot be won. Is it about national defense or police work? Do you have to have strong nerves? Do you have to work around the clock when blackmailers, the cyber group or spyware are about to strike? Even if the news conveys neither a realistic nor a complete picture, the topic of IT security has its peculiarities.

How do we perceive the requirements of IT security? What do we need to know? What should we be able to do? These are the topics of the following essay at the end of this book.

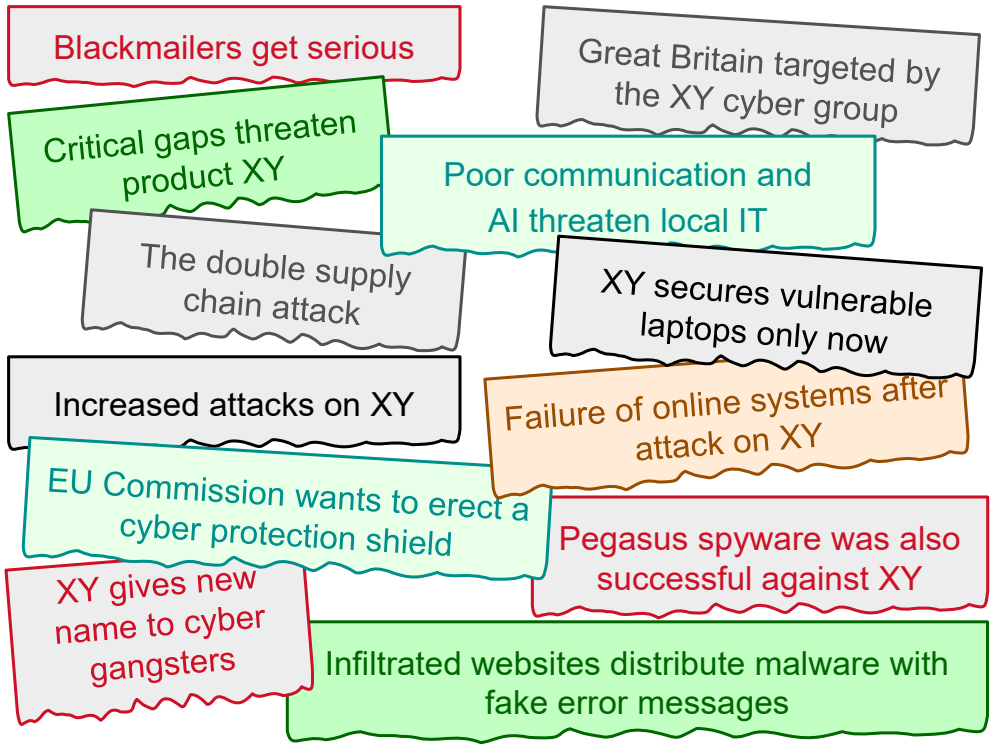


Fig. 9.1: IT security news of a short working week ([1], edited)

© The Author(s), under exclusive license to Springer Nature Switzerland AG 2024
E. von Faber, *Managing IT Service Security*, https://doi.org/10.1007/978-3-031-55533-6_9

9.1 Perception

Confidentiality and Irreversibility

Actually, it is quite simple. If personal information was stolen or trickily captured or simply lost, privacy is violated. It cannot be recovered. If trade secrets have been stolen, this is also irreversible if it got into the hands of those who want to use it for their own business. Since unprotected data can be copied at will, the rightful owner is not missing anything, but others have it. They have migrated into an area that you can control even less than your own. The wounds remain until the information has lost its meaning and value. And that can take time. Active repair is not possible. Neither is creating a replacement.

However, break-ins into computer systems and the theft of data often lead to the victim being blamed. How could he have allowed this to happen? Were the systems not adequately protected? Was there even negligence? Quickly, an organization can be deemed untrustworthy if it has suffered intrusion and data theft. Whether justifiably or not, the reputation suffers. Even if Wilhelm Busch poems "Once your reputation is ruined, you can live quite unencumbered." - the loss of reputation is also not easily repairable. Building a reputation is always more costly and takes longer than losing it. Reliability and trustworthiness are also the most important currencies in business life. While it is a human virtue in private life to forgive mistakes and allow a fresh start, this is only true to a limited extent in business life. If business relationships do not stand up to the strain, economic damage occurs that is irreversible if the company becomes insolvent.

Confidentiality and Perception

The 'outflow of data' is a phenomenon that hardly played a role in the daily life of individuals in the history of mankind and therefore seems strange and inaccessible to us. Of course, people had secrets in the past as well. Classic gossip still thrives on them today. But passing them on was limited to immediate, personal contacts. And, more importantly, forgetting had and still has a cleansing effect, repairing the indiscretion, at least in the long run. Once the dust has settled, everything seems the same as before. Today, disclosure is not limited to personal contacts. Data can be visible to anyone on (anti)social networks. Nor do computer systems forget anything. New layers of sediment are constantly being laid over the old data and obscuring it, but it is still there.

So, it is not that simple: we humans have no real sense of lost data. After all, nothing becomes scarce when it is stolen; we still have it. The loss is not noticeable at first. Only indirectly can the effect of the theft be felt. It is also the case that we find it difficult to measure the value of data. In contrast, a television has a current value, which is calculated from its purchase price, the date of purchase and the price of

currently available, comparable products. Bananas lose their value rather quickly after a few weeks. We can also rate price and value of more invisible things like 10 kilowatt hours of electricity (energy) or 100 gigabytes of data in the mobile network.

Can we measure the time value or replacement value of data when it is not actually gone, but only stolen? Can we basically be grateful to the attackers who encrypt data in order to extort a ransom, because they threaten a real loss that we can really experience? Does this fear increase the willingness to provide adequate IT security?

Integrity

Alongside confidentiality, integrity is the second requirement in IT security or information security. The distinction is not entirely unimportant here because, in principle, it is possible to repair or restore technical components and systems (i.e., IT) if they have been changed, damaged, or manipulated. In the case of electronically stored information (data), this only works if, for example, you have another copy of the data or information that can be used to restore the original information.

If integrity is lost, i.e., if data has been manipulated, we are more likely to be affected because we fear that we are being deceived, exploited, or cheated. However, most possible misuse scenarios are too complex and beyond our imagination, because we are not dealing with the authenticity of a piece of paper lying on a table. Which brings us to integrity's older brother, authenticity (genuineness). Many people succumb to curiosity even in the case of simple attempts at deception (phishing) or are guided by habit.

But loss of integrity or forgeries ('loss of authenticity') are real problems. Something is broken. While physical integrity seems to mean almost everything to us, we care quite little about the integrity of meanings.

Availability

No longer there. Broken. No longer works. Everyone understands that. - Or so they think. The problem here is that the user is relatively indifferent to the cause of the failure and he/she simply complains, and rightly so. The fact that the cause may also lie with the user is not taken into consideration. Availability is a matter for the manufacturer or service provider. It is assumed as a delivery performance and is not a two-sided matter.

More seriously, however, we have become accustomed to errors and failures in IT, or rather we have become accustomed to the unpleasant quality of IT. There is no real guarantee (in the sense of a tangible promise), other than the Service Level Agreements (SLA) with large business customers, and certainly no liability for damages caused by failures and malfunctions. In contrast, there is a legal right to compensation for flight cancellations and significant delays. Even more so, when the

airplanes of predominantly state-owned airlines repeatedly crashed in the early years of passenger aviation, resulting in many deaths, drastic measures were taken. Today, there are rigid requirements and controls that affect the entire life cycle of a passenger airplane. Accordingly, the quality of airplanes has increased dramatically. Currently, states and the European Union are also trying to significantly strengthen regulation in the area of IT and its security. For example, there are regulations for operators of critical infrastructures. Whether this will lead to an overall improvement in the quality of IT remains to be seen.

Accountability

One can understand the accountability as the fourth requirement in information or IT security. Here, it is a matter of actions or results of actions being clearly traceable to and attributable to an identifiable entity. In what is often referred to as the 'analog' world, i.e., when information and data were either communicated directly or stored and communicated using physical carriers, this was still easy, even if it was not always truly successful. But 'digitization', i.e., the machine storage and processing of information and data, has changed many things very fundamentally; and the biggest changes are probably still to come.

The problem regarding accountability (Who is responsible?) arises from the fact that communication is indirect (mediated). This task is taken over by machines (computers) whose mode of operation (programming) is hardly understood by anyone. The computers or their programs also take over the processing of the information and data, and it is often not obvious where they are stored and processed. The manufacturer labels of the devices and the software on our screens are hardly of any help. So, if you ask yourself who is responsible for what, you quickly find yourself confronted with many more questions than there are answers to be found. This is frustrating. Technical solutions, for example, for the secure transmission of emails with proof of origin are explained in technical and obscure terms and are not easy to use, so that their use often fails to materialize or, as with websites, is only partial.

Mix-up and the Bad Image of IT security

The considerations above show that IT security is having a hard time, but perhaps they cannot fully explain it. Are not trust, reliability and sometimes also confidentiality the basis of functioning personal and business relationships? So why do we have such a hard time with IT security?

First, security itself is an abstract concept with many meanings, which in turn can have many nuances. After all, we do not usually talk about confidentiality, availability, and accountability. And even less we talk about secrecy, trustworthiness, reliability and probity, properties that are more or less intuitively understandable.

Second, security has negative connotations. One may have a secure feeling (positive), but rather one gets oneself in safety (evades danger - negative). IT security managers reinforce this by warning about the dangers posed by a lack of security. But everyone is familiar with annoying security checks in buildings and airports, security regulations for fire protection and the discussion about national security, for which data is mainly collected, and international security, where weapons and possible wars are involved.

9.2 Knowledge and Competencies

When it comes to communicating knowledge, one might think that knowledge about damage scenarios and the 'hackers' predominates. This sensitization is probably often necessary, but it is usually not motivating. A worthwhile goal is not proclaimed and, consequently, IT security is perceived as an additional requirement and burden. In a society that relies more and more on motivation and less and less on authority and duty, this is disastrous. The organizers of the 'awareness campaigns' should think about this for once.

But of course, a lot is also done to explain how to configure (harden) systems securely and the like. Users learn how to maintain their computers and how they should generally protect themselves and behave. In IT organizations, on the other hand, the author observes that often too little is done, and in the wrong direction. The issue here is first, again, to educate employees in general (i.e., with general information), and second, primarily to educate IT security personnel. Here, the big lever and the need to deal with IT security lies with the IT staff. On the one hand, it is often underestimated (by IT security personnel) what trained IT personnel know about IT security and usually also put into practice. If, on the other hand, this is lacking, it is primarily the IT personnel who need to be trained. On the other hand, IT personnel are sometimes not given enough credit or expected to do enough. Are the IT security people afraid that they would not be needed anymore? That is incomprehensible, because there is enough to do. If 'IT' does not take sufficient care of IT security, this may be due to a lack of knowledge, but mostly to a lack of specifications (how and not just what), framework conditions (who, when, where) and resources.

"That's just specifications." "This is because of compliance." "Our customers need this." None of these are sufficiently qualified statements. Instead, you should strive for clarity and directness and focus on the following: 1. Where do you want to go? 2. What specifically is to be done and achieved? 3. and why? Formulating and communicating this sensibly is perhaps the most important thing of all. Setting goals, creating framework conditions, and describing tasks, as well as providing justifications. At least the last is often forgotten or confused with defining goals. And often the goals are too general (We should be 'number 1'... We want to grow... etc.).

Being proud of what you have achieved, creating value, or solving problems in a sustainable way are things that spur you on. You have to communicate accordingly and set the incentives.

But what should we foster? Whom do we need? What competencies should be developed? How about the following characteristics or competencies?

> Decision-making skills, listening skills, moderation skills, communication skills, problem-solving skills, an eye for the essentials, structured thinking, quality awareness, an enjoyment of solutions and sustainability, passion, loyalty, a culture of error, a focus on results, and the discipline and willingness to adhere strictly to defined standards and processes.

The author cannot recall ever seeing more than one or two of these items in a letter of application.

Bibliography

References (Sources)

[1] heise Security from April 18-21, 2023 (Heise-Online).

Further Literature (Recommendations)

[2] Bruce Schneier: Secrets and Lies: Digital Security in a Networked World; John Wiley & Sons Inc, 2004, 432 pages, ISBN 978-0-471-45380-2

ELECTRONIC SUPPLEMENTARY MATERIAL
The figures are available as a PowerPoint file.
Contact the author by email or via LinkedIn.

10 Index

IMPORTANT NOTE FOR EBOOK READERS:

> The PAGE NUMBERS in this index correspond to the page count as they appear in the header and in the footer on a chapter's first page. This is for example page 167. The first 12 pages (frontmatter) are NOT counted. So, if your reader now shows page 179 you must always subtract 12 from all the entries in the index.

The explanations or DEFINITIONS OF TERMS can be found in the following directory on the pages with **bold** page numbers. (However, the word processing system may have missed some of this formatting, and they have not been manually added.) If such definitions are referenced elsewhere, the page number is in normal type (i.e., NOT BOLD). This also applies to all other keywords that have been included in this index because of their importance.

==A==

A380 .....1, 119
Access Management 79, 80
Access rights 79, 80
Accountability 164
Acquirer.....123, 126, 128
Airbus A380 1
Airline 3, 164
Airplane.....3, 25, 119, 164
Analysis part (of standards) 92, 93, 100
Application.....6, 7, 8, 9
Application software 6, 7, 8
Asset and Configuration Management..... 42
Asset Management..... 79
Assignment group.....111, 112
Assurance 3, **38**, **55**, 56, 76
Assurance Management 38, 51, **56**, 59, 61, 68, 73, 78
Assurance Material ..26, 31, **38**, 48, 54, 56, 59, 62, 113
Attainment 26, 28, **29**, 38, 39, 41, 43, 47, 121, 126, 128
Attainment Statements.....**29**, 30
Attestation.....79
Authenticity 163
Automated response.....76
Availability 163
Aviation.....3, 164
Awareness campaign 165

==B==

Bibliography (documents) **99**
Business model.....6, 27, 131
Business relationship 13, 69, 72, 113
Business Relationship Management (BRM) 44, 113
Business risk 9

==C==

C4 criteria 34, 74, 99
CASB (Cloud Access Security Broker).....86
Categories 111

© The Author(s), under exclusive license to Springer Nature Switzerland AG 2024

E. von Faber, *Managing IT Service Security*, https://doi.org/10.1007/978-3-031-55533-6

Centralization....2
CERT Advisories 111
Change **77**, 111
Change Advisory Board 111
Change Management 19, 111
Change Request (CR) 34
Change Type (documents) **99**
Classes....144, **151**, 152, 153, 158, 159
Cloud app security 85
Cloud computing 2, 4, 7
Cloud Security Gateway....6, 85
Compatibility 5, 8
Compensation 144
Competitive advantage....6
Complexity 2, 25, 36, 44
Compliance 6, 29, 57, **61**, 62, 75, 93
Computing service **5**
Conceptual evidence31, 38, 39, **40**, 41, 48, 52, 57, 58
Confidence....55
Confidentiality 162
Configuration....41
Configuration Management....79
Confinement 144
Conformity **61**
Consumer 10
Container 7, 8
Continuous improvement 21
Contracting 41, **43**, 48
Corporate security....106
Corporate standards 26, 29, **33**, 34, 35, 43, 47, 91, 121, 125, 126, 129, 130, 131, 132, 136, 138, 143, 145, 146, 151, 157, 158
Corporate Standards (necessity)....**90**
Correctness (measures) 55
Correspondence....**157**
Cost pressure....5
Costs 25, 27
CVE-Nummer 111
Cyber-Physical System ..**143**, 144, 148, 151, 153, 154, 155, 159
Cybersecurity Framework 116

==D==

Data base system 7, 12
Data center 4, 7, 12
Data center-centric IT 142, 143
Data center-centric IT services.... 154
Degree of abstraction 133
Degree of vulnerability 20
Demand 2
Demand side 10
Deming, W. Edwards .103, 105, 106
Digital identity 79, 80
Distributed application.... 9
Division of labor 10, 30, 71, 72, 107, 122, 124, 131
Document Hierarchy 95, 97
Document ID 94, 95, **97**, 98
Document type **94**, 97
Documentation Hierarchy ..**35**, 36, 37, 47, 86, 91, 93, 126, 134, 145, 146
Downtime 112

==E==

Editorial board 34, 74, **99**
Effectiveness 25
Effectiveness (measures) 55
Efficiency 25
EFQM-Modell 106
Embedded System **152**
Emergency Change 20, 111
Endorsement Framework ...29, **33**, 47, 113
Entitlements 79, 80
ESARIS 5, 18, 22, 27, 46, 66, 87, 105, 114, 115, 121, 134
European Foundation for Quality Management (EFQM) 106

Evidence
conceptual.31, 38, 39, **40**, 48, 52, 57, 58
operational32, 38, 39, 40, **43**, 48, 57, 58

==F==

Firewall-as-a-service (FWaaS) 85
Ford, Henry 106
Forensics 77
Fulfillment 26, 29, 30, **31**, 38, 39, 43, 48

==G==

Glossary..... 98
Governance 75

==H==

Hardening 74
Henning, Karl Wilhelm 106
Hierarchy 95, 96
Hierarchy and Taxonomy (necessity) **95**
Hot-Fix..... 112

==I==

Identity Management 79, 80
Identity, digital 79, 80
Impact 20
Implementation 30
Implementation gap 20
Improvement process 20
Incident Management **77**, 111
Industrialization 2, 122
Information Security Management System (ISMS) 75, 106
Infrastructure-as-Code 9
Integration stack 144, 155
Integrity 163
Intelligence 75
Internet of Things (IoT) ...79, **142**, 146, 148, 151, 159
Ishikawa, Kaoru 106
IT as a Service 2
IT as if from the power socket 2, 21
IT component 2
IT department 108
IT outsourcing 9, 21, 122
IT security organization 108
IT service ... 1, 3, 4, **5**, 10, 13, 16, 17, 53, 122, 126
IT Service Continuity Management (ITSCM) 77
IT Service Management (ITSM)**16**, 17, 21, 42, 67, 105, 107, 109, 127, 146
IT service provider.4, 5, **10**, 11, 12, 13, 16, 44, 126
IT stack 7
ITSM process **16**, 18

==J==

Joint provision 29
Joint Security Management (JSM)..22, 28, 31, 32, 42, 67, 69, 71, **72**, 73, 74, 78, 86, 113, 131
Juran, Joseph M. 106

==K==

Kaizen.....106

==L==

Level of detail 133
Library History (documents).....**100**
Library structure 94, 95
Life cycle 13, 16, 69, 72, 113
Log data 76
Logging 76

==M==

Maintenance System 29, 32, 33, **34**, 47, 74, 89, 90, 99
Migration 42
Modification 45, **46**, 48
Monitoring 76
Multi-tenancy 8

==N==

Networking 2
NIST Cybersecurity Framework .. 116
Nordsieck, Fritz 106
Normal Change 20

==O==

Operating environment 2, 92, 93
Operating instructions **44**, 48
Operating system 7, 12
Operational evidence .. 32, 38, 39, 40, **43**, 48, 57, 58
Operational Level Agreement (OLA) 29, **44**, 47, 112, 127, 136
Operational Readiness ... 32, **41**, 44, 48
Operational Technology (OT) 79, **142**, 146, 148, 151, 159
Orchestration..... **36**, 66, 75, 151
Orchestration Layer36, 92, 93, **96**, 126, 132, 134, 138, 145, 151, 158

==P==

Patch management 18
Patching 77, 112
PDCA cycle 116
Platform 14
Portability 8, 9
Portfolio 73
Possibility of influencing 3
Posture management 18
Privacy 162
Privileged user 80
Problem **77**
Problem analysis 93
Problem Management 20, **77**, 112
Process 16
Process model 116
Procurement 73, 74, 136
Product 2, **5**, 53
Proposal 40
Provider Scope of Control (PSC). 121, 126, 127, 132, 136, 139, 145, 154
Provider Scope of Control (PSC) – Methodology **130**
Provider Scope of Control (PSC) – Range **128**
Proxy service 85

==Q==

Qualified instruction 19
Quality 18, 25, 27, 33, 36, **104**, 108
Quality criteria 34, 99
Quality management 103, **104**

==R==

Release **77**, 111, 112
Release and Deployment Management 112
Reliability 162
Reproducibility 90
Request for Proposal (RfP).....40, 125
Reverse proxy 85
Risk 3, 9, 20, 55, 75, 76, 86
Root cause 77

==S==

SASE (Secure Access Service Edge) 86
Scalability 8, 9, 22
Scanner 76
SD-WAN 81
Secure Web Gateway (SWG) 85

Secured by Definition ...**17**, 67, 73, 78, **107**, 108, 109, 110, 113, 115, 146
Security audit **61**, 62
Security bulletin 20
Security by Design 107, 109, 144
Security control..... Security measure
Security Event Management (SEM)76
Security incident 20, 111
Security Information and Event Management (SIEM)..... 76
Security Information Management (SIM) 76
Security measure ..**4**, 18, 20, 33, 55, 92, 93, 96, 97, 101, 134, 135, 136, 145, 158
Security objective 55, 92, 93, 101
Security offer 30, 39, 40
Security Operations Center (SOC)..76
Security posture 18, 43, 75
Security Proposition.30, 38, **39**, 40, 41, 48, 52, 121, 125, 126, 127, 128, 131, 132, 133, 134, 136, 138
Security Proposition template ... 127, **132**, 133
Security report 43
Security reporting 75
Security requirement **94**
Security target 55, 56
Serverless computing..... 9
Service 2, 5
Service catalog 73, 74
Service Delivery Management (SDM) 32
Service Level Agreement (SLA) .. 30, 112, 163
Service Level Management (SLM) . 44
Service Management System (SMS)16
Service Model .5, 6, 21, 41, 52, 86, 128, 129
Service Model (short) **129**
Shared responsibility (model) .22, 129
Shift-left 110
Simplicity 2
Specialization 122
Specification concept **91**, 92, 146
Specification part (of standards) ...92, 93, 100
Specification requirements 34
Standardization ...5, **27**, 29, 36, 48, 122
Supplier (manufacturer, vendor) ...**10**, 11, 12, 44, 123, 126
Supply chain6, 9, 11, 12, 29, 47, 58, 71, 75, 86
Supply side 10
Systems Development Life cycle ..73

==T==

Tags.....97, 98
Target group 35, 92, 94, 96, 97
Target group orientation 96
Taxonomy30, 32, 33, 35, **36**, 37, 47, 66, 72, 86, 90, 91, 95, 96, 97, 114, 115, 121, 126, 129, 130, 132, 135, 136, 138, 144, 146, 151
Taxonomy for Cyber-Physical Systems143, 146, 147, 148, 151, 153, 158, 159
Taylor, Frederick 106
Tender 40
Thesaurus.....98
Third-Party Integration Model.....121, 123, **126**, 127, 134, 135, 137, 138
Threat 93
Total Quality Management (TQM)18, 106
Trade secret 162
Transaction costs 125, 127, 131, 132
Transparency 3
Trustworthiness 3, 38, **55**, 56, 162

==U==

Underpinning Contract (UC) ... 29, **44**, 47, 127, 136
User **10**, 11, 12
User organization 3, 4, 5, **10**, 11, 12, 13, 17, 122, 135, 136

==V==

Virtual machine (VM) 8
Virtualization layer 8
Vulnerability 19, 20, 56, 73, 76, 86, 111
Vulnerability Management 18, **19**

==W==

Work around..... 77

==Z==

Zones.....144, 151, **154**, 155, 159